EUROPEAN COMMISSION
欧盟委员会

Brussels, 27.7.2026　布鲁塞尔，2026年7月27日
C(2026) 5252 final

ANNEX — Commission guidance on the application of Regulation (EU) 2024/2847 (Cyber Resilience Act)
附件 — 委员会关于适用条例(EU) 2024/2847（《网络弹性法案》）的指南

译本说明（不属于委员会原文）

本文件是欧盟委员会文件 C(2026) 5252 的中英对照译本。英文按原文照录；中文是对照译文，不增加、不删去原文的实质内容。条例编号、日期、网址与原文保持一致。图示保留原图，图下只列出图内已有文字的中文对照。本译本不具有委员会文件的法律效力；对《网络弹性法案》的权威解释只能由欧洲联盟法院作出。

Translator's note, not part of the Commission text. English follows the source. Chinese is a parallel translation and does not add or remove substantive content.

Contents
目录

1 Introduction
1 导言
- 1.1 The Cyber Resilience Act
- 1.1 《网络弹性法案》
- 1.2 Purpose of the guidance
- 1.2 本指南的目的

2 Scope
2 适用范围
- 2.1 Placing on the market
- 2.1 投放市场
- 2.2 Software as a product with digital elements
- 2.2 作为含数字元素产品的软件
- 2.3 Computer code
- 2.3 计算机代码
- 2.4 Combination of hardware and software forming a product with digital elements
- 2.4 硬件与软件组合构成含数字元素产品
- 2.5 Data connection
- 2.5 数据连接

2.6 Complex systems
2.6 复杂系统
2.7 Products with digital elements designed before the CRA entered into application
2.7 在CRA开始适用之前设计的含数字元素产品
3 Free and open-source software
3 自由及开源软件
3.1 Determining if free and open-source software is under one’s responsibility
3.1 确定自由及开源软件是否处于某人的责任之下
3.2 Determining if free and open-source software is placed on the EU market
3.2 确定自由及开源软件是否被投放欧盟市场
3.2.1 Charging a price
3.2.1 收取价款
3.2.2 Monetisation of other services or requiring the processing of personal data
3.2.2 变现其他服务或要求处理个人数据
3.2.3 Support services
3.2.3 支持服务
3.2.4 Donations
3.2.4 捐赠
3.2.5 Financing of free and open-source software
3.2.5 自由及开源软件的资助
3.2.6 Not-for-profit entities set up to achieve not-for-profit objectives
3.2.6 为达成非营利目的而设立的非营利实体
3.2.7 Integration by other manufacturers
3.2.7 由其他制造商集成
3.3 Open-source software stewards
3.3 开源软件管理者
3.3.1 Sustained support and ensuring viability of FOSS
3.3.1 持续支持并确保自由及开源软件的存续
3.4 Contributors and downstream uses
3.4 贡献者与下游使用
3.5 Illustrative scenarios
3.5 示例情形
4 Substantial modifications and spare parts
4 实质性修改与备件
4.1 Physical repairs
4.1 物理修理
4.2 Spare parts
4.2 备件
4.3 Software updates as substantial modifications
4.3 作为实质性修改的软件更新
4.4 Consequences of a substantial modification
4.4 实质性修改的后果
4.4.1 Substantial modifications carried out by a person other than the original manufacturer
4.4.1 由原始制造商以外的人实施的实质性修改
4.4.2 Substantial modifications carried out by the original manufacturer
4.4.2 由原始制造商实施的实质性修改
5 Support period
5 支持期

5.1 Substantial modifications and the support period
5.1 实质性修改与支持期
6 Important and critical products with digital elements
6 重要和关键的含数字元素产品
6.1 Core functionality
6.1 核心功能
6.2 Conformity assessment for important and critical products with digital elements
6.2 重要和关键含数字元素产品的合格评定
6.3 Implications for presumption of conformity
6.3 对符合性推定的影响
7 Cybersecurity risk assessment and integration of products with digital elements and components
7 网络安全风险评估以及含数字元素产品和组件的集成
7.1 On the evaluation and treatment of cybersecurity risks
7.1 关于网络安全风险的评估和处理
7.2 On designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks
7.2 关于以基于风险确保适当网络安全水平的方式设计、开发和生产含数字元素产品
7.3 Risk assessment and due diligence in relation to external dependencies and integrated components
7.3 关于外部依赖项和集成组件的风险评估与尽职调查
7.4 Reuse of risk assessments and conformity documentation for families of products with digital elements
7.4 含数字元素产品族的风险评估和合格文件的再利用
8 Remote data processing
8 远程数据处理
8.1 What is considered a remote data processing solution for a product with digital elements?
8.1 何为含数字元素产品的远程数据处理解决方案？
8.1.1 The notion of ‘at a distance’
8.1.1 “在远程进行”这一概念
8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions?
8.1.2 如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？
8.1.3 Has the software been designed and developed by the manufacturer, or under its responsibility?
8.1.3 软件是否由制造商或在其责任下设计和开发？
8.2 Practical and technical implications of remote data processing solutions and reliance on third-party solutions
8.2 远程数据处理解决方案以及依赖第三方解决方案的实际和技术影响
8.3 Use cases for remote data processing solutions
8.3 远程数据处理解决方案的用例
8.3.1 Mobile banking application
8.3.1 移动银行应用程序
8.3.2 Smart thermostat
8.3.2 智能恒温器
8.3.3 e-Reader
8.3.3 电子阅读器
8.3.4 Industrial robot
8.3.4 工业机器人
8.3.5 Cellular network
8.3.5 蜂窝网络

9 Additional elements
9 其他要素
9.1 Reporting obligations
9.1 报告义务
9.2 Vulnerability handling
9.2 漏洞处理
9.2.1 Reporting upstream and sharing security fixes
9.2.1 向上游报告并分享安全修复
9.2.2 Known exploitable vulnerabilities
9.2.2 已知可利用漏洞
9.2.3 Effective and regular tests and reviews
9.2.3 有效且定期的测试和审查
9.3 Interplay with other legislation
9.3 与其他立法的相互关系
9.3.1 Regulation (EU) 2019/2144 and Regulation (EU) No 168/2013
9.3.1 条例(EU) 2019/2144和条例(EU) No 168/2013
9.3.2 Validity of EU type-examination certificates (Article 69(1))
9.3.2 欧盟型式检验证书的有效性（第69条第1款）

1 Introduction
1 导言

1.1 The Cyber Resilience Act
1.1 《网络弹性法案》

1. Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (the Cyber Resilience Act)1 entered into force on 10 December 2024. The Regulation aims to strengthen the EU's approach to cybersecurity, address cyber resilience at EU level and improve the functioning of the internal market by laying down a uniform legal framework for essential cybersecurity requirements for placing products with digital elements on the EU market, as well as during the lifecycle of a product with digital elements.

> 欧洲议会和理事会2024年10月23日关于含数字元素产品的横向网络安全要求并修正条例(EU) No 168/2013和(EU) 2019/1020以及指令(EU) 2020/1828的条例(EU) 2024/2847（《网络弹性法案》）1已于2024年12月10日生效。该条例旨在加强欧盟的网络安全方针，在欧盟层面应对网络弹性，并通过为含数字元素产品投放欧盟市场以及含数字元素产品生命周期内的基本网络安全要求制定统一法律框架，改善内部市场的运行。

2. The Cyber Resilience Act (CRA) is built upon the EU's New Legislative Framework (NLF) set out in Regulation (EC) No 765/2008 of the European Parliament and of the Council of 9 July 2008 setting out the requirements for accreditation and market surveillance relating to the marketing of products and repealing Regulation (EEC) No 339/93 and Decision No 768/2008/EC of the European Parliament and of the Council of 9 July 2008 on a common framework for the marketing of products, and repealing Council Decision 93/465/EEC2.

> 《网络弹性法案》（CRA）建立在欧盟新立法框架（NLF）之上。该新立法框架由以下文书规定：欧洲议会和理事会2008年7月9日条例(EC) No 765/2008，该条例规定与产品销售有关的认可和市场监督要求，并废止条例(EEC) No 339/93；以及欧洲议会和理事会2008年7月9日决定No 768/2008/EC，该决定涉及产品销售的共同框架，并废止理事会决定93/465/EEC2。

3. Market surveillance and enforcement is carried out by national market surveillance authorities. Products with digital elements that fall within the scope of the CRA are covered by Regulation (EU) 2019/1020 of the European Parliament and of the Council of 20 June 2019 on market surveillance and compliance of products and amending Directive 2004/42/EC and Regulations (EC) No 765/2008 and (EU) No 305/2011. The Commission and the European Union Agency for Cybersecurity (ENISA) support economic operators and Member States in the application of the CRA.

> 市场监督和执法由国家市场监督机构实施。属于CRA适用范围的含数字元素产品，受欧洲议会和理事会2019年6月20日条例(EU) 2019/1020规范。该条例涉及产品市场监督与合规，并修正指令2004/42/EC以及条例(EC) No 765/2008和(EU) No 305/2011。委员会和欧盟网络安全局（ENISA）在适用CRA方面支持经济经营者和成员国。

1.2 Purpose of the guidance
1.2 本指南的目的

4. Article 26(1) of the CRA requires the Commission to publish guidance to assist economic operators in applying the Regulation, with a particular focus on facilitating compliance by microenterprises and small and medium-sized enterprises (SMEs). Article 26(2) sets out minimum aspects that should be addressed in the guidance. These include: (i) the scope of the CRA (particularly remote data processing solutions and free and open-source software); (ii) the notion of 'support periods'; (iii) the interplay between the CRA and other EU legislation; and (iv) the concept of 'substantial modification'.

> CRA第26条第1款要求委员会发布指南，以协助经济经营者适用该条例，并特别着重便利微型企业以及中小型企业（SMEs）遵守该条例。第26条第2款规定了指南应当涵盖的最低方面。这些方面包括：(i) CRA的适用范围（尤其是远程数据处理解决方案以及自由及开源软件）；(ii) “支持期”这一概念；(iii) CRA与其他欧盟立法之间的相互关系；以及(iv) “实质性修改”这一概念。

1 OJ L, 2024/2847, 20.11.2024, ELI: http://data.europa.eu/eli/reg/2024/2847/oj 2 The Commission’s 2026 work programme envisages the presentation of a ‘European Product Act’, updating the NLF and the rules on market surveillance and on standardisation: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52025DC0870

> 1 《官方公报》L辑，2024/2847，2024年11月20日，ELI: http://data.europa.eu/eli/reg/2024/2847/oj 2 委员会2026年工作方案设想提出一项“《欧洲产品法》”，以更新新立法框架以及关于市场监督和标准化的规则：https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52025DC0870

5. On 3 December 2025, the Commission published a series of frequently asked questions (FAQs), which are intended to help economic operators prepare for the implementation of the CRA3.

> 2025年12月3日，委员会发布了一系列常见问题（FAQs），旨在帮助经济经营者为实施CRA作准备3。

6. This guidance is intended to help economic operators comply with the CRA and to support the activities of market surveillance authorities, notifying authorities and notified bodies, with a view to ensuring the harmonised enforcement of the CRA across the Union. This guidance is not intended to cover the CRA in its entire scope, but rather to provide clarifications on the rationale of certain key provisions and how they could be implemented in practice. This guidance concerns the CRA and is not applicable to other EU laws.

> 本指南旨在帮助经济经营者遵守CRA，并支持市场监督机构、通知机构和公告机构的活动，以期确保CRA在全联盟范围内得到统一执行。本指南并非意在涵盖CRA的全部适用范围，而是对某些关键条款的理由以及这些条款在实践中可以如何实施作出澄清。本指南涉及CRA，不适用于其他欧盟法律。

7. Stakeholders were extensively consulted in the preparation of this guidance, including the Expert Group on Cybersecurity of products with digital elements4 and through a public consultation held between 3 March and 13 April 20265.

> 在编写本指南的过程中，广泛征求了利益攸关方的意见，包括含数字元素产品网络安全专家组4，以及2026年3月3日至4月13日举行的公开咨询5。

8. This guidance is not binding for economic operators or other actors subject to the CRA. An authoritative interpretation of the CRA may only be given by the Court of Justice of the European Union. Nevertheless, these guidelines set out the Commission’s interpretation of the CRA, with a view to supporting compliance and contributing to the effective implementation of the Regulation. Furthermore, the guidance contains a number of examples to illustrate the application of specific provisions. However, these examples are not intended to replace a case-by-case assessment, which will always be necessary to account for the specifics of each individual case.

> 本指南对经济经营者或受CRA约束的其他行为人不具约束力。对CRA的权威解释只能由欧洲联盟法院作出。尽管如此，本指引载明委员会对CRA的解释，以期支持合规并促进该条例的有效实施。此外，本指南包含若干示例，用以说明特定条款的适用。然而，这些示例并非意在取代逐案评估；为顾及每一具体情形的特殊情况，逐案评估始终是必要的。

9. In line with Article 26 of the CRA, the Commission may consider issuing further guidance, including guidance targeted at manufacturers subject to the CRA and other Union harmonisation legislation or to other related Union legal acts. This guidance may, for example, address questions on interplay between the CRA and Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (AI Act), and Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA).

> 根据CRA第26条，委员会可以考虑发布进一步指南，包括针对同时受CRA和其他联盟协调立法约束的制造商、或针对其他相关联盟法律文书的指南。例如，此类指南可以处理CRA与制定人工智能协调规则的条例(EU) 2024/1689（《人工智能法案》）之间的相互关系问题，以及CRA与关于金融业数字运营韧性的条例(EU) 2022/2554（《数字运营韧性条例》，DORA）之间的相互关系问题。

3 The FAQs can be downloaded via the Commission's CRA implementation website, from the dedicated FAQs webpage. 4 Expert Group on Cybersecurity of products with digital elements in the register of Commission expert groups and other similar entities. 5 Public consultation on draft Commission guidance on the Cyber Resilience Act.

> 3 常见问题可经由委员会的CRA实施网站、从专门的常见问题网页下载。4 委员会专家组及其他类似实体登记册中的含数字元素产品网络安全专家组。5 关于《网络弹性法案》委员会指南草案的公开咨询。

2 Scope
2 适用范围

2.1 Placing on the market
2.1 投放市场

10. The CRA applies to products with digital elements that are made available on the EU market. The concept of making available on the market is defined in Article 3(22) of the CRA as 'the supply of a product with digital elements for distribution or use on the Union market in the course of a commercial activity, whether in return for payment or free of charge'. In accordance with Article 3(21), a product with digital elements is placed on the EU market the first time it is made available.

> CRA适用于在欧盟市场上提供的含数字元素产品。"在市场上提供"这一概念在CRA第3条第22款中定义为："在商业活动过程中，为在联盟市场上分销或使用而供应含数字元素产品，无论有偿还是免费"。根据第3条第21款，含数字元素产品在其首次被提供时，即被投放欧盟市场。

11. The latest edition of the 'Blue Guide on the implementation of EU product rules' published in 2022 (henceforth, 'the Blue Guide')6, provides guidance facilitating the understanding of the EU product rules and their uniform application across the different sectorial legal frameworks aligned to the new legislative framework (NLF), such as the CRA. The Blue Guide indicates that the concepts of 'placing on the market' and of 'making available' are to be understood as referring 'to each individual product, not to a type of product, and whether it was manufactured as an individual unit or in series' (Section 2.3).

> 2022年出版的最新版《关于实施欧盟产品规则的"蓝皮书"》（以下简称"《蓝皮书》"）6，为理解欧盟产品规则及其在与新立法框架（NLF）对齐的不同部门性法律框架（例如CRA）中的统一适用提供指导。《蓝皮书》指出，"投放市场"和"提供"这两个概念应理解为针对"每一件具体产品，而不是某一产品类型，且不论其是作为单件还是成批制造"（第2.3节）。

12. For more 'traditional' products with digital elements covered by the NLF, such as hardware in the form of machinery or radio equipment products with digital elements, the concept of 'placement on the market' is well established, and the Blue Guide provides further guidance to clarify when such products are considered to be placed on the market. The 'summary examples' contained in the Blue Guide's Section 2.12 provide further examples of the concept of 'placing on the market'.

> 对于新立法框架所涵盖的较为"传统"的含数字元素产品，例如机械形式的硬件或属于含数字元素产品的无线电设备，"投放市场"这一概念已经确立，《蓝皮书》提供了进一步指导，以澄清此类产品在何种情况下被视为已投放市场。《蓝皮书》第2.12节所载"摘要示例"就"投放市场"这一概念提供了进一步示例。

13. However, given the nature of intangible products with digital elements such as standalone software, further guidance is needed on when such products with digital elements are considered placed on the market. Once the software's manufacturing phase is complete and the product with digital elements is offered to prospective users in the EU market, its manufacturer can be regarded as having manufactured multiple copies of the same software product with digital elements and having supplied them for distribution or use. In fact, unlike tangible products with digital elements, standalone software is not subject to physical production or stock limitations: each act of making the software available for download or distribution results in a new identical copy being created for the user. As long as this version of the software is not modified in a way that affects compliance with the CRA, the placing on the EU market is to be considered to have occurred at the moment of the first offering for distribution or use. The possibility of subsequent download or distribution of this version of the software product with digital elements is therefore to be regarded as an instance where this software product with digital elements is made available7.

> 然而，鉴于独立软件等无形含数字元素产品的性质，需要进一步指导，以说明此类含数字元素产品在何种情况下被视为已投放市场。一旦软件的制造阶段完成，且该含数字元素产品被提供给欧盟市场上的潜在用户，其制造商即可被视为已经制造了同一含数字元素软件产品的多份副本，并已为分销或使用而供应这些副本。事实上，与有形的含数字元素产品不同，独立软件不受实物生产或库存的限制：每一次使该软件可供下载或分销的行为，都会为用户产生一份新的相同副本。只要该版本软件未被以影响其遵守CRA的方式修改，投放欧盟市场即应视为发生在首次为分销或使用而提供之时。因此，此后下载或分销该版本含数字元素软件产品的可能性，应视为该含数字元素软件产品被提供的一种情形7。

6 Commission notice - The 'Blue Guide' on the implementation of EU product rules 2022 (Text with EEA relevance) 2022/C 247/01, OJ C 247, 29.6.2022, pp. 1–152.

> 6 委员会通知——《关于实施欧盟产品规则的“蓝皮书”》（2022年）（与欧洲经济区相关的文本）2022/C 247/01，《官方公报》C 247，2022年6月29日，第1–152页。

14. Therefore, a standalone software product with digital elements should be considered to have been placed on the market when its manufacturing phase is complete and that software is first supplied for distribution or use on the EU market in the course of a commercial activity. The manufacturer should be considered to have placed on the market multiple copies of the same software product with digital elements at the same time. Therefore, while multiple copies of the same software remain individual products with digital elements, they are considered to be placed on the market at the same time, regardless of when possession or use of each individual copy is transferred to another natural or legal person. At the same time, where the manufacturer makes software available in different variants that differ in their included components, configurations or enabled functionalities (for example, builds for different operating systems or bundles with differing feature sets), those variants cannot be regarded as multiple copies of the same software product with digital elements. Therefore, they should be treated as distinct products with digital elements for the purposes of placing on the market. Example 1: On 1 January 2028, company A first supplies for distribution via its website version 1.0.0 of its software X. On the same day, customer 1 purchases a copy of version 1.0.0 of software X. On 15 January 2028, customer 2 purchases a copy of version 1.0.0 of software X. Both copies of version 1.0.0 of software X are placed on the market on 1 January 2028.

> 因此，独立的含数字元素软件产品，在其制造阶段完成并且该软件在商业活动过程中首次为在欧盟市场上分销或使用而被供应时，应视为已被投放市场。制造商应视为已在同一时间将同一含数字元素软件产品的多份副本投放市场。因此，尽管同一软件的多份副本仍然是各自独立的含数字元素产品，但它们被视为在同一时间被投放市场，而不论每一份副本的占有或使用在何时转移给另一自然人或法人。与此同时，如果制造商以所含组件、配置或所启用功能有所不同的不同变体提供软件（例如，针对不同操作系统的构建版本，或功能集不同的捆绑组合），这些变体不能被视为同一含数字元素软件产品的多份副本。因此，就投放市场而言，它们应作为不同的含数字元素产品对待。示例1：2028年1月1日，A公司首次通过其网站为分销而供应其软件X的1.0.0版本。同日，客户1购买了软件X 1.0.0版本的一份副本。2028年1月15日，客户2购买了软件X 1.0.0版本的一份副本。软件X 1.0.0版本的两份副本均于2028年1月1日被投放市场。

15. Given the iterative nature of software development, it should be further clarified that subsequent iterations of a software product with digital elements are considered as newly placed on the market when those iterations qualify as a 'substantial modification' of a software product with digital elements already placed on the market, as indicated in recital 41 of the CRA. Iterations that do not qualify as substantial modifications do not require the manufacturer to perform a new conformity assessment procedure and therefore do not modify that software's date of placement on the market. For more guidance on the concept of substantial modifications see Section 4 Substantial modifications. Example 2: On 1 January 2028, company A first supplies for distribution via its website version 1.0.0 of software X. On the same day, customer 1 purchases a copy of version 1.0.0 of software X. On 15 January 2028, company A issues an updated version 1.0.1 of software X that does not constitute a substantial modification. On 30 January 2028, customer 2 purchases a copy of version 1.0.1 of software X. Both copies of version 1.0.0 and 1.0.1 of software X are considered to be placed on the market on 1 January 2028.

> 鉴于软件开发的迭代性质，应当进一步澄清：含数字元素软件产品的后续迭代，在构成对已经投放市场的含数字元素软件产品的"实质性修改"时，视为被重新投放市场，正如CRA序言第41项所指出的。不构成实质性修改的迭代，不要求制造商实施新的合格评定程序，因此不改变该软件的投放市场日期。关于实质性修改这一概念的进一步指导，见第4节"实质性修改"。示例2：2028年1月1日，A公司首次通过其网站为分销而供应软件X的1.0.0版本。同日，客户1购买了软件X 1.0.0版本的一份副本。2028年1月15日，A公司发布软件X的更新版本1.0.1，该版本不构成实质性修改。2028年1月30日，客户2购买了软件X 1.0.1版本的一份副本。软件X的1.0.0版本和1.0.1版本的各份副本，均视为于2028年1月1日被投放市场。

16. The guidance laid down in points 13, 14 and 15 applies exclusively insofar as the product with digital elements is standalone software. This is not the case, for example, when the software is combined with hardware, as discussed in Section 2.4 Combination of hardware and software forming a product.

> 第13、14和15点所载指导，仅在含数字元素产品为独立软件的范围内适用。例如，当软件与硬件组合时，即非如此，详见第2.4节"硬件与软件组合构成产品"。

7 In accordance with Article 13(11), manufacturers may maintain public software archives enhancing user access to historical versions. In such cases, users shall be informed clearly and in an easily accessible manner about risks associated with using unsupported software.

> 7 根据第13条第11款，制造商可以维护公共软件档案，以便利用户获取历史版本。在此类情况下，应当以清晰且易于获取的方式告知用户使用不受支持的软件所伴随的风险。

2.2 Software as a product with digital elements
2.2 作为含数字元素产品的软件

17. Article 3(1) of the CRA defines a product with digital elements as 'a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately'. Such products with digital elements fall within the scope of the CRA where their intended purpose or reasonably foreseeable use includes a direct or indirect logical or physical data connection to a device or network.

> CRA第3条第1款将含数字元素产品定义为"软件或硬件产品及其远程数据处理解决方案，包括被单独投放市场的软件或硬件组件"。此类含数字元素产品，在其预期用途或可合理预见的使用包括与设备或网络的直接或间接逻辑或物理数据连接时，属于CRA的适用范围。

18. The CRA therefore can cover a range of products with digital elements, including: (i) standalone software, such as apps and computer programs, whether digitally or physically distributed; (ii) hardware with embedded software (e.g. Internet-of-Things devices, laptops, tablets); (iii) standalone hardware (e.g. integrated circuits, motherboards); and (iv) any combination of hardware and software supplied separately but intended to operate together.

> 因此，CRA可以涵盖一系列含数字元素产品，包括：(i) 独立软件，例如应用程序和计算机程序，无论以数字方式还是实物方式分销；(ii) 嵌入软件的硬件（例如物联网设备、笔记本电脑、平板电脑）；(iii) 独立硬件

（例如集成电路、主板）；以及(iv) 分开供应但旨在协同运行的硬件与软件的任何组合。

19. Standalone software therefore falls in scope of the CRA where it is placed on the market as a product with digital elements. It is helpful to distinguish between software products with digital elements that are subject to the CRA and the remote provision of services that do not fall in scope of the CRA.

因此，独立软件在作为含数字元素产品被投放市场时，属于CRA的适用范围。有助于区分受CRA约束的含数字元素软件产品，与不属于CRA适用范围的远程提供的服务。

20. For software to fall within the scope of the CRA, a software product with digital elements must be provided to a user, obtained by that user and operated on, or as part of, an electronic information system on the user's side. Software that is downloaded, installed or otherwise supplied to the user and that executes on the user's electronic information system meets these criteria, including for example where it takes the form of a browser extension or an application developed using web technologies but supplied for local execution.

软件要属于CRA的适用范围，含数字元素软件产品必须被提供给用户、由该用户取得，并在用户侧的电子信息系统上或作为该系统的一部分运行。被下载、安装或以其他方式供应给用户、并在用户的电子信息系统上执行的软件，符合这些标准，例如包括采取浏览器扩展形式的软件，或使用网络技术开发但为本地执行而供应的应用程序。

21. By contrast, software that executes remotely and is merely accessed by the user is not, on that basis alone, a product with digital elements. Recitals 11 and 12 of the CRA, in fact, draw this distinction, by explaining that processing or storage at a distance is subject to the CRA only to the extent that it is necessary for a product with digital elements to perform its functions (i.e. through the concept of remote data processing as defined in Article 3(2)), and not themselves as products with digital elements. This is typically the case for web applications, including progressive web apps, where they are accessed exclusively through a web browser. The same applies to websites: whilst websites may, to a limited extent, technically run and execute on the user's device, it follows from recital 12 of the CRA that websites are not themselves to be considered as products with digital elements, and fall within the scope of the CRA only where they support the functionality of a product with digital elements, i.e. to the extent that they qualify as remote data processing (as further explained in Section 8 and notably 8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions?).

相反，在远程执行且仅为用户所访问的软件，仅凭这一点并不构成含数字元素产品。事实上，CRA序言第11项和第12项作出了这一区分，说明远程处理或存储仅在其为含数字元素产品履行其功能所必需的范围内受CRA约束（即通过第3条第2款所定义的远程数据处理这一概念），而其本身并不作为含数字元素产品受约束。网络应用程序通常属于这种情况，包括渐进式网络应用程序，即用户仅通过网络浏览器访问的情形。网站亦同：尽管网站在有限程度上可能在技术上于用户设备上运行和执行，但根据CRA序言第12项，网站本身不应被视为含数字元素产品，并且仅在其支持含数字元素产品的功能时才属于CRA的适用范围，即仅在其构成远程数据处理的范围内（详见第8节，尤其是第8.1.2节“如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？”）。

Example 3: a mobile application that a user downloads from an app store and installs on their smartphone is supplied to the user and executes on the user's device and is therefore a product with digital elements. Where it is placed on the market in the course of a commercial activity, it may fall within the scope of the CRA. Example 4: a desktop application built using web technologies but packaged for local installation is supplied to the user and executes on the user's device, and is therefore a product with digital elements. Where it is placed on the market in the course of a commercial activity, it may fall within the scope of the CRA. Example 5: a web application accessed by the user exclusively through a web browser is not a product with digital elements. Unless it supports the functionality of a product with digital elements, it does not fall within the scope of the CRA. By contrast, an application supplied to the user as a locally installed client that executes on the user's device is a product with digital elements. Where it is placed on the market in the course of a

commercial activity, it may fall within the scope of the CRA. If that client relies, in order to perform one or more of its functions, on data processing at a distance which meets the definition of remote data processing, that data processing at a distance is also part of the product with digital elements. Example 6: a website that merely presents information to its visitors and does not support the functionality of a product with digital elements is not itself a product with digital elements. It therefore does not fall within the scope of the CRA.

> 示例3：用户从应用商店下载并安装到其智能手机上的移动应用程序，被供应给用户并在用户设备上执行，因此是含数字元素产品。如果它在商业活动过程中被投放市场，则可能属于CRA的适用范围。示例4：使用网络技术构建但封装为供本地安装的桌面应用程序，被供应给用户并在用户设备上执行，因此是含数字元素产品。如果它在商业活动过程中被投放市场，则可能属于CRA的适用范围。示例5：用户仅通过网络浏览器访问的网络应用程序，不是含数字元素产品。除非它支持含数字元素产品的功能，否则不属于CRA的适用范围。相反，作为在用户设备上执行的本地安装客户端供应给用户的应用程序，是含数字元素产品。如果它在商业活动过程中被投放市场，则可能属于CRA的适用范围。如果该客户端为履行其一项或多项功能而依赖符合远程数据处理定义的远程数据处理，则该远程数据处理也是该含数字元素产品的一部分。示例6：仅向访问者呈现信息、并不支持含数字元素产品功能的网站，其本身不是含数字元素产品。因此，它不属于CRA的适用范围。

2.3 Computer code
2.3 计算机代码

22. It is also useful to clarify whether source code can constitute a software product with digital elements. The CRA defines software as ‘the part of an electronic information system which consists of computer code’ (Article 3(4)). Computer code can take the form of (i) machine code, which is the set of instructions directly executed by a computer’s processor, written in binary format; or (ii) source code, i.e. the set of instructions and statements written in a programming language, which must be compiled or interpreted to be executed by a computer. The definition of software laid down in the CRA covers both.

> 澄清源代码能否构成含数字元素软件产品，亦有助益。CRA将软件定义为“由计算机代码组成的电子信息系统的部分”（第3条第4款）。计算机代码可以采取以下形式：(i) 机器码，即由计算机处理器直接执行的指令集，以二进制格式编写；或(ii) 源代码，即使用编程语言编写的指令和语句集，必须经过编译或解释才能由计算机执行。CRA所规定的软件定义涵盖二者。

23. A separate question is whether a given supply of computer code amounts to placing a product with digital elements on the EU market, which requires a supply in the course of a commercial activity. This may often not be the case for source code. For example, a natural or legal person that shares free and open-source computer code on publicly accessible repositories is generally not considered to be placing that code on the EU market for the purposes of the CRA (as discussed in more detail in Section 3 Free and open-source software). Unfinished code shared during the design and development phase of a product with digital elements (e.g. for testing or review) is also not considered to be placed on the market for the purposes of the CRA, as its manufacturing phase is not completed. Similarly, sample or demo code provided as part of tutorials or training materials is also not considered placed on the market for the purposes of the CRA8.

> 另一个单独的问题是，某一计算机代码的供应是否构成将含数字元素产品投放欧盟市场；这要求在商业活动过程中进行供应。就源代码而言，情况往往并非如此。例如，在可公开访问的存储库上分享自由及开源计算机代码的自然人或法人，就CRA而言，一般不视为将该代码投放欧盟市场（详见第3节“自由及开源软件”）。在含数字元素产品的设计和开发阶段分享的未完成代码（例如用于测试或审查），就CRA而言也不视为被投放市场，因为其制造阶段尚未完成。同样，作为教程或培训材料一部分提供的示例代码或演示代码，就CRA而言也不视为被投放市场8。

24. On the other hand, where a manufacturer provides its customers with computer code as a product with digital elements, that code is considered to be placed on the market, regardless of whether it is machine code or source code9. Example 7: Company A licences source code to company B for a customisable internal platform, and provides that source code in a text file. Even if that source code requires further adaptation and compilation by company B before being used, company A is placing that source code on the market and is therefore subject to the CRA. Company A is not responsible for the compliance with the CRA of company B's subsequent adaptations and compilation of that code.

> 另一方面，如果制造商向其客户提供作为含数字元素产品的计算机代码，则无论该代码是机器码还是源代码，该代码均视为被投放市场9。示例7：A公司就一个可定制的内部平台向B公司许可源代码，并以文本文件形式提供该源代码。即使该源代码在使用前需要由B公司进一步改写和编译，A公司仍在将该源代码投放市场，因此受CRA约束。对于B公司随后对该代码的改写和编译是否遵守CRA，A公司不承担责任。

2.4 Combination of hardware and software forming a product with digital elements
2.4 硬件与软件组合构成含数字元素产品

25. Whether software forms part of a product with digital elements should be determined not by how or when that software is delivered to the user, but by whether, in light of the product's intended purpose and reasonably foreseeable use, the software is necessary for the product with digital elements to perform its intended functions. Where a hardware product with digital elements is designed to work together with a specific software provided by the same manufacturer in order to perform its functions, the hardware and that software together constitute the product with digital elements. Software that is necessary to operate, configure, control or use a product with digital elements in accordance with its intended purpose is therefore part of the product with digital elements, even if it is obtained through a separate channel (e.g. an app store, a download link or another digital channel after the hardware product with digital elements has been placed on the market). Its placing on the market thus occurs at the same point in time as units of the hardware products with digital elements are placed on the market. Example 8: A network printer is placed on the market as a hardware product with digital elements, while the software drivers required to send print jobs, configure the device and manage its operation are made available for download from the manufacturer's website. Although the printer and the drivers are supplied through different channels, they together constitute a single product with digital elements, because the printer cannot fulfil its intended purpose without the drivers.

> 软件是否构成含数字元素产品的一部分，不应根据该软件以何种方式或在何时交付给用户来确定，而应根据产品的预期用途和可合理预见的使用，该软件是否为含数字元素产品履行其预期功能所必需来确定。如果含数字元素硬件产品被设计为与同一制造商提供的特定软件协同工作以履行其功能，则该硬件与该软件共同构成含数字元素产品。为按照预期用途操作、配置、控制或使用含数字元素产品所必需的软件，因此属于该含数字元素产品的一部分，即使该软件通过单独渠道取得（例如，在含数字元素硬件产品投放市场之后，通过应用商店、下载链接或其他数字渠道取得）。因此，其投放市场与含数字元素硬件产品的各单位被投放市场发生于同一时点。示例8：一台网络打印机作为含数字元素硬件产品被投放市场，而发送打印作业、配置设备和管理其运行所需的软件驱动程序则可从制造商网站下载。尽管打印机和驱动程序通过不同渠道供应，它们共同构成单一含数字元素产品，因为没有驱动程序，打印机无法实现其预期用途。

8 It should also be recalled that Article 4(3) allows manufacturers to make available on the market unfinished software which does not comply with the Regulation, such as alpha versions, beta versions or release candidates, provided that the unfinished software is made available only for the time necessary to test it and gather feedback. 9 On the other hand, it should be noted that for the purposes of product liability law, computer code itself does not constitute a product and therefore manufacturers that place such code on the market cannot be held liable under Directive (EU) 2024/2853 (the Product Liability Directive). Recital 13 of that Directive states that 'information is not, however, to be considered a product, and product liability rules should therefore not apply to the content of digital files, such as media files or e-books or the mere source code of software'. This does not preclude that manufacturers may be liable under national tort law.

> 8 还应当回顾，第4条第3款允许制造商在市场上提供不符合本条例的未完成软件，例如alpha版本、beta版本或候选发布版本，但前提是该未完成软件仅在为测试并收集反馈所必要的时间内被提供。9 另一方面，应当指出，就产品责任法而言，计算机代码本身不构成产品，因此将此类代码投放市场的制造商不能根据指令(EU) 2024/2853（《产品责任指令》）被追究责任。

> 该指令序言第13项规定：“然而，信息不应被视为产品，因此产品责任规则不应当适用于数字文件的内容，例如媒体文件或电子书，或软件的纯源代码”。这并不排除制造商可能根据国内侵权法承担责任。

Example 9: A fitness wearable is placed on the market to measure a user's heart rate and activity, while a smartphone application provided by the manufacturer is required to display the measurements, show history and allow configuration of the device. Although the application is downloaded separately through an app store, the wearable and the application together constitute a single product with digital elements, because they are designed and intended to operate together to deliver the functionality of the product with digital elements.

> 示例9：一款健身可穿戴设备被投放市场，用于测量用户的心率和活动量，而制造商提供的智能手机应用程序则是显示测量结果、展示历史记录并允许配置该设备所必需的。尽管该应用程序通过应用商店单独下载，可穿戴设备与应用程序共同构成单一含数字元素产品，因为它们被设计并意图协同运行，以交付该含数字元素产品的功能。

2.5 Data connection

2.5 数据连接

26. Article 2(1) states that the CRA 'applies to products with digital elements made available on the market, the intended purpose or reasonably foreseeable use of which includes a direct or indirect logical or physical data connection to a device or network'. The scope of the CRA is therefore anchored not in the mere presence of electronics, but in the capacity of a product with digital elements to exchange digital information.

> 第2条第1款规定，CRA“适用于在市场上提供的含数字元素产品，其预期用途或可合理预见的使用包括与设备或网络的直接或间接逻辑或物理数据连接”。因此，CRA的适用范围并不取决于仅仅存在电子装置，而取决于含数字元素产品交换数字信息的能力。

27. While the terms 'logical connection' and 'physical connection' are defined in Article 3, the CRA does not define 'data connection' or 'digital data'. It is therefore useful to set out an interpretation of what a data connection is, in order to clarify the boundary of the CRA's scope. This boundary is particularly important to distinguish products with digital elements that merely use electrical signals from those that participate in digital communication and are therefore exposed to cybersecurity risks.

> 尽管“逻辑连接”和“物理连接”这两个用语在第3条中有定义，CRA并未定义“数据连接”或“数字数据”。因此，有必要阐明对何为数据连接的解释，以澄清CRA适用范围的边界。这一边界对于区分仅仅使用电信号的含数字元素产品与参与数字通信并因而面临网络安全风险的含数字元素产品，尤为重要。

28. At its most basic level, a data connection involves transmitting information in binary form, i.e. as a sequence of 0s and 1s. Simply switching an output on and off (i.e. 0/1) does not by itself constitute a data connection if those states are not intended to represent data or are not read by a digital input. For a data connection to exist, the binary states must be deliberately encoded as information by a source and must be capable of being decoded as information at the destination. In other words, there must be a sender that deliberately generates digital symbols according to a defined scheme, and a receiver capable of interpreting those symbols as data. Where electrical or electronic signals are used solely to trigger or power a function, without conveying digitally encoded information, no data connection exists for the purposes of the CRA and therefore the product with digital elements does not fall within the scope of Article 2(1).

> 在最基本的层面上，数据连接涉及以二进制形式传输信息，即以0和1的序列传输。仅仅将某一输出打开和关闭（即0/1），如果这些状态并非意在表示数据，或者并非由数字输入读取，其本身并不构成数据连接。要存在数据连接，二进制状态必须由信源有意编码为信息，并且必须能够在目的端被解码为信息。换言之，必须有一个发送方按照既定方案有意生成数字符号，以及一个能够将这些符号解释为数据的接收方。如果电信号或电子信号仅用于触发或驱动某项功能，而不传递以数字方式编码的信息，则就CRA而言不存在数据连接，因此该含数字元素产品不属于第2条第1款的适用范围。

2.6 Complex systems
2.6 复杂系统

29. Products with digital elements within the scope of the CRA may consist not only of single devices or software components, but also of complex systems, including systems composed of multiple hardware and software elements that operate together to perform a certain function. Where such a system is placed on the market as a single product with digital elements, it constitutes a product with digital elements within the meaning of the CRA.

> 属于CRA适用范围的含数字元素产品，不仅可以由单一设备或软件组件构成，也可以由复杂系统构成，包括由共同运行以履行某一功能的多个硬件和软件元素组成的系统。如果此类系统作为单一含数字元素产品被投放市场，则其构成CRA意义上的含数字元素产品。

30. Such complex systems are often characterised by long design and development cycles, with contracts that may have been signed before the CRA applies, extended operational lifetimes and a high degree of technical and organisational complexity. Such systems, to be placed on the market after the CRA enters into application, may rely on components placed on the market before the CRA entered into application, on established architectures or on widely used interoperability standards, including standards referred to in other EU legislation or sector-specific frameworks. As a result, certain technical characteristics of those systems may be difficult or disproportionate to modify without affecting their intended purpose, safety, reliability or interoperability with existing infrastructure.

> 此类复杂系统的特点往往是设计和开发周期较长，合同可能在CRA适用之前已经签订，运行寿命较长，并且技术和组织复杂程度较高。拟在CRA开始适用之后投放市场的此类系统，可能依赖在CRA开始适用之前投放市场的组件、既有架构或广泛使用的互操作性标准，包括其他欧盟立法或部门性框架所提及的标准。因此，在不影响其预期用途、安全性、可靠性或与现有基础设施的互操作性的情况下，修改这些系统的某些技术特性可能是困难的，或者不成比例。

31. These characteristics do not in themselves exclude complex systems from the CRA's scope. Rather, they illustrate the application of the CRA's risk-based approach, which allows compliance to be demonstrated in different ways depending on the characteristics and constraints of the product with digital elements, in accordance with Article 13(3) of the CRA. Those characteristics form part of its intended purpose and operating context and are therefore relevant when assessing compliance with the essential cybersecurity requirements (the 'essential requirements'). In particular, recital 55 explicitly recognises that certain essential requirements may not be fully compatible with the nature of a product with digital elements. For example, this may be the case where compliance would undermine mandatory interoperability requirements or the system's proper functioning.

> 这些特性本身并不将复杂系统排除在CRA适用范围之外。相反，它们说明了CRA基于风险的方法的适用；根据CRA第13条第3款，该方法允许依含数字元素产品的特性和制约，以不同方式证明合规。这些特性构成其预期用途和运行环境的一部分，因此在评估是否符合基本网络安全要求（下称“基本要求”）时具有相关性。特别是，序言第55项明确承认，某些基本要求可能与含数字元素产品的性质并非完全相容。例如，在合规会损害强制性互操作性要求或系统正常运行的情况下，即可能如此。

32. Accordingly, manufacturers are required to address cybersecurity risks on the basis of the cybersecurity risk assessment referred to in Article 13(2). As also explained in recital 55, in some cases, specific essential requirements are not applicable or cannot be fulfilled via the implementation of state-of-the-art security measures due to, for example, the system's intended purpose, which requires the product with digital elements to interact with existing dependencies or to follow certain interoperability requirements. In such cases, manufacturers should identify and document those specific constraints, assess the associated risks, and implement appropriate alternative or compensatory risk-mitigation measures, so as to not undermine the security of the product with digital elements. For these purposes, both the technical documentation referred to in Article 31 and the information and instructions to the user referred to in Annex II play a key role in transparently describing the identified constraints, the associated cybersecurity risks and the risk-mitigation measures implemented. In accordance with the obligation to keep the risk assessment updated during the support period,

manufacturers should also periodically reassess whether such constraints continue to exist. Where such constraints can be lifted or reduced over time, manufacturers should update the product with digital elements accordingly so that it can move towards an appropriate level of cybersecurity10. Example 10: A manufacturer places on the market a product with digital elements that communicates with external systems using a network protocol. As part of the application of the essential requirements, the manufacturer determines, on the basis of the cybersecurity risk assessment, that the use of a secure communication protocol is necessary to ensure the confidentiality and integrity of data exchanged by the product with digital elements. However, its intended purpose includes interoperability with existing systems that only support an older or less secure protocol. In such cases, the manufacturer may implement that protocol where this is necessary to achieve interoperability, provided that the associated cybersecurity risks are identified and mitigated through other means. Where it is technically feasible for the product with digital elements to support both the secure protocol and the less secure protocol, the manufacturer is expected to implement the secure protocol and to enable its use by default. The less secure protocol would be allowed only where required for interoperability. Example 11: A manufacturer of an industrial automation system purchases some microcontrollers before the CRA enters into application. The manufacturer undertakes the cybersecurity risk assessment for its industrial automation system to be placed on the market after the CRA enters into application. On the basis of that cybersecurity risk assessment, the manufacturer does not identify specific cybersecurity risks associated with using one of those microcontrollers. The manufacturer integrates it into its industrial automation system and ensures that the product with digital elements as a whole (the industrial automation system) meets the essential requirements.

> 因此，制造商必须根据第13条第2款所指的网络安全风险评估来应对网络安全风险。正如序言第55项亦所说明的，在某些情况下，由于例如系统的预期用途要求含数字元素产品与既有依赖项交互或遵循某些互操作性要求，特定基本要求不适用，或者无法通过实施符合当前技术发展水平的安全措施来满足。在此类情况下，制造商应当识别并记录这些特定制约，评估相关风险，并实施适当的替代性或补偿性风险缓解措施，以免减损含数字元素产品的安全性。为此，第31条所指的技术文件以及附件II所指的向用户提供的信息和说明，在透明说明已识别的制约、相关网络安全风险以及已实施的风险缓解措施方面发挥关键作用。根据在支持期内保持风险评估更新的义务，制造商还应当定期重新评估此类制约是否仍然存在。如果此类制约能够随时间消除或减轻，制造商应当相应更新含数字元素产品，使其能够迈向适当的网络安全水平10。示例10：某制造商投放市场一款使用网络协议与外部系统通信的含数字元素产品。作为适用基本要求的一部分，制造商根据网络安全风险评估确定，使用安全通信协议对于确保该含数字元素产品所交换数据的保密性和完整性是必要的。然而，其预期用途包括与仅支持较旧或安全性较低协议的现有系统实现互操作。在此类情况下，如果为了实现互操作而有必要，制造商可以实施该协议，但前提是相关网络安全风险被识别并通过其他手段加以缓解。如果含数字元素产品在技术上能够同时支持安全协议和安全性较低的协议，则预期制造商实施安全协议并默认启用其使用。安全性较低的协议仅在互操作所要求的情况下才被允许。示例11：某工业自动化系统的制造商在CRA开始适用之前购买了若干微控制器。该制造商对其拟在CRA开始适用之后投放市场的工业自动化系统开展网络安全风险评估。根据该网络安全风险评估，制造商并未识别出与使用其中一款微控制器相关的特定网络安全风险。制造商将其集成到工业自动化系统中，并确保作为整体的含数字元素产品（即该工业自动化系统）符合基本要求。

10 It should be noted that the considerations laid down in this paragraph may be applicable, as appropriate, to all products with digital elements in scope of the CRA, and not just ‘complex systems’.

> 10 应当指出，本点所载考虑在适当情况下可适用于属于CRA适用范围的所有含数字元素产品，而不仅仅是“复杂系统”。

2.7 Products with digital elements designed before the CRA entered into application
2.7 在CRA开始适用之前设计的含数字元素产品

33. In some cases, a manufacturer will place on the market, after the CRA enters into application on 11 December 2027, units of a product with digital elements manufactured in accordance with a type or model designed and developed before the date of application of the CRA. In such cases, compliance with this Regulation does not necessarily require that those units of the product with digital elements be redesigned. The manufacturer is required to carry out a cybersecurity risk

assessment in accordance with Article 13(2) of the CRA in order to determine, on the basis of the intended purpose and reasonably foreseeable use of the product with digital elements, which of the essential requirements set out in Part I of Annex I are applicable to that product with digital elements, and how those requirements are implemented.

> 在某些情况下，制造商将在CRA于2027年12月11日开始适用之后，投放按照在CRA开始适用之日前设计和开发的型式或型号制造的含数字元素产品单位。在此类情况下，遵守本条例并不必然要求重新设计这些含数字元素产品单位。制造商必须根据CRA第13条第2款开展网络安全风险评估，以便根据含数字元素产品的预期用途和可合理预见的使用，确定附件I第一部分所载基本要求中哪些适用于该含数字元素产品，以及这些要求如何得到实施。

34. Where the outcome of that risk assessment demonstrates that the product with digital elements already incorporates appropriate and effective security measures addressing the relevant risks, the manufacturer may rely on those existing measures to demonstrate compliance with the CRA. The CRA does not in itself impose an obligation to introduce new security features or to redesign the product with digital elements where this is not necessary to address the identified risks.

> 如果该风险评估的结果表明，含数字元素产品已经包含应对相关风险的适当且有效的安全措施，制造商可以依赖这些既有措施来证明遵守CRA。如果为应对已识别的风险并无必要，CRA本身并不施加引入新安全功能或重新设计含数字元素产品的义务。

35. Nevertheless, the manufacturer remains subject to the obligations laid down in the CRA. These include making sure, before the product with digital elements is placed on the market, that the applicable conformity assessment procedure has been carried out, the EU declaration of conformity has been drawn up and the CE marking affixed. Compliance with those requirements is independent of whether the design of the product with digital elements required modification as a result of the risk assessment. For products with digital elements designed before the date of application of the CRA, but placed on the market after that date, when it is not possible for the manufacturer to demonstrate how the risk assessment has been taken into account during the design and development phase of the product with digital elements, the obligation of Article 13(2) should be understood as requiring manufacturers to perform a cybersecurity risk assessment and demonstrate on that basis that the product with digital elements incorporates adequate security measures with a view to minimising cybersecurity risks, preventing incidents and minimising their impact, including in relation to the health and safety of users.

> 尽管如此，制造商仍然受CRA所规定义务的约束。这些义务包括：在含数字元素产品投放市场之前，确保已完成适用的合格评定程序、已起草欧盟符合性声明并已加贴CE标志。遵守这些要求，并不取决于含数字元素产品的设计是否因风险评估而需要修改。对于在CRA开始适用之日前设计、但在该日之后投放市场的含数字元素产品，如果制造商无法证明在该含数字元素产品的设计和开发阶段如何考虑了风险评估，则第13条第2款的义务应理解为要求制造商开展网络安全风险评估，并在此基础上证明该含数字元素产品包含充分的安全措施，以期尽量降低网络安全风险、防止事件发生并尽量减轻其影响，包括与用户健康和安全有关的影响。

36. Accordingly, products with digital elements designed before the CRA entered into application might be placed on the market under the CRA without redesign, provided that the manufacturer can demonstrate, through the cybersecurity risk assessment and the technical documentation, that the product with digital elements achieves an appropriate level of cybersecurity in light of its intended purpose and reasonably foreseeable use and complies with the cybersecurity essential requirements.

> 因此，在CRA开始适用之前设计的含数字元素产品，可以在不重新设计的情况下依CRA投放市场，但前提是制造商能够通过网络安全风险评估和技术文件证明：鉴于其预期用途和可合理预见的使用，该含数字元素产品达到适当的网络安全水平，并符合网络安全基本要求。

37. Furthermore, it is helpful to clarify the application of conformity assessment obligations for manufacturers of products with digital elements that are placed on the market after the CRA enters into application, but manufactured in accordance with a type or model designed and developed before that date. In accordance with Article 13(12), the manufacturer is

required to demonstrate via the relevant conformity assessment procedure that its product with digital elements is in conformity with the applicable essential requirements and to include evidence to that effect in the product's technical documentation (point 6 of Annex VII).

> 此外，宜澄清合格评定义务对于如下制造商的适用：其含数字元素产品在CRA开始适用之后投放市场，但按照在该日之前设计和开发的型式或型号制造。根据第13条第12款，制造商必须通过相关合格评定程序证明其含数字元素产品符合适用的基本要求，并将证明该事实的证据纳入产品的技术文件（附件VII第6点）。

38. However, the application of such requirements needs to be interpreted in light of the cybersecurity risk assessment and the cybersecurity risk profile of the product with digital elements. Particularly in the case of products with digital elements designed before the date of application of the CRA (but placed on the market after that date) and subject to the conformity assessment procedures of Article 32(1), where the risk assessment demonstrates that the product with digital elements already incorporates appropriate and effective security measures addressing that product's risks, the obligation to provide evidence as part of the conformity assessment procedure should not be understood as requiring the manufacturer to provide test results covering the original design and development phases of such products with digital elements. This would not be necessary as it would not be contributing to increasing the security of the product with digital elements itself. Where tests may nonetheless be necessary, manufacturers are not expected to provide evidence of tests carried out on all product variants, but can group such tests across families of products with digital elements, as further discussed in Section 7.4 Reuse of risk assessments and conformity documentation for families of products with digital elements.

> 然而，此类要求的适用需要结合网络安全风险评估以及含数字元素产品的网络安全风险状况来解释。特别是对于在CRA开始适用之日前设计（但在该日之后投放市场）、并适用第32条第1款合格评定程序的含数字元素产品，如果风险评估表明该含数字元素产品已经包含应对该产品风险的适当且有效的安全措施，则作为合格评定程序一部分提供证据的义务，不应理解为要求制造商提供涵盖此类含数字元素产品原设计和开发阶段的测试结果。这并无必要，因为这样做无助于提高含数字元素产品本身的安全性。尽管如此，在测试仍可能必要的情况下，并不预期制造商提供对所有产品变体实施的测试的证据，而是可以跨含数字元素产品族归集此类测试，详见第7.4节“含数字元素产品族的风险评估和合格文件的再利用”。

39. Nonetheless, the manufacturer should provide evidence of how it complies with the vulnerability handling processes laid down in Part II of Annex I, it should keep its risk assessment updated in line with Article 13(3), as well as fulfil all other obligations laid down in the CRA, including by providing users with information and instructions in accordance with Article 13(18). Example 12: A manufacturer places on the market a microcontroller that was designed and developed before the date of application of the CRA. The microcontroller is intended to be integrated into a range of electronic products with digital elements, including products with digital elements with connectivity functionalities. Before placing new units of the microcontroller on the market after the CRA applies, the manufacturer carries out a cybersecurity risk assessment in accordance with Article 13(2). On the basis of the intended purpose of the microcontroller and its reasonably foreseeable use, the manufacturer identifies relevant cybersecurity risks, such as unauthorised access, manipulation of software or data, and misuse of available interfaces. The outcome of the risk assessment shows that the microcontroller, as originally designed, already incorporates appropriate and effective security measures addressing the identified risks. The manufacturer therefore concludes that the product with digital elements meets the relevant essential requirements set out in Part I of Annex I and that no redesign or introduction of additional security functionalities is necessary. Where it is not possible to demonstrate how a cybersecurity risk assessment was taken into account during the original design and development phase, the manufacturer documents a current cybersecurity risk assessment and explains how the existing design and measures mitigate the identified risks. The manufacturer is not required to recreate historical design or test documentation, as this would not contribute to enhancing the cybersecurity of the product with digital elements. Where several variants of the microcontroller are based on the same design and share the same cybersecurity risk profile, the manufacturer may also rely on representative evidence covering the relevant product family. The manufacturer also ensures compliance with the vulnerability handling requirements laid down in Part II of Annex I, including by maintaining processes to address and remediate vulnerabilities and by keeping the cybersecurity risk assessment under review in accordance with Article 13(3). In these circumstances, the microcontroller designed before the

date of application of the CRA may be placed on the market without redesign, provided that the manufacturer can demonstrate, through the cybersecurity risk assessment and the technical documentation, that it achieves an appropriate level of cybersecurity in light of its intended purpose and reasonably foreseeable use and complies with the applicable essential requirements.

> 尽管如此，制造商应当提供其如何遵守附件I第二部分所规定的漏洞处理流程的证据，应当根据第13条第3款保持其风险评估更新，并履行CRA所规定的所有其他义务，包括根据第13条第18款向用户提供信息和说明。示例12：某制造商投放市场一款在CRA开始适用之日前设计和开发的微控制器。该微控制器旨在被集成到一系列电子含数字元素产品中，包括具有连接功能的含数字元素产品。在CRA适用之后、将微控制器的新单位投放市场之前，制造商根据第13条第2款开展网络安全风险评估。根据该微控制器的预期用途及其可合理预见的使用，制造商识别出相关网络安全风险，例如未经授权的访问、对软件或数据的篡改，以及对可用接口的滥用。风险评估的结果表明，该微控制器按原设计已经包含应对已识别风险的适当且有效的安全措施。因此，制造商得出结论：该含数字元素产品符合附件I第一部分所载的相关基本要求，没有必要重新设计或引入额外的安全功能。如果无法证明在原设计和开发阶段如何考虑了网络安全风险评估，制造商应记录一份当前的网络安全风险评估，并说明既有设计和措施如何缓解已识别的风险。并不要求制造商重新制作历史设计或测试文件，因为这样做无助于增强该含数字元素产品的网络安全。如果该微控制器的若干变体基于同一设计并具有相同的网络安全风险状况，制造商还可以依赖涵盖相关产品族的代表性证据。制造商还确保遵守附件I第二部分所规定的漏洞处理要求，包括维持处理和补救漏洞的流程，并根据第13条第3款对网络安全风险评估进行审查。在这些情况下，在CRA开始适用之日前设计的微控制器可以在不重新设计的情况下被投放市场，但前提是制造商能够通过网络安全风险评估和技术文件证明：鉴于其预期用途和可合理预见的使用，它达到适当的网络安全水平，并符合适用的基本要求。

3 Free and open-source software
3 自由及开源软件

40. As recalled in Section 2.1 Placing on the market, the CRA applies to products with digital elements that are made available on the EU market in the course of a commercial activity for the first time (i.e. ‘placed on the market’), as well as to any subsequent instance that constitutes making that same product with digital elements available on the market. The Blue Guide (Section 2.2) clarifies that ‘commercial activity’ is to be understood as providing goods, in return for payment or free of charge, in a business-related context and can only be appreciated on a case-by-case basis, taking into account the regularity of the supplies, the characteristics of the product, the intentions of the supplier, etc.

> 正如第2.1节“投放市场”所回顾的，CRA适用于在商业活动过程中首次在欧盟市场上提供的含数字元素产品（即“被投放市场”），也适用于此后构成在市场上提供同一含数字元素产品的任何情形。《蓝皮书》（第2.2节）澄清，“商业活动”应理解为在与业务相关的背景下提供货物，无论有偿还是免费，并且只能逐案认定，同时考虑供应的经常性、产品的特性、供应方的意图等。

41. Supply in the course of a commercial activity is characterised by a range of circumstances, amply documented in the Blue Guide and recalled in recital 15 of the CRA. These can include directly charging a price, as well as ‘charging a price for technical support services where this does not serve only the recuperation of actual costs, by an intention to monetise, for instance by providing a software platform through which the manufacturer monetises other services, by requiring as a condition for use the processing of personal data for reasons other than exclusively for improving the security, compatibility or interoperability of the software, or by accepting donations exceeding the costs associated with the design, development and provision of a product with digital elements’ (recital 15) 11.

> 在商业活动过程中的供应，由一系列情形所表征；这些情形在《蓝皮书》中有充分记载，并在CRA序言第15项中被回顾。这些情形可以包括直接收取价款，以及“在并非仅用于收回实际成本的情况下就技术支持服务收取价款；具有变现意图，例如通过提供软件平台，制造商经由该平台变现其他服务；将出于并非专为改善

> 软件的安全性、兼容性或互操作性的原因处理个人数据作为使用条件；或者接受超过与含数字元素产品的设计、开发和提供相关成本的捐赠”（序言第15项）11。

42. The CRA, however, recognises the specificities in the different ways of developing and publishing ‘free and open-source software’ (FOSS) and offers some guidance to help identify whether a FOSS is a product with digital elements placed on the market (i.e. in the course of a commercial activity) within the meaning of the CRA. As explained in recital 18, ‘the mere circumstances under which the product with digital elements has been developed, or how the development has been financed, should […] not be taken into account when determining the commercial or non-commercial nature of that activity’. More specifically, ‘to ensure that there is a clear distinction between the development and supply phases, the provision of products with digital elements qualifying as free and open-source software that are not monetised by their manufacturers should not be considered to be a commercial activity’.

> 然而，CRA承认开发和发布“自由及开源软件”（FOSS）的不同方式所具有的特殊性，并提供若干指导，以帮助识别某一自由及开源软件是否为CRA意义上在市场上投放的含数字元素产品（即在商业活动过程中投放）。正如序言第18项所说明的，“含数字元素产品得以开发的单纯情形，或开发如何获得资助，在确定该活动的商业或非商业性质时，[……]不应当予以考虑”。更具体而言，“为确保在开发阶段与供应阶段之间有明确区分，提供符合自由及开源软件条件且未被其制造商变现的含数字元素产品，不应当被视为商业活动”。

43. It is therefore useful to (i) clarify what FOSS is; (ii) when it is deemed to fall under the responsibility of a natural or legal person; and (iii) to provide examples to help stakeholders understand when the distribution of FOSS constitutes a placement on the market. Where FOSS is not placed on the market, it falls outside the scope of the CRA, unless the entity publishing it is a legal person that meets the definition of ‘open-source software steward’ (henceforth, ‘steward’) under Article 3(14). In that case, it is subject only to the obligations laid down in Article 24.

> 因此，有必要：(i) 澄清何为自由及开源软件；(ii) 澄清其在何时被视为处于自然人或法人的责任之下；以及(iii) 提供示例，以帮助利益攸关方理解自由及开源软件的分发在何时构成投放市场。如果自由及开源软件未被投放市场，则不属于CRA的适用范围，除非发布它的实体是符合第3条第14款“开源软件管理者”（以下简称“管理者”）定义的法人。在该情况下，该法人仅受第24条所规定义务的约束。

11 It should also be recalled that, while often products with digital elements are monetised (also) via the processing of personal data, protection of personal data is a fundamental right and therefore personal data cannot be considered as a commodity, as indicated in recital 24 of Directive 2019/770 of the European Parliament and of the Council of 20 May 2019 on certain aspects concerning contracts for the supply of digital content and digital services, OJ L 136, 22.5.2019, pp. 1–27, ELI: http://data.europa.eu/eli/dir/2019/770/oj.

> 11 还应当回顾，尽管含数字元素产品往往（也）通过处理个人数据来变现，但保护个人数据是一项基本权利，因此个人数据不能被视为商品，正如欧洲议会和理事会2019年5月20日关于数字内容和数字服务供应合同某些方面的指令2019/770序言第24项所指出的。《官方公报》L 136，2019年5月22日，第1–27页，ELI: http://data.europa.eu/eli/dir/2019/770/oj。

44. Article 3(48) defines FOSS as ‘software the source code of which is openly shared and which is made available under a free and open-source licence which provides for all rights to make it freely accessible, usable, modifiable and redistributable’. While this guidance does not identify specific free and open-source licences that are compatible with the definition laid down in Article 3(48), it follows from the wording of that provision that only software that cumulatively fulfils two conditions qualifies as FOSS for the purposes of the CRA: (i) the software must be made available under a free and open-source licence granting the full set of rights referred to in Article 3(48); and (ii) its source code must be openly shared.

> 第3条第48款将自由及开源软件定义为“源代码被公开分享，并且依据一项自由及开源许可提供的软件，该许可规定使其可自由获取、使用、修改和再分发的全部权利”。本指南并不指明与第3条第48款所规定定义相容的具体自由及开源许可，但根据该款规定的措辞可以得出，就CRA而言，只有同时满足两个条件的软件才构成自由及开源软件：(i) 该软件必须依据一项授予第3条第48款所指全部权利的自由及开源许可提供；并且(ii) 其源代码必须被公开分享。

45. The requirement that the licence provide for the software to be 'freely accessible, usable, modifiable and redistributable' reflects the traditional understanding of FOSS, namely that users must be able to access the source code, use it without undue restriction, modify it and redistribute original or modified versions. Access to the source code is therefore a necessary precondition for the exercise of the other rights: without access to the source code, it is not practically possible to modify or meaningfully reuse the software.

> 许可须规定软件“可自由获取、使用、修改和再分发”这一要求，反映了对自由及开源软件的传统理解，即用户必须能够获取源代码、在没有不当限制的情况下使用它、修改它，并再分发原始版本或修改后的版本。因此，获取源代码是行使其他权利的必要前提：没有对源代码的获取，实际上就不可能修改该软件或有意义地再利用该软件。

46. However, Article 3(48) goes beyond referring only to the licence terms, as it expressly requires that the source code 'is openly shared'. The notion of 'openly shared' indicates that the source code must be made publicly available (either 'upstream' or 'downstream'), and not merely provided on a restricted or conditional basis. Accordingly, software distributed under a free and open-source licence but whose source code is only shared (or allowed to be shared) with paying customers or a limited group of users is not to be considered FOSS within the meaning of Article 3(48). For the purposes of the CRA, only software whose source code is publicly available and licensed under a free and open-source licence granting the full set of rights referred to in Article 3(48) should therefore be considered to qualify as FOSS.

> 然而，第3条第48款并不止于仅指向许可条款，因为它明确要求源代码“被公开分享”。“公开分享”这一概念表明，源代码必须被公开提供（无论是在“上游”还是在“下游”），而不是仅仅在受限制或附条件的基础上提供。因此，依据自由及开源许可分发、但其源代码仅与付费客户或有限用户群体分享（或被允许分享）的软件，不应被视为第3条第48款意义上的自由及开源软件。因此，就CRA而言，只有源代码公开可得、并且依据授予第3条第48款所指全部权利的自由及开源许可进行许可的软件，才应当被视为构成自由及开源软件。

3.1 Determining if free and open-source software is under one's responsibility
3.1 确定自由及开源软件是否处于某人的责任之下

47. The CRA places key responsibilities on economic operators that supply products with digital elements in the EU market. It defines the manufacturer as the natural or legal person that supplies a product with digital elements under its name or trademark, and that does so in the course of a commercial activity (thereby placing it on the market). Similarly, an importer is the natural or legal person established in the EU that supplies the product with digital elements of a person established outside of the EU, and that does so in the course of a commercial activity (thereby placing it on the market). The obligations of stewards apply to the legal person that supplies a FOSS intended for commercial activities12, but does not place it on the market within the meaning of the CRA.

> CRA将关键责任置于在欧盟市场上供应含数字元素产品的经济经营者。它将制造商定义为以其名称或商标供应含数字元素产品、并且在商业活动过程中这样做（从而将其投放市场）的自然人或法人。同样，进口商是在欧盟设立的自然人或法人，其供应在欧盟以外设立之人的含数字元素产品，并且在商业活动过程中这样做（从而将其投放市场）。管理者的义务适用于供应旨在用于商业活动的自由及开源软件12、但并未在CRA意义上将其投放市场的法人。

48. Therefore, to determine whether a natural or legal person is placing FOSS on the EU market, first it needs to be clarified whether that natural or legal person is actually supplying the FOSS. To correctly establish the applicable obligations under the CRA, it is essential to determine whether the natural or legal person is indeed performing the action of supplying a FOSS. In fact, as recalled in recital 18, the CRA does not apply to natural or legal persons who contribute source code to products with digital elements qualifying as FOSS that are not under their responsibility.

> 因此，要确定自然人或法人是否在将自由及开源软件投放欧盟市场，首先需要澄清该自然人或法人是否实际上在供应该自由及开源软件。为正确确定CRA项下适用的义务，必须确定该自然人或法人是否确实在实施供

> 应自由及开源软件的行为。事实上，正如序言第18项所回顾的，CRA不适用于向符合自由及开源软件条件、且并不处于其责任之下的含数字元素产品贡献源代码的自然人或法人。

49. Given the specificities of the development of FOSS, which often involves multiple contributors, decentralised collaboration models and a separation between contribution and decision-making, it is useful to clarify that FOSS is considered to be 'under the responsibility' of natural or legal persons who publish it and exercise primary control over its development, releases, and distribution decisions (often referred to as ‘maintainers’). Persons who contribute source code but do not control releases, roadmaps, or governance decisions are considered ‘contributors’; in such cases, the FOSS is not under their responsibility, even though they contributed code to it. The mere existence of technical permissions, such as commit access, is not sufficient to establish that the FOSS is under that person’s responsibility; responsibility lies with those who publish and control the FOSS. Example 13: An individual developer or an employee of a company submits a ‘pull’ or ‘merge’ request containing a security patch or a new feature to a FOSS project. The project’s maintainers review, accept and merge the code into the main repository, subsequently including it in a new release. In this scenario, the person who submitted the pull request is a ‘contributor’ and is not subject to the CRA. Although that person contributed source code, they do not exercise primary control over the development, releases or distribution decisions.

> 鉴于自由及开源软件开发的特殊性——它往往涉及多名贡献者、去中心化的协作模式，以及贡献与决策之间的分离——宜澄清：自由及开源软件被视为处于发布它并对其开发、发布和分发决定行使主要控制的自然人或法人的“责任之下”（这些人通常称为“维护者”）。贡献源代码但不控制发布、路线图或治理决定的人被视为“贡献者”；在此类情况下，该自由及开源软件并不处于其责任之下，尽管他们向其贡献了代码。仅仅存在技术权限，例如提交权限，并不足以确定该自由及开源软件处于该人的责任之下；责任在于发布并控制该自由及开源软件的人。示例13：一名个人开发者或某公司的雇员向一个自由及开源软件项目提交包含安全补丁或新功能的“拉取”或“合并”请求。该项目的维护者审查、接受并将该代码合并到主存储库，随后将其纳入一次新的发布。在这一情形中，提交拉取请求的人是“贡献者”，不受CRA约束。尽管该人贡献了源代码，但其并不对开发、发布或分发决定行使主要控制。

3.2 Determining if free and open-source software is placed on the EU market
3.2 确定自由及开源软件是否被投放欧盟市场

50. Once it is established that a FOSS is under the responsibility of a natural or legal person, it needs to be established whether that person supplies it in the course of a commercial activity, thereby constituting a placement on the market.

> 一旦确定某一自由及开源软件处于自然人或法人的责任之下，就需要确定该人是否在商业活动过程中供应它，从而构成投放市场。

3.2.1 Charging a price
3.2.1 收取价款

51. Where the natural or legal person that supplies a FOSS charges a price for the software itself (e.g. by charging a price for the pre-compiled binaries), that person is placing a product with digital elements on the market. The person that places a FOSS on the market is therefore a manufacturer under the CRA.

> 如果供应自由及开源软件的自然人或法人就软件本身收取价款（例如就预编译二进制文件收取价款），则该人是在将含数字元素产品投放市场。因此，将自由及开源软件投放市场的人是CRA项下的制造商。

12 This is a necessary but not sufficient condition for a legal person to qualify as an open-source software steward, as the definition set out in Article 3(14) lays down additional conditions for a legal person to qualify as steward.

> 12 这是法人构成开源软件管理者的必要但不充分条件，因为第3条第14款所规定的定义还为法人构成管理者规定了额外条件。

52. Often, manufacturers of FOSS supply versions for free of that software (often called ‘community’ versions), whose codebase is (almost) identical to the paid version. Those products with digital elements, however, are different products:

the paid version is monetised in some way (e.g. either by charging a price or via other means as discussed in this section) and therefore considered to be placed on the market, triggering the manufacturer's obligations. The version provided for free (or community version) is not monetised and therefore is not considered to be placed on the market for the purposes of the CRA. This is also the case where the paid version is an 'enhanced' commercial version, which extends the codebase of the version provided for free, or incorporates that version into a broader product with digital elements (e.g. as in the case of the 'open-core' model).

> 自由及开源软件的制造商往往免费供应该软件的版本（通常称为“社区”版），其代码库与付费版本（几乎）相同。然而，这些含数字元素产品是不同的产品：付费版本以某种方式被变现（例如通过收取价款，或通过本节所讨论的其他方式），因此被视为被投放市场，从而引发制造商的义务。免费提供的版本（或社区版）未被变现，因此就CRA而言不视为被投放市场。付费版本是“增强”商业版本的情形亦同；该增强版本扩展了免费提供版本的代码库，或将该版本纳入更广泛的含数字元素产品（例如“开放核心”模式的情形）。

53. If the person supplying the community version is a legal person, that legal person is also subject to the obligations on stewards for the version it supplies for free (the community version). If the entity is a natural person, the version provided for free (the community version) is not within the scope of the CRA.

> 如果供应社区版的人是法人，则该法人对其免费供应的版本（社区版）也受管理者义务的约束。如果该实体是自然人，则免费提供的版本（社区版）不属于CRA的适用范围。

3.2.2 Monetisation of other services or requiring the processing of personal data
3.2.2 变现其他服务或要求处理个人数据

54. A natural or legal person publishing a FOSS may also be placing it on the market (i.e. supplying it in the course of a commercial activity) where it provides the software through which it monetises other products with digital elements or services, or where it requires as a condition for use the processing of personal data for reasons other than exclusively for improving the security, compatibility or interoperability of the software. Example 14: A natural or legal person publishes a free and open-source marketplace application. The application is available free of charge and enables users to purchase goods or services through it. The app allows the person that published it to monetise other products with digital elements and services offered through it (e.g. through advertisements, commission fees or subscription fees). Therefore, the application is considered placed on the market in the course of a commercial activity. Example 15: A natural or legal person publishes a free and open-source VPN. The application is available free of charge, but it enables users to pay to access additional servers or dedicated IP addresses. That application allows that person to monetise other services offered through it, therefore it is considered placed on the market in the course of a commercial activity. Example 16: A natural or legal person publishes a free and open-source fitness tracking application. The application is available free of charge, but its use is conditional upon the processing of users' personal data for purposes such as targeted advertising or analytics unrelated to the security, compatibility or interoperability of the software. By requiring such data processing as a condition for use, the application is therefore considered placed on the market in the course of a commercial activity.

> 发布自由及开源软件的自然人或法人，在通过该软件变现其他含数字元素产品或服务的情况下，或者在将出于并非专为改善软件的安全性、兼容性或互操作性的原因处理个人数据作为使用条件的情况下，也可能是在将其投放市场（即在商业活动过程中供应它）。示例14：某自然人或法人发布一款自由及开源的市场应用程序。该应用程序免费提供，并使用户能够通过它购买货物或服务。该应用程序使发布它的人能够变现通过它所提供的其他含数字元素产品和服务（例如通过广告、佣金或订阅费）。因此，该应用程序被视为在商业活动过程中被投放市场。示例15：某自然人或法人发布一款自由及开源VPN。该应用程序免费提供，但使用户能够付费访问额外的服务器或专用IP地址。该应用程序使该人能够变现通过它所提供的其他服务，因此被视为在商业活动过程中被投放市场。示例16：某自然人或法人发布一款自由及开源的健身追踪应用程序。该应用程序免费提供，但其使用以处理用户个人数据为条件，处理目的例如定向广告或与软件的安全性、兼容性

> 或互操作性无关的分析。由于将此类数据处理作为使用条件，该应用程序因此被视为在商业活动过程中被投放市场。

3.2.3 Support services
3.2.3 支持服务

55. The mere fact that a natural or legal person publishing a FOSS also offers paid support services related to it does not, as such, mean that the product with digital elements is supplied in the course of a commercial activity. Support services may include activities such as consultancy, training or professional services related to the use, documentation, configuration and deployment of the software by a customer.

> 发布自由及开源软件的自然人或法人同时也提供与之相关的付费支持服务，仅此事实本身并不意味着该含数字元素产品是在商业活动过程中被供应的。支持服务可以包括与客户使用、记录、配置和部署该软件有关的咨询、培训或专业服务等活动。

56. The decisive factor is whether access to the FOSS itself (i.e. the provision of the product with digital elements), including its maintenance, is conditioned on remuneration, rather than the mere offering of professional services around a freely available product with digital elements, as indicated in recital 18 of the CRA ('the provision of products with digital elements qualifying as free and open-source software that are not monetised by their manufacturers should not be considered to be a commercial activity'). Where the FOSS can be downloaded and installed freely, and users can optionally choose to purchase professional services separately, that FOSS is not considered to be placed on the market.

> 决定性因素是，对自由及开源软件本身的获取（即含数字元素产品的提供），包括其维护，是否以取得报酬为条件，而不是仅仅围绕一项可自由获取的含数字元素产品提供专业服务，正如CRA序言第18项所指出的（“提供符合自由及开源软件条件且未被其制造商变现的含数字元素产品，不应当被视为商业活动”）。如果该自由及开源软件可以免费下载和安装，并且用户可以选择另行购买专业服务，则该自由及开源软件不视为被投放市场。

57. By contrast, in some cases access to a specific version of the product with digital elements including certain benefits such as technical assistance or performance optimisation, is conditioned on remuneration. In such cases, that provision constitutes a monetised provision of a product with digital elements supplied in the course of a commercial activity and is therefore considered placed on the market. This includes cases where a paid edition or enterprise version is made available under a commercial agreement, irrespective of whether functionally equivalent software is also available free of charge under a free and open-source licence. Example 17: A natural or legal person publishes a free and open-source operating system, offering a paid version of that operating system which includes support services, such as technical assistance or performance optimisation. The paid version of the operating system is considered placed on the market in the course of a commercial activity. Example 18: A natural or legal person publishes a free and open-source command line tool. The tool is freely accessible and anyone can download and install it. That natural or legal person separately offers professional services, such as optional consultancy services to train users and support them in installing and using the tool. That FOSS is not considered placed on the market within the meaning of the CRA.

> 相反，在某些情况下，对包含技术协助或性能优化等某些利益的含数字元素产品特定版本的获取，以取得报酬为条件。在此类情况下，该提供构成在商业活动过程中供应的、被变现的含数字元素产品提供，因此被视为被投放市场。这包括付费版或企业版依据商业协议提供的情形，不论功能上等同的软件是否也依据自由及开源许可免费提供。示例17：某自然人或法人发布一款自由及开源操作系统，并提供该操作系统的付费版本，其中包含支持服务，例如技术协助或性能优化。该操作系统的付费版本被视为在商业活动过程中被投放市场。示例18：某自然人或法人发布一款自由及开源命令行工具。该工具可自由获取，任何人都可以下载和安装它。该自然人或法人另行提供专业服务，例如可选的咨询服务，以培训用户并支持其安装和使用该工具。该自由及开源软件不视为在CRA意义上被投放市场。

58. Particularly in the case of natural persons publishing FOSS, offering technical assistance directly bundled with access to the product with digital elements would still not qualify as a commercial activity if, as indicated by recital 15 of the CRA, the price charged serves only the recuperation of actual costs. Such actual costs include a variety of costs related to that software's design, development and maintenance, including the person's reasonable living expenses. Therefore, a natural person publishing a FOSS and offering technical assistance to cover their costs and obtain fair remuneration is not to be considered, on that basis alone, as placing that software on the EU market.

> 特别是在自然人发布自由及开源软件的情况下，将技术协助与获取含数字元素产品直接捆绑提供，如果正如CRA序言第15项所指出的，所收取的价款仅用于收回实际成本，则仍然不构成商业活动。此类实际成本包括与该软件的设计、开发和维护有关的各种成本，包括该人的合理生活费用。因此，发布自由及开源软件并提供技术协助以覆盖其成本并获得公平报酬的自然人，仅凭这一点，不应被视为将该软件投放欧盟市场。

59. A natural or legal person offering technical assistance related to a FOSS not under its responsibility is not considered to be placing that software on the market, unless that person substantially modifies the FOSS, in accordance with Article 22, as part of their delivery of such assistance. Example 19: A service provider does not publish a FOSS, but helps a customer install it on the customer's on-premises server. It does so without performing a substantial modification of that FOSS. The service provider is therefore not considered to be placing the FOSS on the market.

> 就并不处于其责任之下的自由及开源软件提供技术协助的自然人或法人，不视为将该软件投放市场，除非该人在交付此类协助时根据第22条对该自由及开源软件进行了实质性修改。示例19：某服务提供者不发布某一自由及开源软件，但帮助客户将其安装在客户的本地服务器上。其这样做时并未对该自由及开源软件进行实质性修改。因此，该服务提供者不视为将该自由及开源软件投放市场。

3.2.4 Donations
3.2.4 捐赠

60. Natural or legal persons publishing FOSS projects routinely include ways for users of that software to voluntarily donate money to thank the project's publisher(s) and also to ensure that the project remains actively maintained.

> 发布自由及开源软件项目的自然人或法人，通常会纳入使用户自愿捐赠金钱的方式，以感谢项目的发布者，并确保项目保持积极维护。

61. As indicated in recital 15 of the CRA 'accepting donations without the intention of making a profit should not be considered to be a commercial activity'. The mere fact of including a link to a donation platform or similar tools to collect donations should not be viewed as an intention to make a profit, even where the amount collected via donations exceeds the mere costs associated with the design, development and provision of a product with digital elements. This includes reasonable compensation for the contributors hired by a legal person, and/or a natural person's reasonable living expenses. Donations, by their very nature, fluctuate over time, and therefore a degree of flexibility is to be exercised when assessing whether a FOSS monetised exclusively through donations is considered to be placed on the market. A FOSS supported only through donations is therefore unlikely to be considered to be placed on the market within the meaning of the CRA. Example 20: A natural or legal person publishes a FOSS tool in a public online repository, allowing anyone to download, use, modify and redistribute it under a free and open-source licence. The publisher invites users to make voluntary donations via a donation platform to support the project's continued development and maintenance. Access to the software, its source code and its updates is not conditional on making a donation. That FOSS is not considered to be supplied in the course of a commercial activity and is not considered to be placed on the market within the meaning of the CRA.

> 正如CRA序言第15项所指出的，“接受捐赠而无营利意图，不应当被视为商业活动”。纳入指向捐赠平台或类似工具以收集捐赠的链接，仅此事实不应被视为营利意图，即使通过捐赠收集的金额超过与含数字元素产品的设计、开发和提供相关的单纯成本。这包括对法人所雇用贡献者的合理报酬，和/或自然人的合理生活费用。捐赠就其性质而言随时间波动，因此在评估仅通过捐赠变现的自由及开源软件是否被视为被投放市场

> 时，应当行使一定程度的灵活性。因此，仅通过捐赠获得支持的自由及开源软件，不太可能被视为在CRA意义上被投放市场。示例20：某自然人或法人在公共在线存储库中发布一款自由及开源软件工具，允许任何人依据自由及开源许可下载、使用、修改和再分发它。发布者邀请用户通过捐赠平台作出自愿捐赠，以支持项目的持续开发和维护。获取该软件、其源代码及其更新，并不以作出捐赠为条件。该自由及开源软件不视为在商业活动过程中被供应，也不视为在CRA意义上被投放市场。

62. Nonetheless, there are instances where a FOSS supported through donations may be considered to be placed on the market. This is the case where, based on an overall assessment of the circumstances, the donations are de facto equivalent to charging a price to access the product with digital elements or certain of its functionalities. This may be the case, in particular, where access to the FOSS, to essential functionalities or to updates is conditioned in practice on making a donation, or where donations are associated with contractual benefits or exclusive advantages that go beyond community perks. Example 21: A natural or legal person publishes a software product with digital elements under a free and open-source licence, but provides downloadable releases and security updates only to users who make a donation. Users who do not make a donation do not have access to the software's current version. In this case, the donations are de facto a condition for access to the product with digital elements and therefore amount to charging a price. That FOSS is therefore considered to be placed on the market within the meaning of the CRA. Example 22: A natural or legal person makes the source code of a FOSS publicly available, but provides pre-compiled binaries, regular updates and guaranteed security fixes only to donors. In this case, the donations are linked to access to essential aspects of the product with digital elements and constitute remuneration for that product's supply. That FOSS is therefore considered to be placed on the market in the course of a commercial activity.

> 尽管如此，在某些情况下，通过捐赠获得支持的自由及开源软件可能被视为被投放市场。根据对有关情形的整体评估，捐赠事实上等同于为获取含数字元素产品或其某些功能而收取价款的，即属此种情形。特别是，在实践中对自由及开源软件、对基本功能或对更新的获取以作出捐赠为条件，或者捐赠与超出社区福利的合同利益或专属优势相联系的，即可能如此。示例21：某自然人或法人依据自由及开源许可发布一款含数字元素软件产品，但仅向作出捐赠的用户提供可下载的发布版本和安全更新。不作出捐赠的用户不能获取该软件的当前版本。在此情况下，捐赠事实上是获取含数字元素产品的条件，因此等同于收取价款。因此，该自由及开源软件被视为在CRA意义上被投放市场。示例22：某自然人或法人公开提供某一自由及开源软件的源代码，但仅向捐赠者提供预编译二进制文件、定期更新和有保证的安全修复。在此情况下，捐赠与获取含数字元素产品的基本方面相联系，并构成对该产品供应的报酬。因此，该自由及开源软件被视为在商业活动过程中被投放市场。

3.2.5 Financing of free and open-source software
3.2.5 自由及开源软件的资助

63. The mere fact that a third party has paid for, sponsored or otherwise financed the development of a FOSS does not in itself determine whether that FOSS is placed on the market. It is common practice in the FOSS ecosystem for individual developers, foundations or communities to receive funding from companies, public bodies or other sponsors in order to work on specific features, fix bugs or maintain critical components. This funding may take many forms, including grants, bug bounties, sponsorships, service contracts or paid development work.

> 第三方已支付、赞助或以其他方式资助某一自由及开源软件的开发，仅此事实本身并不决定该自由及开源软件是否被投放市场。在自由及开源软件生态系统中，个人开发者、基金会或社区从公司、公共机构或其他赞助者获得资金，以便从事特定功能、修复缺陷或维护关键组件，是常见做法。此类资助可以采取多种形式，包括赠款、漏洞赏金、赞助、服务合同或有偿开发工作。

64. As already recalled, recital 18 of the CRA, clarifies that the mere circumstances under which the product with digital elements has been developed, or how the development has been financed, should not be taken into account when determining the commercial nature of that activity.

> 正如已经回顾的，CRA序言第18项澄清，含数字元素产品得以开发的单纯情形，或开发如何获得资助，在确定该活动的商业性质时不应当予以考虑。

65. Therefore, where the FOSS is openly shared and made freely available for all to access, use, modify and redistribute, the fact that a commercial entity may have paid for that project should not contribute to determining whether the software is placed on the market. In fact, if that FOSS is not otherwise monetised, it is not to be considered as placed on the market. Where the company that funded the FOSS's development (as well as any other company) integrates it into its product with digital elements, that company is to exercise due diligence in accordance with Article 13(5) of the CRA. Example 23: An individual developer publishes a FOSS project and actively maintains it. Manufacturer A requests that the individual developer add a specific feature for that FOSS, and funds that development. The developer adds the feature to the FOSS codebase, openly sharing it and making it freely available for all to access, use, modify and redistribute. The individual developer is not considered to have placed that FOSS on the market. If the manufacturer integrates the FOSS into its product with digital elements, it needs to exercise due diligence in accordance with Article 13(5).

> 因此，如果自由及开源软件被公开分享，并免费提供给所有人获取、使用、修改和再分发，则某一商业实体可能已为该项目付费这一事实，不应当用于确定该软件是否被投放市场。事实上，如果该自由及开源软件并未以其他方式被变现，则不应视为被投放市场。如果资助该自由及开源软件开发的公司（以及任何其他公司）将其集成到自己的含数字元素产品中，则该公司应当根据CRA第13条第5款开展尽职调查。示例23：一名个人开发者发布一个自由及开源软件项目并积极维护它。制造商A要求该个人开发者为该自由及开源软件增加一项特定功能，并资助该开发。开发者将该功能加入自由及开源软件的代码库，公开分享它，并使其免费提供给所有人获取、使用、修改和再分发。该个人开发者不视为已将该自由及开源软件投放市场。如果该制造商将该自由及开源软件集成到自己的含数字元素产品中，则需要根据第13条第5款开展尽职调查。

3.2.6 Not-for-profit entities set up to achieve not-for-profit objectives
3.2.6 为达成非营利目的而设立的非营利实体

66. Where a legal person publishing a FOSS is a not-for-profit organisation 'set up in such a way that ensures that all earnings after costs are used to achieve not-for-profit objectives' (recital 18 of the CRA), the FOSS it publishes is not considered to be placed on the market. Where that legal person meets the definition of 'steward', it is subject to the corresponding obligations (Article 24 of the CRA). Example 24: A legal person publishes a free and open-source browser that is directly monetised via search engine partnerships, but all its earnings after costs are used for not-for-profit objectives. The browser is not considered to be placed on the market within the meaning of the CRA. The legal person publishing it is subject to the obligations applicable to stewards.

> 如果发布自由及开源软件的法人是"以确保扣除成本后的全部收益用于实现非营利目的的方式设立"的非营利组织（CRA序言第18项），则其所发布的自由及开源软件不视为被投放市场。如果该法人符合"管理者"的定义，则受相应义务的约束（CRA第24条）。示例24：某法人发布一款通过搜索引擎合作直接变现的自由及开源浏览器，但其扣除成本后的全部收益均用于非营利目的。该浏览器不视为在CRA意义上被投放市场。发布它的法人受适用于管理者的义务的约束。

3.2.7 Integration by other manufacturers
3.2.7 由其他制造商集成

67. In some cases, a FOSS is published by a clearly identifiable natural or legal person, but that FOSS is 'intended for integration by other manufacturers into their own products with digital elements'. In such cases, that FOSS is not considered to be placed on the EU market, unless it is also monetised by the person that publishes it (i.e. the original manufacturer), in line with previous sections of this guidance.

> 在某些情况下，自由及开源软件由可以明确识别的自然人或法人发布，但该自由及开源软件"旨在供其他制造商集成到其自己的含数字元素产品中"。在此类情况下，该自由及开源软件不视为被投放欧盟市场，除非

> 它也被发布它的人（即原始制造商）变现，这与本指南前面各节相一致。

68. Where that FOSS is not placed on the market, the legal person publishing it would be subject to the obligations of stewards, if it provides support on a sustained basis, in line with the definition of ‘steward’. Example 25: A legal person publishes a FOSS library for building user interfaces. It does not monetise the supply of that library, but integrates it into one of its products with digital elements (which is in turn placed on the market). The library is not considered placed on the market within the meaning of the CRA, but it is intended for integration into products with digital elements. The legal person that publishes it is its steward. Example 26: A legal person places an operating system on the market, and also publishes FOSS libraries to serve as reference implementations for users of that operating system. The legal person does not monetise the FOSS libraries, which are intended for integration into other products with digital elements. The legal person that publishes them is a steward to those FOSS libraries.

> 如果该自由及开源软件未被投放市场，则发布它的法人在按照“管理者”的定义持续提供支持的情况下，将受管理者义务的约束。示例25：某法人发布一个用于构建用户界面的自由及开源软件库。它并不变现该库的供应，但将其集成到自己的一款含数字元素产品中（该产品又被投放市场）。该库不视为在CRA意义上被投放市场，但它旨在被集成到含数字元素产品中。发布它的法人是其管理者。示例26：某法人将一款操作系统投放市场，并同时发布自由及开源软件库，作为该操作系统用户的参考实现。该法人并不变现这些自由及开源软件库，而这些库旨在被集成到其他含数字元素产品中。发布它们的法人是这些自由及开源软件库的管理者。

3.3 Open-source software stewards
3.3 开源软件管理者

69. The CRA introduces the novel legal category of ‘open-source software steward’ in light of ‘the importance for cybersecurity of many products with digital elements qualifying as free and open-source software that are published, but not made available on the market within the meaning of the [CRA]’ (recital 19 of the CRA).

> CRA鉴于“许多被发布、但并未在[CRA]意义上在市场上提供的、符合自由及开源软件条件的含数字元素产品对网络安全的重要性”（CRA序言第19项），引入了“开源软件管理者”这一新的法律类别。

70. In some cases, a FOSS is published but not made available on the market within the meaning of the CRA by a legal person who ‘has the purpose or objective of systematically providing support on a sustained basis for the development of [FOSS] […] intended for commercial activities, and that ensures the viability of those products’ (Article 3(14) of the CRA). In such cases, that legal person is subject to the obligations of stewards.

> 在某些情况下，自由及开源软件由某一法人发布，但并未在CRA意义上在市场上提供，而该法人“其目的或宗旨在于持续、系统地为旨在用于商业活动的[自由及开源软件]的开发提供支持，并确保这些产品的存续”（CRA第3条第14款）。在此类情况下，该法人受管理者义务的约束。

71. A steward is defined as ‘a legal person, other than a manufacturer’ because a manufacturer, by definition, is the natural or legal person who places products with digital elements on the market (‘markets them’) under its own name or trademark. A legal person can be a steward only to products with digital elements qualifying as FOSS that are published, but not made available on the market within the meaning of the CRA. The concept of steward, therefore, applies to specific instances of FOSS that ‘are ultimately intended for commercial activities, such as for integration into commercial services or into monetised products with digital elements’ (recital 19 of the CRA13) but not made available on the market within the meaning of the CRA, and for which the legal person publishing that FOSS ensures systematic support.

> 管理者被定义为“制造商以外的法人”，因为制造商根据定义是以自己的名称或商标将含数字元素产品投放市场（“将其销售”）的自然人或法人。法人只能对符合自由及开源软件条件、被发布但并未在CRA意义上在市场上提供的含数字元素产品担任管理者。因此，管理者这一概念适用于如下具体的自由及开源软件情形：该软件“最终旨在用于商业活动，例如被集成到商业服务中或被集成到已变现的含数字元素产品中”

> （CRA序言第19项13），但并未在CRA意义上在市场上提供，并且发布该自由及开源软件的法人确保系统性支持。

72. Being a steward for one specific FOSS does not mean that that legal person is necessarily also a steward for other FOSS that it publishes. Similarly, being a manufacturer for one specific FOSS does not mean that the legal person may not be a steward for other FOSS. This includes providing 'community' versions of the same FOSS, as described in Section 3.2.1 Charging a price.

> 担任某一特定自由及开源软件的管理者，并不意味着该法人必然也是其所发布的其他自由及开源软件的管理者。同样，担任某一特定自由及开源软件的制造商，并不意味着该法人不能担任其他自由及开源软件的管理者。这包括提供同一自由及开源软件的“社区”版，如第3.2.1节“收取价款”所述。

73. A legal person may therefore simultaneously be a steward for one specific FOSS (where the steward systematically provides support on a sustained basis and ensures the software's viability) and a manufacturer for another specific FOSS (where it places it on the market). In other words, the same legal entity can be required to fulfil different roles for different FOSS projects.

> 因此，某一法人可以同时是某一特定自由及开源软件的管理者（管理者持续、系统地提供支持并确保该软件的存续），又是另一特定自由及开源软件的制造商（将其投放市场）。换言之，同一法律实体可能被要求就不同的自由及开源软件项目履行不同角色。

74. For each specific FOSS that it publishes, the legal person will need to ascertain whether that FOSS is considered to be placed on the market within the meaning of the CRA. If so, that makes the legal entity the software's manufacturer. If the FOSS is not considered to be placed on the market, the legal person may be the steward to it, if the software is intended for commercial activities and if the legal person is sustaining it in line with the definition of steward14.

> 对于其所发布的每一项特定自由及开源软件，该法人需要确定该自由及开源软件是否被视为在CRA意义上被投放市场。如果是，则该法律实体成为该软件的制造商。如果该自由及开源软件不视为被投放市场，则在该软件旨在用于商业活动、并且该法人按照管理者的定义维持它的情况下，该法人可以是其管理者14。

3.3.1 Sustained support and ensuring viability of FOSS
3.3.1 持续支持并确保自由及开源软件的存续

75. Recital 19 explains that the provision of sustained support to the development of a product with digital elements may include (but is not limited to): (i) the hosting and managing of software development collaboration platforms; (ii) hosting source code or software; (iii) governing or managing products with digital elements qualifying as FOSS; and (iv) steering the development of such products with digital elements.

> 序言第19项说明，对含数字元素产品的开发提供持续支持可以包括（但不限于）：(i) 托管和管理软件开发协作平台；(ii) 托管源代码或软件；(iii) 治理或管理符合自由及开源软件条件的含数字元素产品；以及(iv) 引导此类含数字元素产品的开发。

76. This may be the case, for example, for a legal entity that develops FOSS for integration into its own products with digital elements and then publishes it without placing it on the market. This is also discussed in Section 3.2.7 Integration by other manufacturers. In this case, the legal entity is not a manufacturer of the software, but may be a steward to it. Additionally, as also explained in previous sections, a legal entity that publishes a free (or community) version and a monetised version of the same FOSS, is deemed a steward to the free (or community) version, and a manufacturer to the monetised version.

> 例如，开发自由及开源软件以集成到自己的含数字元素产品中、然后在不将其投放市场的情况下予以发布的法律实体，即可能如此。第3.2.7节“由其他制造商集成”也讨论了这一点。在此情况下，该法律实体不是该

> 软件的制造商，但可以是其管理者。此外，正如前面各节亦所说明的，发布同一自由及开源软件的免费（或社区）版本和变现版本的法律实体，被视为免费（或社区）版本的管理者，以及变现版本的制造商。

13 This notion is also contained in the formulation ‘intended for commercial activities’ included in the definition of ‘open-source software steward’ set out in Article 3(14) of the CRA. 14 The legal person may also not be subject to any obligations under the CRA, in cases where: (i) a specific FOSS is not placed on the market within the meaning of the CRA; and (ii) the legal entity does not meet the definition of steward in relation to that specific FOSS.

> 13 这一概念也包含在CRA第3条第14款所规定的“开源软件管理者”定义中的“旨在用于商业活动”这一表述之内。14 在下列情况下，该法人也可能不受CRA项下任何义务的约束：(i) 某一特定自由及开源软件并未在CRA意义上被投放市场；并且(ii) 该法律实体就该特定自由及开源软件不符合管理者的定义。

77. Similarly, a legal entity that monetises a FOSS but is a not-for-profit entity whose earnings after costs are used to achieve not-for-profit objectives (and therefore its FOSS is not placed on the market within the meaning of the CRA, as discussed in Section 3.2.6 Not-for-profit entities) is a steward to the FOSS it publishes.

> 同样，变现某一自由及开源软件、但是扣除成本后的收益用于实现非营利目的的非营利实体（因此其自由及开源软件并未在CRA意义上被投放市场，如第3.2.6节“非营利实体”所讨论的），是其所发布的自由及开源软件的管理者。

78. Furthermore, certain foundations offer collaboration platforms with various forms of governance that enable manufacturers to contribute regularly to the development of FOSS and/or that are regularly financed by manufacturers. Such foundations are to be considered stewards in relation to specific FOSS which are intended for commercial activities and for which the foundation offers sustained support. However, as explained in Section 3.3 Open-source software stewards, such a foundation may not be subject to any obligations under the CRA for other specific FOSS that it hosts, in cases where it does not provide systematic support for a specific FOSS, it does not ensure its viability, and/or that specific software is not intended for commercial activities.

> 此外，某些基金会提供具有各种治理形式的协作平台，使制造商能够定期为自由及开源软件的开发作出贡献，和/或由制造商定期资助。就旨在用于商业活动、并且基金会为其提供持续支持的特定自由及开源软件而言，此类基金会应被视为管理者。然而，正如第3.3节“开源软件管理者”所说明的，如果基金会并不为某一特定自由及开源软件提供系统性支持、并不确保其存续，和/或该特定软件并非旨在用于商业活动，则该基金会就其所托管的其他特定自由及开源软件可能不受CRA项下任何义务的约束。

79. The type of ‘sustained support’ that foundations and similar organisations provide to specific FOSS projects can vary greatly. For example, certain legal entities only provide non-technical support, such as managing the branding of projects, laying down governance rules, organising community events or collecting donations. Other entities also provide the underlying IT infrastructure necessary to run the project, such as hosting source code repositories, providing version control systems, or generating signing keys. Others go further in the type of support they provide by actively contributing engineering resources to the project, for example by employing developers, coordinating development work, reviewing or merging code, managing releases, or handling vulnerability reports and security patches. While all legal entities that qualify as stewards under the CRA are required to comply with the obligations in Article 24(1) and (2), how far the obligations laid down in Article 14(1), (3) and (8) apply to those legal entities varies depending on the type of support they provide, in accordance with Article 24(3).

> 基金会和类似组织向特定自由及开源软件项目提供的“持续支持”的类型可能差异很大。例如，某些法律实体仅提供非技术性支持，例如管理项目品牌、制定治理规则、组织社区活动或收集捐赠。其他实体还提供运行项目所必需的底层信息技术基础设施，例如托管源代码存储库、提供版本控制系统或生成签名密钥。另一些实体在其所提供的支持类型上更进一步，积极向项目贡献工程资源，例如雇用开发者、协调开发工作、审查或合并代码、管理发布，或处理漏洞报告和安全补丁。尽管所有符合CRA项下管理者资格的法律实体都必须遵守第24条第1款和第2款的义务，但第14条第1款、第3款和第8款所规定的义务在多大程度上适用于这些法律实体，依其所提供的支持类型而有所不同，这符合第24条第3款。

80. For example, a steward that only provides non-technical support is, by definition, not involved in development of the product with digital elements, and is therefore not required to report actively exploited vulnerabilities. That steward also does not provide any network and information systems for the development of such products with digital elements, and therefore is not required to report severe incidents to ENISA and the CSIRTs or to impacted users. Nonetheless, where the steward becomes aware of an actively exploited vulnerability (e.g. via a report from external sources, such as security researchers), it should share the information with the maintainers of the product with digital elements, in accordance with its cybersecurity policy. The maintainers of the products with digital elements and/or the stewards should also consider reporting the vulnerability on a voluntary basis, in accordance with Article 15.

> 例如，仅提供非技术性支持的管理者，根据定义并不参与含数字元素产品的开发，因此不需要报告已遭积极利用的漏洞。该管理者也不为开发此类含数字元素产品提供任何网络和信息系统，因此不需要向欧盟网络安全局和计算机安全事件响应小组（CSIRT）或向受影响用户报告严重事件。尽管如此，如果管理者知悉某一已遭积极利用的漏洞（例如通过安全研究人员等外部来源的报告），则应当根据其网络安全政策与该含数字元素产品的维护者分享该信息。含数字元素产品的维护者和/或管理者还应当考虑根据第15条在自愿基础上报告该漏洞。

81. On the other hand, where a steward provides the underlying IT infrastructure for certain products with digital elements, it is required to notify ENISA and the CSIRTs, in accordance with Article 14(3) of any severe incidents related to that infrastructure that have an impact on the security of products with digital elements. It is also required, where appropriate, to inform all users (e.g. via a general announcement). As indicated in the previous point, while the steward is not required to report actively exploited vulnerabilities it becomes aware of, it should foster the correct handling of vulnerabilities and should consider voluntary reporting in accordance with Article 15.

> 另一方面，如果管理者为某些含数字元素产品提供底层信息技术基础设施，则其必须根据第14条第3款，就与该基础设施有关、并对含数字元素产品的安全有影响的任何严重事件，通知欧盟网络安全局和计算机安全事件响应小组。在适当情况下，其还必须告知所有用户（例如通过一般公告）。正如上一点所指出的，尽管管理者并不必须报告其所知悉的已遭积极利用的漏洞，但其应当促进对漏洞的正确处理，并应当考虑根据第15条进行自愿报告。

82. Finally, where a steward also provides engineering resources to specific products with digital elements, it is required to: (i) notify, in accordance with Article 14(1), of actively exploited vulnerabilities that it becomes aware of; and (ii) where appropriate, to inform all users. To the extent that the steward also has a direct relationship with impacted users, it is also required to inform them directly, in accordance with Article 14(8).

> 最后，如果管理者还向特定含数字元素产品提供工程资源，则其必须：(i) 根据第14条第1款，通知其所知悉的已遭积极利用的漏洞；以及(ii) 在适当情况下，告知所有用户。在管理者与受影响用户也有直接关系的范围内，其还必须根据第14条第8款直接告知这些用户。

83. Where an entity ceases to provide systematic support on a sustained basis for a specific FOSS, it may no longer meet the definition of steward and may therefore no longer be subject to the corresponding obligations. In such cases, that entity is encouraged to communicate clearly the change in its status for that specific FOSS.

> 如果某一实体停止对某一特定自由及开源软件持续提供系统性支持，则其可能不再符合管理者的定义，因此可能不再受相应义务的约束。在此类情况下，鼓励该实体就该特定自由及开源软件清晰告知其地位的变化。

84. In certain situations, an entity that was a steward to a specific project may decide to monetise that project directly, thereby placing the product with digital elements on the market and triggering the manufacturer’s obligations under the CRA. In such circumstances, that entity qualifies as the manufacturer of the product with digital elements from the date on which it places it on the market (but not in respect of earlier versions for which it acted as a steward).

> 在某些情况下，曾担任某一特定项目管理者的实体可能决定直接变现该项目，从而将含数字元素产品投放市场，并引发CRA项下制造商的义务。在此类情形下，该实体自将其投放市场之日起构成该含数字元素产品的

> 制造商（但不涉及其曾作为管理者行事的更早版本）。

3.4 Contributors and downstream uses
3.4 贡献者与下游使用

85. As already mentioned in Section 3.1 Determining if free and open-source software is under one's responsibility, the CRA clarifies that it does not apply 'to natural or legal persons who contribute with source code to products with digital elements qualifying as free and open-source software that are not under their responsibility' (recital 18).

> 正如第3.1节“确定自由及开源软件是否处于某人的责任之下”已经提到的，CRA澄清，它不适用于“向符合自由及开源软件条件、且并不处于其责任之下的含数字元素产品贡献源代码的自然人或法人”（序言第18项）。

86. Manufacturers of products with digital elements that integrate FOSS components into their own products with digital elements also do not become responsible for such components' individual compliance with the CRA, even where the manufacturers contribute source code to their maintenance.

> 将自由及开源软件组件集成到自己的含数字元素产品中的含数字元素产品制造商，也不对这些组件各自遵守CRA承担责任，即使这些制造商为其维护贡献了源代码。

87. Similarly, the mere fact that manufacturers integrate FOSS components into their own (monetised) products with digital elements has no impact on the status of that FOSS component under the CRA. Maintainers of FOSS components that are not placed on the market do not bear obligations in relation to other entities that may integrate such components into their products with digital elements. Whether the CRA applies to a given FOSS component depends solely on whether the natural or legal person that publishes it places it on the market.

> 同样，制造商将自由及开源软件组件集成到自己的（已变现）含数字元素产品中，仅此事实对该自由及开源软件组件在CRA项下的地位没有影响。未被投放市场的自由及开源软件组件的维护者，不对可能将这些组件集成到其含数字元素产品中的其他实体承担义务。CRA是否适用于某一给定的自由及开源软件组件，仅取决于发布它的自然人或法人是否将其投放市场。

88. Nonetheless, manufacturers of products with digital elements that integrate FOSS components are required to comply with the CRA for their own products with digital elements. They also have a due diligence obligation, in accordance with Article 13(5), towards the FOSS components that they integrate. In addition, they are required to report vulnerabilities in integrated components and share security fixes in accordance with Article 13(6). For more guidance on this topic, see Section 9.2.1 Reporting upstream and sharing security fixes.

> 尽管如此，集成自由及开源软件组件的含数字元素产品制造商，必须就其自己的含数字元素产品遵守CRA。他们还根据第13条第5款，对其所集成的自由及开源软件组件负有尽职调查义务。此外，他们必须根据第13条第6款报告集成组件中的漏洞并分享安全修复。关于这一主题的进一步指导，见第9.2.1节“向上游报告并分享安全修复”。

3.5 Illustrative scenarios
3.5 示例情形

89. The examples listed below are completely hypothetical and only meant to illustrate different cases as explained in the sections above. Example 27: Individual developer A has developed a FOSS. Developer A publishes that FOSS under its own name or trademark, but does not charge a price for its use. The software is openly shared and freely available for all to access, use, modify and redistribute. Developer A also includes a link to a platform to collect voluntary donations. Companies B, C and D integrate that FOSS into their own products with digital elements. To support ongoing maintenance, companies B, C and D make voluntary donations to developer A. These donations enable developer A to

keep the project actively maintained. That FOSS is not placed on the market within the meaning of the CRA. Developer A has no obligations under the CRA. Companies B, C, and D are to exercise due diligence in accordance with Article 13(5) when integrating that FOSS into their own products with digital elements. Example 28: Not-for-profit foundation F publishes a FOSS component for integration into other commercial products with digital elements. Foundation F commits to providing sustained support to that FOSS, to ensure its viability and uptake. Companies A, B and C integrate that FOSS into their own products with digital elements. Companies A and B voluntarily contribute some of their developers' time to development and maintenance of FOSS projects within foundation F, including for that FOSS. As foundation F is a not-for-profit entity set up in such a way that its earnings after costs are used to achieve not-for-profit objectives, the FOSS is not considered to be placed on the market within the meaning of the CRA. Foundation F is the FOSS steward and is subject to the corresponding obligations laid down in Article 24. Companies A, B and C are to exercise due diligence in accordance with Article 13(5) when integrating that FOSS into their own products with digital elements. Example 29: Company A has developed a FOSS component for integration into its own products with digital elements. It also publishes that FOSS separately under its own name or trademark and actively maintains it. However, it does not charge for its use or monetise in other ways. Companies B, C and D integrate that FOSS into their own products with digital elements, and voluntarily contribute some of their developers' time to its maintenance. That FOSS is not considered to be placed on the market within the meaning of the CRA. Company A is not its manufacturer, but is its steward. Companies B, C, and D are to exercise due diligence in accordance with Article 13(5) when integrating the FOSS into their own products with digital elements. Example 30: Company A publishes a FOSS under its own name or trademark and offers it as a paid version, which includes certain benefits such as technical assistance or performance optimisation. Developers from companies B, C and D contribute to the FOSS's maintenance, but it remains under the control of company A. Company A is considered a manufacturer to that FOSS15. Companies B, C and D are not subject to obligations under the CRA for that specific FOSS. If they integrate that FOSS into their own products with digital elements, they are required to exercise due diligence in accordance with Article 13(5). Example 31: Company A publishes a FOSS under its own name or trademark and provides ongoing maintenance to ensure its long-term viability, to enable that software to be integrated into other companies' products with digital elements. Company A does not charge for its use, process personal data it collects through the product with digital elements, or sell support services associated with publishing the FOSS. Company B contributes code and developers' time to the FOSS's maintenance, but does not distribute it commercially. Company B offers technical support services independently from the FOSS's distribution. Company A is deemed to be the steward for that FOSS, whereas company B has no obligations under the CRA for that FOSS. Example 32: A FOSS component is published by a not-for-profit entity set up in such a way that ensures that all earnings after costs are used to achieve not-for-profit objectives. The entity provides sustained support to ensure the project's long-term viability. Maintenance is financed through public funding, such as research grants. Additional developments, including new features, are funded through donations and specific projects, carried out in partnership with manufacturers that integrate that FOSS into their products with digital elements. Such features are incorporated into the FOSS's codebase. The not-for-profit entity that publishes the FOSS is deemed the steward for that FOSS component. A manufacturer that has contributed to the development of certain features does not become the manufacturer of that FOSS component. Where the manufacturer integrates that FOSS component into its own product with digital elements, it needs to exercise due diligence in accordance with Article 13(5). Example 33: A not-for-profit entity set up in such a way that ensures that all earnings after costs are used to achieve not-for-profit objectives publishes a FOSS software development kit (SDK) and ensures its ongoing maintenance. The SDK is openly shared and is freely available for all to access, use, modify and redistribute. Funding is provided through membership fees paid to the not-for-profit entity, and developers employed by member organisations contribute code and other resources to the SDK's development. Manufacturers use the SDK as a component to build other products with digital elements. The not-for-profit entity that publishes that SDK is the steward for it. The foundation's members are not responsible for the SDK's compliance with the CRA. Where manufacturers use the SDK to build their own product with digital elements, they need to exercise due diligence in accordance with Article 13(5).

> 下列示例完全是假设的，仅用于说明上文各节所解释的不同情形。示例27：个人开发者A开发了一款自由及开源软件。开发者A以自己的名称或商标发布该自由及开源软件，但不就其使用收取价款。该软件被公开分享，并免费提供给所有人获取、使用、修改和再分发。开发者A还纳入一个指向平台的链接，以收集自愿捐

赠。B、C和D公司将该自由及开源软件集成到自己的含数字元素产品中。为支持持续维护，B、C和D公司向开发者A作出自愿捐赠。这些捐赠使开发者A能够使项目保持积极维护。该自由及开源软件并未在CRA意义上被投放市场。开发者A在CRA项下没有义务。B、C和D公司在将该自由及开源软件集成到自己的含数字元素产品中时，应当根据第13条第5款开展尽职调查。示例28：非营利基金会F发布一个供集成到其他商业含数字元素产品中的自由及开源软件组件。基金会F承诺为该自由及开源软件提供持续支持，以确保其存续和采用。A、B和C公司将该自由及开源软件集成到自己的含数字元素产品中。A公司和B公司自愿贡献其部分开发者的时间，用于基金会F内自由及开源软件项目的开发和维护，包括该自由及开源软件。由于基金会F是以确保扣除成本后的收益用于实现非营利目的的方式设立的非营利实体，该自由及开源软件不视为在CRA意义上被投放市场。基金会F是该自由及开源软件的管理者，并受第24条所规定的相应义务的约束。A、B和C公司在将该自由及开源软件集成到自己的含数字元素产品中时，应当根据第13条第5款开展尽职调查。示例29：A公司开发了一个供集成到自己的含数字元素产品中的自由及开源软件组件。它还以自己的名称或商标单独发布该自由及开源软件并积极维护它。然而，它并不就其使用收费，也不以其他方式变现。B、C和D公司将该自由及开源软件集成到自己的含数字元素产品中，并自愿贡献其部分开发者的时间用于其维护。该自由及开源软件不视为在CRA意义上被投放市场。A公司不是其制造商，而是其管理者。B、C和D公司在将该自由及开源软件集成到自己的含数字元素产品中时，应当根据第13条第5款开展尽职调查。示例30：A公司以自己的名称或商标发布一款自由及开源软件，并将其作为付费版本提供，该版本包含技术协助或性能优化等某些利益。来自B、C和D公司的开发者对该自由及开源软件的维护作出贡献，但它仍处于A公司的控制之下。A公司被视为该自由及开源软件的制造商15。B、C和D公司就该特定自由及开源软件不受CRA项下义务的约束。如果它们将该自由及开源软件集成到自己的含数字元素产品中，则必须根据第13条第5款开展尽职调查。示例31：A公司以自己的名称或商标发布一款自由及开源软件，并提供持续维护以确保其长期存续，以便该软件能够被集成到其他公司的含数字元素产品中。A公司并不就其使用收费，不处理其通过该含数字元素产品收集的个人数据，也不销售与发布该自由及开源软件相关的支持服务。B公司向该自由及开源软件的维护贡献代码和开发者时间，但并不对其进行商业分发。B公司独立于该自由及开源软件的分发提供技术支持服务。A公司被视为该自由及开源软件的管理者，而B公司就该自由及开源软件在CRA项下没有义务。示例32：某一自由及开源软件组件由以确保扣除成本后的全部收益用于实现非营利目的的方式设立的非营利实体发布。该实体提供持续支持，以确保项目的长期存续。维护通过公共资金资助，例如研究赠款。额外的开发，包括新功能，通过捐赠和特定项目资助，这些项目与将该自由及开源软件集成到其含数字元素产品中的制造商合作开展。此类功能被纳入该自由及开源软件的代码库。发布该自由及开源软件的非营利实体被视为该自由及开源软件组件的管理者。对某些功能的开发作出贡献的制造商，并不成为该自由及开源软件组件的制造商。如果该制造商将该自由及开源软件组件集成到自己的含数字元素产品中，则需要根据第13条第5款开展尽职调查。示例33：以确保扣除成本后的全部收益用于实现非营利目的的方式设立的非营利实体发布一个自由及开源软件开发工具包（SDK），并确保其持续维护。该SDK被公开分享，并免费提供给所有人获取、使用、修改和再分发。资金通过向该非营利实体支付的成员费提供，成员组织所雇用的开发者向该SDK的开发贡献代码和其他资源。制造商将该SDK用作组件，以构建其他含数字元素产品。发布该SDK的非营利实体是其管理者。该基金会的成员不对SDK遵守CRA承担责任。如果制造商使用该SDK构建自己的含数字元素产品，则需要根据第13条第5款开展尽职调查。

15 Unless company A is a not-for-profit entity set up in such a way that ensures that all earnings after costs are used to achieve not-for-profit objectives, in which case it would be the steward to that FOSS.

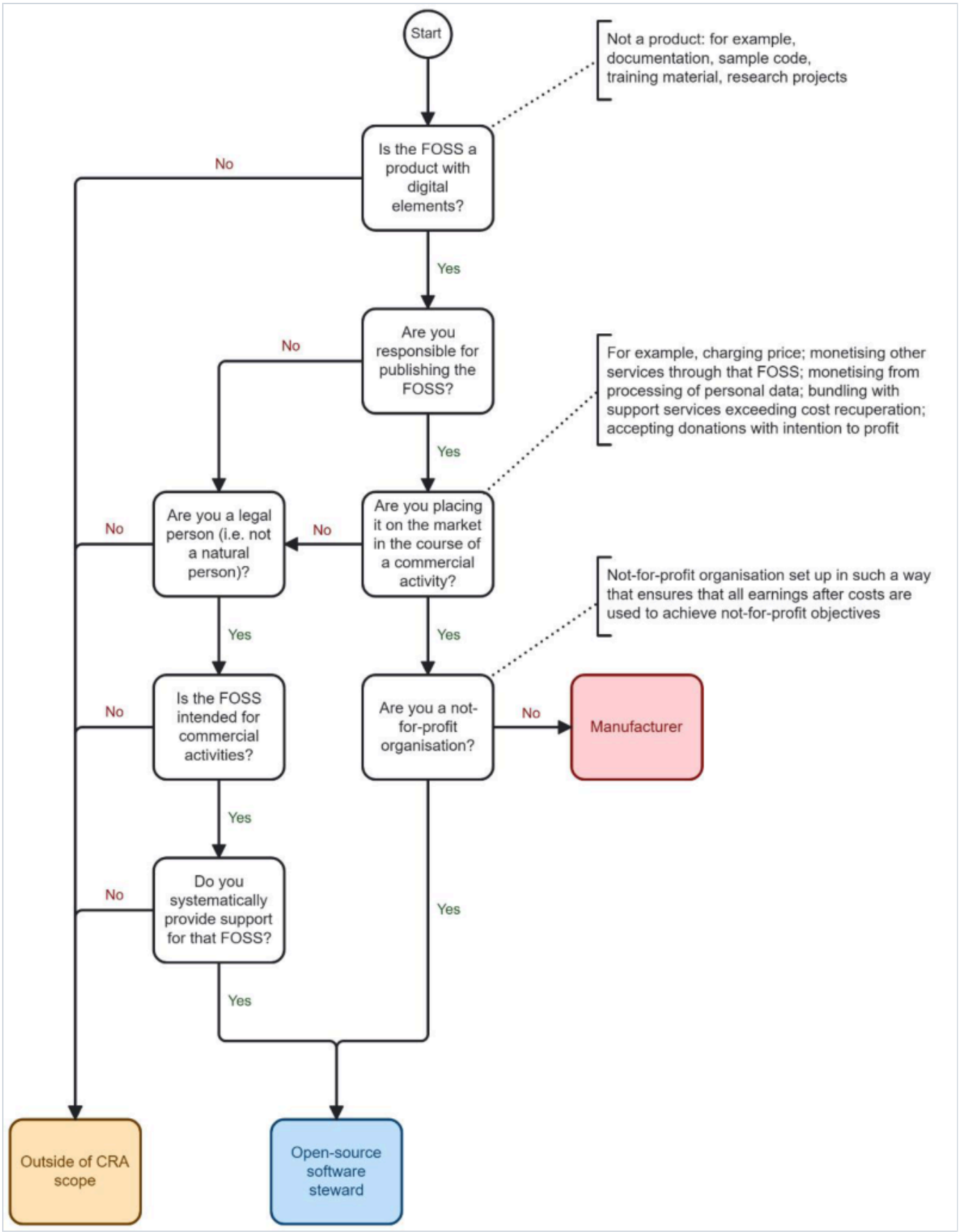
15 除非A公司是以确保扣除成本后的全部收益用于实现非营利目的的方式设立的非营利实体；在该情况下，它将是该自由及开源软件的管理者。

Example 34: An individual developer publishes a FOSS library on a public package repository for a given programming language and actively maintains it. In the package documentation, the developer adds a link to collect donations. A manufacturer downloads that library from the repository for free and integrates it into its own product with digital elements. The individual developer and the package repository do not have any obligations under the CRA. The manufacturer that integrates the library needs to exercise due diligence in accordance with Article 13(5).

> 示例34：一名个人开发者在某一编程语言的公共软件包存储库上发布一个自由及开源软件库并积极维护它。在软件包文档中，该开发者加入一个用于收集捐赠的链接。某制造商从该存储库免费下载该库，并将其集成到自己的含数字元素产品中。该个人开发者和该软件包存储库在CRA项下没有任何义务。集成该库的制造商需要根据第13条第5款开展尽职调查。

Figure 1: Stylised flowchart for CRA coverage of free and open-source software

> 图1：关于自由及开源软件是否属于CRA适用范围的示意流程图



图中文字对照（只译图内已有文字，不增补说明）

Start	开始
Is the FOSS a product with digital elements?	该自由及开源软件是否为含数字元素产品？

Are you responsible for publishing the FOSS?	你是否负责发布该自由及开源软件？
Are you placing it on the market in the course of a commercial activity?	你是否在商业活动过程中将其投放市场？
Are you a legal person (i.e. not a natural person)?	你是否为法人（即不是自然人）？
Is the FOSS intended for commercial activities?	该自由及开源软件是否旨在用于商业活动？
Do you systematically provide support for that FOSS?	你是否系统性地为该自由及开源软件提供支持？
Are you a not-for-profit organisation?	你是否为非营利组织？
Manufacturer	制造商
Outside of CRA scope	不属于CRA适用范围
Open-source software steward	开源软件管理者
Yes / No	是 / 否
Not a product: for example, documentation, sample code, training material, research projects	不属于产品：例如文件、示例代码、培训材料、研究项目
For example, charging price; monetising other services through that FOSS; monetising from processing of personal data; bundling with support services exceeding cost recuperation; accepting donations with intention to profit	例如：收取价款；通过该自由及开源软件变现其他服务；通过处理个人数据变现；与超出成本回收的支持服务捆绑；接受捐赠且具有营利意图
Not-for-profit organisation set up in such a way that ensures that all earnings after costs are used to achieve not-for-profit objectives	以确保扣除成本后的全部收益用于实现非营利目的的方式设立的非营利组织

4 Substantial modifications and spare parts
4 实质性修改与备件

90. Article 3(30) of the CRA defines a ‘substantial modification’ as a change to the product with digital elements following its placing on the market, which (i) affects the compliance of the product with digital elements with the essential requirements set out in Part I of Annex I; or (ii) results in a modification to the intended purpose for which the product with digital elements has been assessed.

> CRA第3条第30款将“实质性修改”定义为含数字元素产品在投放市场之后发生的变更，该变更(i) 影响含数字元素产品对附件I第一部分所载基本要求的符合；或(ii) 导致含数字元素产品已被评估的预期用途发生修改。

91. The notion of substantial modification is relevant for ascertaining CRA obligations in a number of cases, including the following: a. in accordance with Article 21, an importer or distributor that carries out a substantial modification of a product with digital elements already placed on the market is considered to be its manufacturer; b. in accordance with Article 22, any natural or legal person that carries out a substantial modification of a product with digital elements and makes it available on the market is considered to be its manufacturer; c. in accordance with Article 69(2), any natural or legal person that carries out a substantial modification after 11 December 2027 of a product with digital elements placed on the market before 11 December 2027 and places it on the market is considered to be its manufacturer; d. for manufacturers of products with digital elements placed on the market after 11 December 2027, in order to determine whether a product with digital elements is required to undergo a new conformity assessment procedure due to changes made after that date, particularly in light of the iterative nature of software development.

> 实质性修改这一概念，对于在若干情形中确定CRA义务具有相关性，包括以下情形：a. 根据第21条，对已经投放市场的含数字元素产品实施实质性修改的进口商或经销商，被视为其制造商；b. 根据第22条，对含数字元素产品实施实质性修改并在市场上提供它的任何自然人或法人，被视为其制造商；c. 根据第69条第2款，在2027年12月11日之后，对在2027年12月11日之前投放市场的含数字元素产品实施实质性修改并将其投放

> 市场的任何自然人或法人，被视为其制造商；d. 对于在2027年12月11日之后投放市场的含数字元素产品的制造商，用以确定含数字元素产品是否因在该日之后作出的变更而必须接受新的合格评定程序，尤其是鉴于软件开发的迭代性质。

92. Therefore, it is important to provide guidance to help economic operators understand when hardware or software modifications qualify as substantial modifications.

> 因此，有必要提供指导，以帮助经济经营者理解硬件或软件修改在何时构成实质性修改。

4.1 Physical repairs
4.1 物理修理

93. As stated in recital 42 of the CRA, ‘where a product with digital elements is subject to ‘refurbishment’, ‘maintenance’ and ‘repair’ as defined in Article 2, points (18), (19) and (20), of Regulation (EU) 2024/1781 of the European Parliament and of the Council, this does not necessarily lead to a substantial modification of the product, for instance if the intended purpose and functionalities are not changed and the level of risk remains unaffected. However, an upgrade of a product with digital elements by the manufacturer might lead to changes in the design and development of that product and might therefore affect its intended purpose and compliance with the requirements set out in this Regulation’. This is consistent with Section 2.1 of the Blue Guide, which recalls that ‘a product subject to important changes or overhaul after it has been put into service must be considered as a new product if: i) its original performance, purpose or type is modified, without this being foreseen in the initial risk assessment; ii) the nature of the hazard has changed or the level of risk has increased in relation to the relevant Union harmonisation legislation; and iii) the product is made available (or put into service if the applicable legislation also covers putting into service within its scope). This has to be assessed on a case-by-case basis and, in particular, in view of the objective of the legislation and the type of products covered by the legislation in question’.

> 正如CRA序言第42项所述，“如果含数字元素产品接受欧洲议会和理事会条例(EU) 2024/1781第2条第(18)、(19)和(20)点所定义的‘翻新’、‘维护’和‘修理’，这并不必然导致该产品的实质性修改，例如在预期用途和功能未改变且风险水平未受影响的情况下。然而，制造商对含数字元素产品的升级可能导致该产品的设计和开发发生变化，因此可能影响其预期用途以及对本条例所规定要求的符合”。这与《蓝皮书》第2.1节相一致，该节回顾：“在投入使用之后接受重大变更或大修的产品，在下列情况下必须被视为新产品：i) 其原有性能、用途或型式被修改，而初始风险评估并未预见这一点；ii) 就相关联盟协调立法而言，危害的性质已经改变或风险水平已经提高；以及iii) 该产品被在市场上提供（或者，如果适用的立法也将投入使用纳入其适用范围，则被投入使用）。这必须逐案评估，尤其要考虑该立法的目标以及有关立法所涵盖的产品类型”。

94. Operations of refurbishment, maintenance or repair which result in physical modifications of products with digital elements already placed on the market do not necessarily amount to substantial modifications. A case-by-case assessment should therefore be performed, to ascertain whether such physical modification affects the compliance of the product with digital elements with the essential requirements of Part I of Annex I, or results in a change to the product’s intended purpose covered by the cybersecurity risk assessment.

> 导致已经投放市场的含数字元素产品发生物理修改的翻新、维护或修理操作，并不必然构成实质性修改。因此应当进行逐案评估，以确定此类物理修改是否影响含数字元素产品对附件I第一部分基本要求的符合，或者是否导致网络安全风险评估所涵盖的产品预期用途发生变更。

95. Replacing defective parts or worn items by parts that perform better (e.g. because of technical progress or because the old part is no longer produced) does not in itself trigger a substantial modification of the repaired product with digital elements. It only does so if the performance change or the way the repaired product with digital elements operates (i) affects its compliance with the essential requirements or (ii) results in a change to the intended purpose that was not covered by the risk assessment. Example 35: The manufacturer of a computer server performs a repair operation,

switching out a defective RAM with a new, better performing one. The server's compliance with the essential requirements is not affected. The server performs better, but its new performance remains within the server's intended use as considered in the cybersecurity risk assessment. The computer server is not considered to be substantially modified.

> 用性能更好的部件替换有缺陷的部件或磨损件（例如由于技术进步，或由于旧部件不再生产），其本身并不引发被修理的含数字元素产品的实质性修改。仅当性能变化或被修理的含数字元素产品的运行方式(i) 影响其对基本要求的符合，或(ii) 导致风险评估未涵盖的预期用途发生变更时，才构成实质性修改。示例35：某计算机服务器的制造商实施修理操作，用性能更好的新内存替换有缺陷的内存（RAM）。该服务器对基本要求的符合未受影响。服务器性能更好，但其新性能仍处于网络安全风险评估所考虑的该服务器预期使用范围之内。该计算机服务器不视为被实质性修改。

4.2 Spare parts
4.2 备件

96. Article 2(6) of the CRA establishes that spare parts intended to replace identical components and manufactured according to the same specifications as those components are not subject to the CRA. Recital 29 further states that the exemption covers both spare parts for products with digital elements made available before the CRA entered into application, and spare parts that have already undergone a conformity assessment procedure as laid down in the Regulation.

> CRA第2条第6款规定，旨在替换相同组件并按照与这些组件相同的规格制造的备件，不受CRA约束。序言第29项进一步规定，该豁免既涵盖在CRA开始适用之前已在市场上提供的含数字元素产品的备件，也涵盖已经按照本条例所规定的合格评定程序完成评定的备件。

97. The exemption in Article 2(6) of the CRA should be understood as applying only where the spare part is specifically supplied to repair or extend the durability of a product with digital elements already placed on the market (before or after 11 December 2027). Where a product with digital elements is supplied as a standalone product, without any connection to the maintenance or repair of a pre-existing product with digital elements, it is placed on the market within the meaning of the CRA and should not be considered a spare part falling within the scope of Article 2(6). The maintenance or repair purpose should be apparent from the context of the supply, for example through identification of the product with digital elements or product family in the order or commercial offer, or through supply via after-sales or service channels. Supporting evidence to that effect should also be kept available to market surveillance authorities. The fact that a product with digital elements could technically be used to replace a component is not, in itself, sufficient to bring it within the scope of the exemption in the absence of such elements.

> CRA第2条第6款中的豁免，应理解为仅在备件被专门供应以修理或延长已经投放市场（无论在2027年12月11日之前还是之后）的含数字元素产品的耐用性时适用。如果含数字元素产品作为独立产品被供应，而与既有含数字元素产品的维护或修理没有任何联系，则它是在CRA意义上被投放市场，不应被视为属于第2条第6款范围的备件。维护或修理目的应当从供应的背景中显现出来，例如通过在订单或商业要约中标明含数字元素产品或产品族，或者通过售后或服务渠道供应。证明该事实的支持性证据也应当可供市场监督机构查阅。含数字元素产品在技术上可以被用来替换某一组件这一事实，在缺乏此类要素的情况下，其本身并不足以使其落入该豁免的范围。

98. Accordingly, where a spare part is identical to a component already included in a product with digital elements either placed on the market before the CRA's date of application or that has been placed on the market in compliance with the CRA, that spare part is not itself subject to the CRA.

> 因此，如果备件与已经包含在含数字元素产品中的组件相同，而该含数字元素产品或者在CRA开始适用之日前已投放市场，或者已在遵守CRA的情况下投放市场，则该备件本身不受CRA约束。

99. The assessment of whether a spare part should be considered identical to a component should focus on its functional role in the product with digital elements and the characteristics that may be relevant to cybersecurity. While a case-by-case assessment is always needed, differences that do not affect the security characteristics or the cybersecurity risk profile of the component do not, in themselves, prevent that spare part from falling within the scope of Article 2(6) of the CRA.

> 关于备件是否应被视为与某一组件相同的评估，应当侧重于其在含数字元素产品中的功能作用以及可能与网络安全相关的特性。尽管始终需要进行逐案评估，但不影响该组件的安全特性或网络安全风险状况的差异，其本身并不妨碍该备件落入CRA第2条第6款的范围。

100. By contrast, differences in characteristics relevant to the cybersecurity of the component, such as algorithms, protocols, cryptographic mechanisms, access control features or other security-relevant characteristics, may mean that the new part cannot be considered identical to the component it is intended to replace.

> 相反，与组件网络安全相关的特性差异，例如算法、协议、密码机制、访问控制功能或其他与安全相关的特性，可能意味着新部件不能被视为与其拟替换的组件相同。

101. Where a spare part is not identical to the original component, that spare part constitutes a product with digital elements in its own right and is therefore subject to the CRA. In such cases, compliance with the essential requirements must be assessed in light of the replacement component’s intended purpose. Of particular relevance is the replacement component’s function of ensuring compatibility or interoperability with an existing product with digital elements, including where that product is a product with digital elements placed on the market before the CRA entered into application. Where certain essential requirements cannot reasonably be met due to that intended purpose or technical constraints, the manufacturer must reflect this in the cybersecurity risk assessment and implement appropriate alternative or compensatory risk-mitigation measures, in order not to undermine the security of the product with digital elements. As also discussed in Section 2.6 Complex systems, both the technical documentation and the information and instructions to the user play a key role in transparently describing the identified constraints, the associated cybersecurity risks and the risk-mitigation measures implemented. As explained in Section 4.1 Physical repairs, replacing defective parts or worn items by parts that perform better does not in itself trigger a substantial modification of the repaired product with digital elements. Example 36: A manufacturer has placed connected controllers on the EU market. In one case, the controller was placed on the market in 2026, before the date of application of the CRA. In another case, the controller was placed on the market in 2028, in compliance with the CRA. In 2028, a digital communication module in both types of controllers fails. The manufacturer supplies as a spare part a replacement module that is identical and manufactured according to the same specifications as the original. In both cases, the replacement module falls within the scope of the exemption in Article 2(6). The spare part is not itself subject to the CRA, even though it is a product with digital elements, because it replaces an identical component in a product with digital elements. The repair does not constitute a substantial modification of the product with digital elements. Example 37: A manufacturer placed a connected industrial controller on the EU market in 2026, before the date of application of the CRA. In 2028, a communication chip in that controller fails. As the manufacturer no longer manufactures that chip, it supplies as a spare part a newer chip with equivalent functionality, but with a different cryptographic implementation and updated secure boot mechanism, in order to maintain compatibility and continued operation. In this case, the replacement chip cannot be considered identical, as the differences in the cryptographic implementation and secure boot mechanism affect the chip’s cybersecurity properties. It therefore does not benefit from the exemption in Article 2(6) and constitutes a product with digital elements subject to the CRA. Compliance of the replacement part must be assessed in light of its intended purpose, including its role in ensuring interoperability with the product with digital elements placed on the market before the CRA entered into application. Example 38: A manufacturer places on the market a smart building controller in 2028 in compliance with the CRA. In 2029, the wireless module in that controller fails. As the manufacturer no longer manufactures that module, it supplies as a spare part a new module that performs the same function using the same communication protocols and security mechanisms, but is based on a different chipset and has updated firmware that does not alter characteristics that may be relevant to cybersecurity. In this case, the replacement module can be considered identical. The module therefore benefits from the exemption in Article 2(6) and is not subject to the CRA.

如果备件与原组件不相同，则该备件本身构成含数字元素产品，因此受CRA约束。在此类情况下，对基本要求的符合必须结合替换组件的预期用途来评估。尤为相关的是替换组件确保与既有含数字元素产品的兼容性或互操作性的功能，包括该产品是在CRA开始适用之前投放市场的含数字元素产品的情形。如果由于该预期用途或技术制约，某些基本要求无法合理地得到满足，制造商必须在网络安全风险评估中反映这一点，并实施适当的替代性或补偿性风险缓解措施，以免减损含数字元素产品的安全性。正如第2.6节“复杂系统”亦所讨论的，技术文件以及向用户提供的信息和说明，在透明说明已识别的制约、相关网络安全风险以及已实施的风险缓解措施方面发挥关键作用。正如第4.1节“物理修理”所说明的，用性能更好的部件替换有缺陷的部件或磨损件，其本身并不引发被修理的含数字元素产品的实质性修改。示例36：某制造商已在欧盟市场上投放联网控制器。在一种情形中，该控制器于2026年、即CRA开始适用之日前被投放市场。在另一种情形中，该控制器于2028年在遵守CRA的情况下被投放市场。2028年，两类控制器中的数字通信模块均发生故障。制造商供应一个替换模块作为备件，该模块与原件相同，并按照与原件相同的规格制造。在两种情形中，该替换模块都属于第2条第6款豁免的范围。该备件本身不受CRA约束，尽管它是含数字元素产品，因为它替换的是含数字元素产品中的相同组件。该修理不构成含数字元素产品的实质性修改。示例37：某制造商于2026年、即CRA开始适用之日前，在欧盟市场上投放一款联网工业控制器。2028年，该控制器中的通信芯片发生故障。由于制造商不再制造该芯片，它供应一款功能等同但密码实现不同、并更新了安全启动机制的较新芯片作为备件，以维持兼容性和持续运行。在此情况下，该替换芯片不能被视为相同，因为密码实现和安全启动机制的差异影响该芯片的网络安全属性。因此，它不享受第2条第6款的豁免，并构成受CRA约束的含数字元素产品。替换部件的符合必须结合其预期用途来评估，包括其在确保与CRA开始适用之前投放市场的含数字元素产品实现互操作方面的作用。示例38：某制造商于2028年在遵守CRA的情况下投放一款智能楼宇控制器。2029年，该控制器中的无线模块发生故障。由于制造商不再制造该模块，它供应一个新模块作为备件，该模块使用相同的通信协议和安全机制履行相同功能，但基于不同的芯片组，并具有不改变可能与网络安全相关的特性的更新固件。在此情况下，该替换模块可以被视为相同。因此，该模块享受第2条第6款的豁免，不受CRA约束。

102. The exemption for spare parts applies regardless of whether the spare part replaces a component within a product with digital elements or whether it replaces a complete product with digital elements that itself forms part of a larger product, including where that larger product with digital elements is composed of several integrated components, provided that the replacement part is specifically supplied as a spare part, as explained in the preceding paragraphs. Example 39: In 2027, a manufacturer places on the market an industrial automation system that incorporates a programmable logic controller (PLC) as one of its components. In 2031, the PLC’s central processing unit (CPU) fails. The manufacturer offers two repair options: (i) the supply of a replacement CPU unit, which can be considered identical to the CPU originally installed; or (ii) the supply of a complete replacement PLC, which can be considered identical to the PLC originally installed. In each case, the replacement is supplied through the manufacturer’s after-sales service channel as a spare part, and the industrial automation system for which the replacement is intended is clearly identified. In both cases, the replacement falls within the scope of the exemption in Article 2(6), whether the replacement concerns a component within the PLC, or the PLC as a whole.

备件豁免的适用，不论该备件替换的是含数字元素产品内的某一组件，还是替换本身构成更大产品一部分的完整含数字元素产品，包括该更大的含数字元素产品由若干集成组件组成的情形，但前提是替换部件如前面各段所说明的那样被专门作为备件供应。示例39：2027年，某制造商投放一款工业自动化系统，其中纳入可编程逻辑控制器（PLC）作为其组件之一。2031年，该PLC的中央处理器（CPU）发生故障。制造商提供两种修理选项：(i) 供应一个替换CPU单元，该单元可以视为与原先安装的CPU相同；或(ii) 供应一个完整的替换PLC，该PLC可以视为与原先安装的PLC相同。在每一种情形中，替换件都通过制造商的售后服务渠道作为备件供应，并且拟使用该替换件的工业自动化系统被明确标明。在两种情形中，该替换都属于第2条第6款豁免的范围，不论替换涉及的是PLC内的组件，还是作为整体的PLC。

4.3 Software updates as substantial modifications

4.3 作为实质性修改的软件更新

103. Software development is iterative in nature, with software products with digital elements already placed on the market being frequently and continuously updated. In this context, it is useful to provide more guidance to ascertain when software is to be considered substantially modified. Such guidance is intended in particular to help manufacturers of software products with digital elements who make changes to their own products determine whether those changes amount to a substantial modification.

> 软件开发在性质上是迭代的，已经投放市场的含数字元素软件产品会被频繁且持续地更新。在此背景下，宜提供更多指导，以确定软件在何时应被视为被实质性修改。此类指导尤其旨在帮助对其自己的产品作出变更的含数字元素软件产品制造商，确定这些变更是否构成实质性修改。

104. Recital 39 indicates that a product with digital elements is substantially modified where a change alters the level of cybersecurity risk, and where such altered or additional risk has not been considered by the manufacturer in its risk assessment and, consequently, in its implementation of the essential requirements. A manufacturer should therefore assess, on a case-by-case basis, whether a software update introduces new or increased cybersecurity risks, and whether such risks were already addressed in its risk assessment.

> 序言第39项指出，如果某一变更改变了网络安全风险水平，并且该改变后的或额外的风险未被制造商在其风险评估中考虑，因而也未在其对基本要求的实施中考虑，则含数字元素产品被实质性修改。因此，制造商应当逐案评估软件更新是否引入新的或提高的网络安全风险，以及此类风险是否已在其风险评估中得到处理。

105. Where a manufacturer introduces new functionalities in a product with digital elements that result in a change to the product’s intended purpose as a whole, it is likely that the manufacturer did not consider such changes in its risk assessment. In such circumstances, the change would generally qualify as a substantial modification. Example 40: A manufacturer places on the market a dashboard that collects data from machines and displays trends and alerts, without having the ability to control such machines. The manufacturer subsequently develops a new version of that dashboard, introducing functionalities that enable it to control the machines, including by adjusting operating parameters and restarting machines following fault conditions. As a result of these changes, the dashboard’s intended purpose has evolved beyond what was envisaged in the risk assessment, shifting from a situational awareness tool to a product with digital elements intended to exercise operational control over other devices. The dashboard has therefore been substantially modified. Example 41: A manufacturer places on the market a consumer software application intended to organise and display personal data, such as emails, messages, or documents, and to support basic search and filtering functions. The manufacturer subsequently introduces an update that enables the application to automatically analyse user content in order to generate behavioural profiles and make automated decisions affecting the prioritisation, suppression, or recommendation of content without user intervention. As a result of this change, the software’s intended purpose shifts from a user-controlled information management tool to an automated decision-making system, which was not envisaged in the risk assessment. The application has therefore been substantially modified.

> 如果制造商在含数字元素产品中引入新功能，导致产品整体的预期用途发生变更，则制造商很可能未在其风险评估中考虑此类变更。在此类情形下，该变更一般构成实质性修改。示例40：某制造商投放一款仪表板，该仪表板从机器收集数据并显示趋势和警报，但不具有控制这些机器的能力。制造商随后开发该仪表板的新版本，引入使其能够控制机器的功能，包括调整运行参数以及在故障状况之后重新启动机器。由于这些变更，该仪表板的预期用途已经超出风险评估所设想的范围，从态势感知工具转变为旨在对其他设备行使运行控制的含数字元素产品。因此，该仪表板已被实质性修改。示例41：某制造商投放一款消费软件应用程序，旨在整理和显示个人数据，例如电子邮件、消息或文档，并支持基本的搜索和筛选功能。制造商随后引入一项更新，使该应用程序能够自动分析用户内容，以生成行为画像，并在没有用户干预的情况下作出影响内容优先级、抑制或推荐的自动决策。由于这一变更，该软件的预期用途从用户控制的信息管理工具转变为自动决策系统，而这并未在风险评估中被设想。因此，该应用程序已被实质性修改。

106. At the same time, however, it is possible that a manufacturer progressively introduces new functionalities already included in its risk assessment or that do not, in themselves, alter the cybersecurity risk profile of the product with digital elements. This may be the case, for example, where the manufacturer has anticipated the development of those functionalities, has already described and assessed the associated risks, and has implemented appropriate mitigation measures to ensure continued compliance with the essential requirements. This may also be the case where the new functionalities do not implement changes that introduce new or increased risks. Updates of this nature should therefore not be regarded as substantial modifications, as they do not increase the cybersecurity risk and consequently do not change the implementation of the essential requirements. Example 42: A messaging application is initially released with functionality limited to one-to-one messaging. The manufacturer's risk assessment covers the later introduction of group messaging, including for example the increased complexity of message routing. In a subsequent update, the manufacturer adds a group chat functionality together with administrator controls and moderation tools that were already foreseen and assessed in the original design. The update implements functionalities that fall within the scope of the original intended purpose and risk assessment. The messaging application has therefore not been substantially modified. Example 43: A production monitoring system is placed on the market with read-only dashboards enabled, while automated control features are present in the system architecture but remain disabled. The manufacturer's risk assessment explicitly covers the future activation of automated control loops, including the cybersecurity risks associated with closed-loop control, as well as safeguards such as operator override mechanisms and fail-safe states. In a later update, the manufacturer enables the automated control features and activates the safeguards as originally assessed. The production monitoring system has therefore not been substantially modified.

> 与此同时，制造商也可能逐步引入已经包含在其风险评估中的新功能，或者这些新功能本身并不改变含数字元素产品的网络安全风险状况。例如，制造商已经预见到这些功能的开发，已经描述并评估了相关风险，并且已经实施适当的缓解措施以确保持续符合基本要求，即可能如此。新功能并未实施会引入新的或提高的风险的变更，亦可能如此。因此，这种性质的更新不应被视为实质性修改，因为它们并不提高网络安全风险，因而也不改变对基本要求的实施。示例42：一款消息应用程序最初发布时，功能限于一对一消息。制造商的风险评估涵盖此后引入群组消息，例如包括消息路由复杂性的增加。在随后的更新中，制造商增加群组聊天功能，以及在原设计中已经预见并评估的管理员控制和内容管理工具。该更新实施的功能处于原预期用途和风险评估的范围之内。因此，该消息应用程序并未被实质性修改。示例43：一款生产监控系统在投放市场时启用了只读仪表板，而自动控制功能存在于系统架构中但保持禁用。制造商的风险评估明确涵盖未来启用自动控制回路，包括与闭环控制相关的网络安全风险，以及操作员超控机制和故障安全状态等保障措施。在后来的更新中，制造商启用自动控制功能，并按照原先评估的那样激活保障措施。因此，该生产监控系统并未被实质性修改。

107. Conversely, even limited or seemingly minor new functionalities may introduce significant cybersecurity risks that impact compliance with the essential requirements. The assessment of substantial modification should therefore not be based on the scale or complexity of the change, but on its potential adverse impact on the cybersecurity risk profile of the product with digital elements and consequently the implementation of the essential requirements. Example 44: A manufacturer introduces an update to a software application adding a 'remember me' or persistent login feature that stores authentication tokens locally to improve user convenience. Although the functionality is limited in scope, it introduces new risks related to token theft, unauthorised access, and session hijacking that were not considered in the risk assessment. The update therefore affects compliance with the essential requirements. The software application has been substantially modified. Example 45: A manufacturer adds a new logging and diagnostics feature to an existing software product with digital elements, enabling detailed system logs to be exported for troubleshooting purposes. While the functionality appears minor, it results in the collection and storage of sensitive operational data in an unencrypted format, introducing risks of data exposure that were not previously assessed or mitigated. The change may therefore have a significant impact on the cybersecurity risk profile of the product with digital elements. The software product with digital elements has been substantially modified.

> 相反，即使是有限的或表面上微小的新功能，也可能引入影响对基本要求之符合的重大网络安全风险。因此，对实质性修改的评估不应当基于变更的规模或复杂程度，而应当基于其对含数字元素产品网络安全风险

状况的潜在不利影响，以及因而对基本要求之实施的影响。示例44：某制造商对一款软件应用程序引入更新，增加“记住我”或持久登录功能，该功能在本地存储认证令牌以提高用户便利。尽管该功能范围有限，但它引入了与令牌窃取、未经授权的访问和会话劫持有关的、风险评估中未考虑的新风险。因此，该更新影响对基本要求的符合。该软件应用程序已被实质性修改。示例45：某制造商向既有含数字元素软件产品增加新的日志记录和诊断功能，使详细的系统日志能够被导出以用于故障排查。尽管该功能显得微小，但它导致以未加密格式收集和存储敏感运行数据，引入先前未被评估或缓解的数据暴露风险。因此，该变更可能对含数字元素产品的网络安全风险状况产生重大影响。该含数字元素软件产品已被实质性修改。

108. In line with recital 39 of the CRA, security updates are generally not to be regarded as substantial modifications, as their primary purpose is to reduce the level of cybersecurity risk associated with the product with digital elements. A security update that does not modify that product’s intended purpose and does not introduce new cybersecurity risks should therefore not be considered a substantial modification, even where that update may introduce significant technical changes. This includes where certain functionalities are modified or constrained solely for the purpose of mitigating identified vulnerabilities and ensuring continued compliance with the essential requirements. Example 46: A manufacturer deploys a security update to address a vulnerability in the codebase of a product with digital elements by correcting an input validation error that could lead to a buffer overflow, or by fixing a logic flaw allowing authentication bypass through improper session token validation. The update modifies the internal implementation of the software without affecting that product’s intended purpose or introducing new exposure. Such an update is intended exclusively to reduce the cybersecurity risk. The security update should not be considered a substantial modification. Example 47: A manufacturer introduces a security update that strengthens existing security configurations, such as tightening firewall rules, disabling unused network ports, changing default administrator password policies, or making multi-factor authentication mandatory where such functionality was already available or foreseen. Although the update may affect how users configure or access the product with digital elements, it does not alter its intended purpose and serves solely to enhance its security posture. The security update should not be considered a substantial modification. Example 48: A manufacturer places on the market a software product with digital elements that secures communications using a configurable encryption framework supporting multiple cryptographic algorithms and key sizes, as described in the product’s technical documentation and risk assessment. The risk assessment covers all the cryptographic options provided in the product with digital elements and anticipates the future deprecation of certain algorithms. The risk assessment also includes mitigation measures, such as cryptographic agility, internal key management, and compatibility testing. In response to emerging cryptographic guidance, the manufacturer deploys a security update that disables a deprecated algorithm and activates a stronger, already supported alternative, without introducing new external dependencies or altering data flows. As the update implements a security measure that was foreseen and assessed as part of the original design, and it does not introduce new cybersecurity risks, the security update should not be considered a substantial modification.

根据CRA序言第39项，安全更新一般不应被视为实质性修改，因为其主要目的是降低与含数字元素产品相关的网络安全风险水平。因此，不修改该产品预期用途且不引入新网络安全风险的安全更新，不应被视为实质性修改，即使该更新可能引入重大技术变更。这包括某些功能被修改或限制，其唯一目的是缓解已识别的漏洞并确保持续符合基本要求的情形。示例46：某制造商部署安全更新，以处理含数字元素产品代码库中的漏洞，方法是纠正可能导致缓冲区溢出的输入验证错误，或修复允许通过不当的会话令牌验证绕过认证的逻辑缺陷。该更新修改软件的内部实现，而不影响该产品的预期用途或引入新的暴露。此类更新专为降低网络安全风险。该安全更新不应被视为实质性修改。示例47：某制造商引入安全更新，以加强既有安全配置，例如收紧防火墙规则、禁用未使用的网络端口、改变默认管理员密码策略，或在该功能已经可用或已被预见的情况下将多因素认证设为强制。尽管该更新可能影响用户如何配置或访问含数字元素产品，但它并不改变其预期用途，并且仅用于增强其安全态势。该安全更新不应被视为实质性修改。示例48：某制造商投放一款含数字元素软件产品，该产品使用可配置的加密框架保护通信，该框架支持多种密码算法和密钥长度，正如产品技术文件和风险评估所述。风险评估涵盖该含数字元素产品中提供的所有密码选项，并预见到某些算法未来被弃用。风险评估还包括缓解措施，例如密码敏捷性、内部密钥管理和兼容性测试。为回应新出现的密码指导，制造商部署安全更新，禁用已弃用的算法并启用已经支持的更强替代算法，而不引入新的外部依赖项或

> 改变数据流。由于该更新实施的是原设计中已经预见并评估的安全措施，并且不引入新的网络安全风险，该安全更新不应被视为实质性修改。

109. By contrast, a security update may qualify as a substantial modification where, notwithstanding its security objective, the update results in the intended purpose of the product with digital elements being modified beyond what was originally foreseen or introduces new or increased cybersecurity risks. This may be the case, for example, where an update materially changes that product's boundaries or dependency structure in a way not foreseen in the risk assessment, e.g. by materially altering data flows, or adding new externally reachable interfaces. Example 49: A manufacturer places on the market a software product with digital elements intended to provide local file encryption for data stored on a user's device, enabling users to encrypt and decrypt files on demand. Following the discovery of a vulnerability in the encryption workflow, the manufacturer deploys a security update that removes local encryption functionality and instead requires all files to be uploaded to, stored in, and processed by a remote encryption service operated by the manufacturer. As a result of this change, the product with digital elements no longer performs local encryption as originally intended, instead functioning as a remote encryption and data processing service. Although the update is introduced for security reasons, it fundamentally alters that product's intended purpose in a manner not foreseen in the risk assessment and therefore qualifies as a substantial modification. Example 50: A manufacturer places on the market a software product with digital elements that relies on an established encryption protocol and an internally managed key lifecycle to secure communications between components of the product with digital elements. In response to newly identified cryptographic weaknesses, the manufacturer introduces a security update that replaces the existing encryption mechanism with a different protocol requiring the use of an external key management service operated by a third party. As a result of this change, the dependencies and data flows of the product with digital elements are materially altered, introducing new external interfaces and reliance on third-party services not considered in the risk assessment. Although the update is security-driven, it introduces new cybersecurity risks, and therefore qualifies as a substantial modification.

> 相反，尽管安全更新具有安全目的，如果该更新导致含数字元素产品的预期用途被修改到超出原先预见的程度，或引入新的或提高的网络安全风险，则该安全更新可能构成实质性修改。例如，更新以风险评估中未预见的方式实质改变该产品的边界或依赖结构，例如实质改变数据流，或增加新的可从外部到达的接口，即可能如此。示例49：某制造商投放一款含数字元素软件产品，旨在为存储在用户设备上的数据提供本地文件加密，使用户能够按需加密和解密文件。在发现加密工作流中的漏洞之后，制造商部署安全更新，移除本地加密功能，转而要求所有文件被上传到、存储于并由制造商运营的远程加密服务处理。由于这一变更，该含数字元素产品不再按原先意图实施本地加密，而是作为远程加密和数据处理服务运行。尽管该更新是出于安全原因引入的，但它以风险评估中未预见的方式根本改变了该产品的预期用途，因此构成实质性修改。示例50：某制造商投放一款含数字元素软件产品，该产品依赖既定的加密协议和内部管理的密钥生命周期，以保护含数字元素产品各组件之间的通信。为回应新识别的密码弱点，制造商引入安全更新，用一种不同的协议替换既有加密机制，该协议要求使用由第三方运营的外部密钥管理服务。由于这一变更，含数字元素产品的依赖项和数据流被实质改变，引入风险评估中未考虑的新外部接口和对第三方服务的依赖。尽管该更新是出于安全驱动的，但它引入了新的网络安全风险，因此构成实质性修改。

110. As stated in point 104 above, whether a software update constitutes a substantial modification should be assessed on a case-by-case basis. When performing this assessment, manufacturers may consider, in a non-exhaustive manner, whether the software update: a. introduces new threat vectors, such as additional interfaces, communication channels, execution environments, or external dependencies through which threats could materialise; b. enables new attack scenarios, including for example new ways in which unauthorised access, manipulation, interference or misuse of the product with digital elements, or of data processed by it, could plausibly occur; c. changes the likelihood of previously identified attack scenarios, for example by lowering the effort or expertise required to exploit them, increasing exposure to untrusted actors, or weakening existing safeguards; d. changes the potential impact of previously identified attack scenarios, including for example the scope of affected data or functions, the severity of operational, safety or economic consequences, or the ability to detect, contain or recover from an incident.

> 如上文第104点所述，软件更新是否构成实质性修改应当逐案评估。在进行这一评估时，制造商可以非穷尽地考虑该软件更新是否：a. 引入新的威胁途径，例如额外的接口、通信信道、执行环境，或威胁可能藉以成为现实的外部依赖项；b. 使新的攻击情景成为可能，例如未经授权的访问、篡改、干扰或滥用含数字元素产品或其所处理的数据，可能以新的方式合理地发生；c. 改变先前已识别攻击情景的可能性，例如通过降低利用它们所需的努力或专业知识、增加对不受信任行为者的暴露，或削弱既有保障措施；d. 改变先前已识别攻击情景的潜在影响，例如受影响数据或功能的范围、运行、安全或经济后果的严重程度，或发现、遏制事件或从事件中恢复的能力。

111. In some cases, a software update does not introduce new threat vectors, does not enable new attack scenarios, and does not materially alter the likelihood or impact of previously identified attack scenarios. This may indicate that the update does not introduce new or increased cybersecurity risks, provided that the assumptions and mitigation measures relied upon in the risk assessment remain valid and effective. It is therefore likely that the update does not qualify as a substantial modification.

> 在某些情况下，软件更新不引入新的威胁途径，不使新的攻击情景成为可能，也不实质改变先前已识别攻击情景的可能性或影响。这可以表明该更新不引入新的或提高的网络安全风险，但前提是风险评估所依赖的假设和缓解措施仍然有效。因此，该更新很可能不构成实质性修改。

112. Conversely, a software update may introduce new threat vectors, enable new attack scenarios, or materially alter the likelihood or impact of existing attack scenarios. In such cases, the manufacturer should reassess the cybersecurity risks of the product with digital elements and determine whether the essential requirements continue to be met, including whether the update introduces new or increased risks not foreseen in the risk assessment.

> 相反，软件更新可能引入新的威胁途径，使新的攻击情景成为可能，或实质改变既有攻击情景的可能性或影响。在此类情况下，制造商应当重新评估含数字元素产品的网络安全风险，并确定基本要求是否继续得到满足，包括该更新是否引入风险评估中未预见的新的或提高的风险。

113. Whether a software update qualifies as a substantial modification is relevant when determining whether certain obligations under the CRA apply, as set out in point 91. However, irrespective of that qualification, manufacturers remain responsible for ensuring the security of software updates and of their product with digital elements during its support period, in accordance with the vulnerability handling requirements set out in Part II of Annex I to the CRA. Furthermore, regardless of whether software updates qualify as substantial modifications or not, manufacturers are required to keep the risk assessment and the technical documentation accurate, complete and continuously up to date, in accordance with Articles 13(7) and 31(2).

> 软件更新是否构成实质性修改，在确定CRA项下某些义务是否适用时具有相关性，如第91点所述。然而，不论该定性如何，制造商在支持期内仍然负责确保软件更新及其含数字元素产品的安全，这符合CRA附件I第二部分所规定的漏洞处理要求。此外，不论软件更新是否构成实质性修改，制造商都必须根据第13条第7款和第31条第2款，保持风险评估和技术文件准确、完整并持续更新。

4.4 Consequences of a substantial modification
4.4 实质性修改的后果

114. The consequences of a substantial modification carried out by an actor other than the original manufacturer of a product with digital elements already placed on the market are addressed in Articles 21 and 22 of the CRA. Article 21 concerns importers and distributors, while Article 22 concerns any natural or legal person other than the manufacturer, importer or distributor.

> 由已经投放市场的含数字元素产品的原始制造商以外的行为人实施的实质性修改的后果，规定于CRA第21条和第22条。第21条涉及进口商和经销商，第22条涉及制造商、进口商或经销商以外的任何自然人或法人。

115. Where the substantial modification is carried out by the original manufacturer of the product with digital elements, the consequences derive from the generally established concept of substantial modification referred to in recital 41 of the CRA and are further elaborated in Section 2.1 of the Blue Guide. That section states that a product that has been subject to significant changes or an overhaul after being placed on the market is to be considered a new product where its original performance, purpose or type has been modified, the nature of the hazard has changed or the level of risk has increased, and the product with digital elements is made available on the market.

> 如果实质性修改由含数字元素产品的原始制造商实施，则其后果源于CRA序言第41项所指的、已经一般确立的实质性修改概念，并在《蓝皮书》第2.1节中进一步阐述。该节规定，在投放市场之后接受重大变更或大修的产品，在其原有性能、用途或型式已被修改、危害的性质已经改变或风险水平已经提高、并且该含数字元素产品被在市场上提供的情况下，应被视为新产品。

116. The generally established consequence is therefore that, where a modification of a product with digital elements qualifies as a substantial modification and the modified product with digital elements is made available on the market, it is to be treated as a new product with digital elements for the purposes of the CRA. As a result, the act of making the substantially modified product available on the market constitutes a new placing on the market. This applies whether the substantial modification is carried out by the original manufacturer or by another person. In order to ensure that the CRA is applied in a uniform and proportionate manner across the different categories of actor that may carry out a substantial modification, the following subsections address the resulting obligations of the person carrying out the substantial modification when the substantially modified product with digital elements is placed on the market. The consequences for the support period of the product with digital elements are addressed in Section 5 Support period.

> 因此，已经一般确立的后果是：如果对含数字元素产品的修改构成实质性修改，并且被修改的含数字元素产品被在市场上提供，则就CRA而言，它应作为新的含数字元素产品对待。因此，在市场上提供被实质性修改的产品这一行为构成新的投放市场。不论实质性修改由原始制造商还是由其他人实施，均适用这一点。为确保CRA在可能实施实质性修改的不同类别行为人之间以统一且相称的方式适用，以下各分节说明，在被实质性修改的含数字元素产品被投放市场时，实施实质性修改之人因此承担的义务。对含数字元素产品支持期的后果，在第5节“支持期”中说明。

4.4.1 Substantial modifications carried out by a person other than the original manufacturer
4.4.1 由原始制造商以外的人实施的实质性修改

117. In accordance with Articles 21 and 22, where a substantial modification of a product with digital elements already placed on the market is carried out by a natural or legal person other than the manufacturer of the product with digital elements, the person who carries out the substantial modification and makes the modified product with digital elements available on the market is to be regarded as the manufacturer of the modified product with digital elements, irrespective of whether that person was involved in the original design or placing on the market of that product.

> 根据第21条和第22条，如果对已经投放市场的含数字元素产品的实质性修改由该含数字元素产品的制造商以外的自然人或法人实施，则实施该实质性修改并在市场上提供被修改的含数字元素产品的人，应被视为被修改的含数字元素产品的制造商，不论该人是否参与了该产品的原设计或投放市场。

118. Article 22 further clarifies that the person carrying out the modification is subject to the obligations laid down in Articles 13 and 14 only in respect of the part of the product with digital elements affected by the substantial modification, where that modification does not have an impact on the cybersecurity of the product with digital elements as a whole.

> 第22条进一步澄清，如果该修改不影响含数字元素产品整体的网络安全，则实施修改的人仅就受实质性修改影响的含数字元素产品部分，受第13条和第14条所规定义务的约束。

119. Where a substantial modification affects compliance with the essential requirements but does not negatively affect the cybersecurity of the product with digital elements as a whole, the person carrying out the modification is subject to

Articles 13 (including the obligation to ensure compliance with the essential requirements and to carry out a conformity assessment procedure) and 14 (reporting obligations) only in relation to the part of the product with digital elements that has been substantially modified16 . Furthermore, the original manufacturer's obligations under the CRA continue to apply to the original product with digital elements placed on the market, ensuring continuity in vulnerability handling and compliance for the unchanged parts.

> 如果实质性修改影响对基本要求的符合，但并不对含数字元素产品整体的网络安全产生不利影响，则实施修改的人仅就已被实质性修改的含数字元素产品部分受第13条（包括确保符合基本要求并实施合格评定程序的义务）和第14条（报告义务）的约束16。此外，原始制造商在CRA项下的义务继续适用于已投放市场的原含数字元素产品，从而确保对未改变部分的漏洞处理和合规的连续性。

120. A case of substantial modification should not be confused with cases of integration, in which a person assembles components (including, where appropriate, by modifying them) into a new product with digital elements that they themselves place on the market. In such cases, the integrator is not modifying a product with digital elements already placed on the market by another manufacturer; rather, it is placing a new product with digital elements of its own on the market. The integrator is the manufacturer of that new product with digital elements for the purposes of the CRA and is required to comply with the Regulation in its entirety in respect of the product with digital elements as a whole. Where the manufacturer integrates components that are subject to the CRA, it may rely on the compliance activities of the components' manufacturers to facilitate its own compliance with the CRA. Example 51: A company purchases off-the-shelf microcontroller modules and connectivity components from third-party suppliers, develops proprietary firmware and a sensor package, and assembles them into a connected agricultural monitoring product with digital elements that it places on the market under its own name. Although the company has modified the underlying microcontroller modules and combined them with other components, it is not substantially modifying a product with digital elements already placed on the market; rather, it is placing a new product with digital elements on the market. The company is the manufacturer of the agricultural monitor for the purposes of the CRA and is required to comply with the Regulation in respect of the agricultural monitor as a whole.

> 实质性修改的情形不应与集成的情形相混淆。在集成情形中，某人将组件组装（包括在适当情况下通过修改它们）成其自己投放市场的新含数字元素产品。在此类情况下，集成者并非在修改已由另一制造商投放市场的含数字元素产品；相反，它是在将自己的新含数字元素产品投放市场。就CRA而言，集成者是该新含数字元素产品的制造商，并且必须就作为整体的含数字元素产品完整遵守本条例。如果制造商集成受CRA约束的组件，它可以依赖这些组件制造商的合规活动，以便利其自己遵守CRA。示例51：某公司从第三方供应商购买现成的微控制器模块和连接组件，开发专有固件和传感器套件，并将它们组装成一款联网农业监测含数字元素产品，以自己的名称投放市场。尽管该公司修改了底层微控制器模块并将它们与其他组件组合，它并非在对已经投放市场的含数字元素产品进行实质性修改；相反，它是在将新的含数字元素产品投放市场。就CRA而言，该公司是该农业监测器的制造商，并且必须就作为整体的农业监测器遵守本条例。

16 In line with Section 2.1 of the Blue Guide, 'it is not necessary to repeat tests and produce new documentation in relation to aspects not impacted by the modification. It is up to the natural or legal person who carries out changes or has changes carried out to the product to demonstrate that not all elements of the technical documentation need to be updated. The natural or legal person who carries out changes or has changes carried out to the product shall be responsible for the conformity of the modified product and draw a declaration of conformity, even if they use existing tests and technical documentation'.

> 16 根据《蓝皮书》第2.1节，“就不受修改影响的方面而言，没有必要重复测试并制作新的文件。由对产品实施变更或使变更得以实施的自然人或法人来证明，并非技术文件的所有要素都需要更新。对产品实施变更或使变更得以实施的自然人或法人，应当对修改后产品的符合负责并作出符合性声明，即使其使用既有的测试和技术文件”。

121. Where a substantial modification carried out by a person other than the original manufacturer negatively affects the cybersecurity of the product with digital elements as a whole, for example because the modification is no longer targeted or limited to a specific component or subsystem, the modified product with digital elements made available on the market should be treated as a new product with digital elements subject to the CRA in its entirety. In such cases, that product's overall cybersecurity risk profile has changed, and the modification cannot be assessed without considering the product

with digital elements as a whole. The person carrying out the modification is subject to the obligations of a manufacturer laid down in Articles 13 and 14 in respect of the modified product with digital elements as a whole.

> 如果由原始制造商以外的人实施的实质性修改对含数字元素产品整体的网络安全产生不利影响，例如因为该修改不再针对或限于特定组件或子系统，则在市场上提供的被修改含数字元素产品应作为整体受CRA约束的新含数字元素产品对待。在此类情况下，该产品的整体网络安全风险状况已经改变，并且不能不考虑作为整体的含数字元素产品来评估该修改。实施修改的人就作为整体的被修改含数字元素产品，受第13条和第14条所规定的制造商义务的约束。

4.4.2 Substantial modifications carried out by the original manufacturer
4.4.2 由原始制造商实施的实质性修改

122. Where the substantial modification is carried out by the original manufacturer, including in the context of iterative development of software products with digital elements, that manufacturer remains the manufacturer for the purposes of the CRA. However, the substantially modified product with digital elements is to be considered as newly placed on the market.

> 如果实质性修改由原始制造商实施，包括在含数字元素软件产品迭代开发的背景下，则就CRA而言该制造商仍然是制造商。然而，被实质性修改的含数字元素产品应视为被重新投放市场。

123. In accordance with Section 2.1 of the Blue Guide, the original manufacturer placing the substantially modified product with digital elements on the market may reuse existing documentation and tests for aspects of the product with digital elements that are not impacted by the substantial modification. Particularly where the manufacturer places substantially modified versions of the same product with digital elements on the market, the conformity assessment procedure should focus on the substantially modified parts of the product with digital elements. Similarly, where a third-party conformity assessment is performed, the conformity assessment body should focus its assessment on the substantially modified parts. For unchanged parts of the product with digital elements, it may reuse existing documentation and test results.

> 根据《蓝皮书》第2.1节，将被实质性修改的含数字元素产品投放市场的原始制造商，可以就不受实质性修改影响的含数字元素产品方面再利用既有文件和测试。特别是在制造商将同一含数字元素产品的被实质性修改版本投放市场的情况下，合格评定程序应当侧重于含数字元素产品中被实质性修改的部分。同样，在实施第三方合格评定的情况下，合格评定机构应当将其评估侧重于被实质性修改的部分。对于含数字元素产品中未改变的部分，它可以再利用既有文件和测试结果。

124. The proportionality considerations set out in the previous subsection apply equally to substantial modifications carried out by the original manufacturer of a product with digital elements placed on the market before 11 December 2027. Such a substantial modification carried out by the original manufacturer does not, in itself, require the manufacturer to bring the entire product with digital elements placed on the market before that date into full compliance with the CRA, unless the modification negatively affects the cybersecurity of the product with digital elements as a whole. Where the modification does not affect the cybersecurity of the product with digital elements as a whole, the original manufacturer’s obligations in respect of the modification should be limited to the substantially modified parts.

> 上一分节所载的相称性考虑，同样适用于由在2027年12月11日之前投放市场的含数字元素产品的原始制造商实施的实质性修改。原始制造商实施的此类实质性修改，其本身并不要求制造商使在该日之前投放市场的整个含数字元素产品完全符合CRA，除非该修改对含数字元素产品整体的网络安全产生不利影响。如果该修改不影响含数字元素产品整体的网络安全，则原始制造商就该修改所负的义务应当限于被实质性修改的部分。

5 Support period

5 支持期

125. Article 13(8) of the CRA requires manufacturers to determine the support period during which the vulnerabilities of the product with digital elements, including its components, are handled effectively and in accordance with the essential requirements set out in Part II of Annex I. The support period reflects the period of time during which the product with digital elements is expected to be in use (the expected use time), and should be determined in light of the criteria set out in Article 13(8), in particular reasonable user expectations, the nature of the product with digital elements, including its intended purpose, as well as relevant Union law determining the lifetime of products with digital elements17. Overall, such criteria are to be taken into account in a manner that ensures proportionality in determining the support period.

> CRA第13条第8款要求制造商确定支持期；在支持期内，含数字元素产品（包括其组件）的漏洞得到有效处理，并符合附件I第二部分所载的基本要求。支持期反映含数字元素产品预期被使用的时间段（预期使用时间），并且应当根据第13条第8款所载标准来确定，尤其是用户的合理预期、含数字元素产品的性质（包括其预期用途），以及确定含数字元素产品寿命的相关联盟法律17。总体而言，这些标准应当以确保确定支持期时的相称性的方式加以考虑。

126. Article 13(8) further requires that the support period be at least five years, unless the product with digital elements is expected to be in use for less than five years, in which case the support period shall correspond to the expected use time. The minimum support period therefore operates only as a safeguard, ensuring that vulnerabilities are handled for a sufficiently long period, while allowing manufacturers to take into account products with digital elements with genuinely shorter expected use times. Recital 60 provides more guidance in this respect, clarifying that products with digital elements reasonably expected to be in use for longer than five years should accordingly have longer support periods. A support period of five years is therefore not to be considered as the default for all products with digital elements. Instead, the manufacturer should determine the appropriate support period in light of the criteria referred to in Article 13(8).

> 第13条第8款进一步要求，支持期至少为五年，除非含数字元素产品预期被使用的时间少于五年；在后一种情况下，支持期应当与预期使用时间相一致。因此，最低支持期仅作为一项保障而运作，确保漏洞在足够长的期间内得到处理，同时允许制造商考虑预期使用时间确实较短的含数字元素产品。序言第60项在这方面提供了更多指导，澄清可合理预期使用时间长于五年的含数字元素产品应当相应具有更长的支持期。因此，五年的支持期不应被视为所有含数字元素产品的默认值。相反，制造商应当根据第13条第8款所指的标准确定适当的支持期。

127. Article 13(19) requires manufacturers to indicate at the time of purchase, in a clear and understandable manner, the end date of the support period (at least the month and year). It also requires manufacturers to display a notification to users once the support period expires, where this is technically feasible in light of the nature of the product with digital elements. This obligation is intended to provide transparency to users as regards the duration for which security support can be expected.

> 第13条第19款要求制造商在购买时以清晰且可理解的方式标明支持期的结束日期（至少标明月份和年份）。它还要求制造商在支持期届满后向用户显示通知，如果鉴于含数字元素产品的性质这在技术上可行。这一义务旨在就可以预期获得安全支持的期间向用户提供透明度。

128. In the case of software products with digital elements, which are often developed and released iteratively and where substantially modified versions may be placed on the market frequently over time, the support period must be understood in light of this development model. Each substantially modified version of a software product with digital elements placed on the market has to have a declared support period that complies with Article 13(8). This includes the minimum support period of at least five years, unless the expected use time of that version is demonstrably shorter, as also clarified in recital 60. Section 5.1 Substantial modifications and the support period further clarifies that, where the substantial modification does not lead to changes in the factors that originally determined the expected use time of the product with digital

elements, the original support period is unaffected (i.e. including in cases where the remaining support period is less than five years).

> 就含数字元素软件产品而言，它们往往以迭代方式开发和发布，并且被实质性修改的版本可能随时间频繁投放市场，支持期必须结合这一开发模式来理解。投放市场的含数字元素软件产品的每一个被实质性修改的版本，都必须有一个符合第13条第8款的已声明支持期。这包括至少五年的最低支持期，除非该版本的预期使用时间可证明更短，正如序言第60项亦所澄清的。第5.1节“实质性修改与支持期”进一步澄清，如果实质性修改并不导致原先决定含数字元素产品预期使用时间的因素发生变化，则原支持期不受影响（即包括剩余支持期少于五年的情形）。

17 Additional criteria that may be taken into account, in accordance with Article 13(8), include the support periods of products with digital elements offering a similar functionality placed on the market by other manufacturers, the availability of the operating environment, the support periods of integrated components that provide core functions and are sourced from third parties as well as relevant guidance provided by the CRA administrative cooperation group (ADCO) and the Commission.

> 17 根据第13条第8款可以考虑的额外标准包括：其他制造商投放市场的、提供类似功能的含数字元素产品的支持期，运行环境的可用性，提供核心功能并来源于第三方的集成组件的支持期，以及CRA行政合作小组（ADCO）和委员会提供的相关指导。

129. Article 13(10) provides flexibility for software products with digital elements by allowing manufacturers, under certain conditions, to ensure compliance with the vulnerability handling requirement set out in point (2) of Part II of Annex I (addressing and remediating vulnerabilities) only for the version of the software product with digital elements last placed on the market. This is permitted where users of previously placed versions have access to the version last placed on the market free of charge and do not incur additional costs to adjust the hardware and software environment in which they use that product's original version.

> 第13条第10款为含数字元素软件产品提供了灵活性，允许制造商在某些条件下，仅就最后投放市场的含数字元素软件产品版本，确保遵守附件I第二部分第(2)点所规定的漏洞处理要求（处理和补救漏洞）。在先前投放版本的用户可以免费获取最后投放市场的版本，并且不产生额外费用以调整其使用该产品原版本的硬件和软件环境的情况下，允许这样做。

130. For the purposes of Article 13(10), the concept of 'additional costs' should be interpreted in a practical and proportionate manner, taking into account normal and expected practices in software maintenance and operation. It does not encompass reasonable operational effort that is inherent to applying software updates or maintaining a secure operating environment, such as personnel time, routine testing, configuration adjustments or upgrades of underlying software dependencies that are necessary to address end-of-life components or known security vulnerabilities. By contrast, 'additional costs' refers to burdens that go beyond what can normally be expected in the context of software updates, such as mandatory purchases of new hardware, infrastructure replacement or fundamental changes to the operating environment.

> 就第13条第10款而言，“额外费用”这一概念应当以实际且相称的方式解释，同时考虑软件维护和运行中正常且预期的做法。它不包括适用软件更新或维持安全运行环境所固有的合理运行努力，例如人员时间、例行测试、配置调整，或为处理已达寿命终点的组件或已知安全漏洞所必要的底层软件依赖项升级。相反，“额外费用”是指超出软件更新背景下通常可以预期之范围的负担，例如强制购买新硬件、更换基础设施或对运行环境的根本改变。

131. For continuously evolving software products with digital elements, manufacturers may place successive substantially modified versions on the market over relatively short intervals and expect users to upgrade regularly. In such cases the declared support period for each substantially modified version must comply with Article 13(8) at the time it is placed on the market. In other words, the manufacturer must declare a new support period for that substantially modified version. However, manufacturers may rely on Article 13(10) to discontinue addressing and remediating vulnerabilities for earlier versions once users are able to upgrade to a later version free of charge and without incurring additional costs as referred to above, even if this results in a shorter effective support period for those earlier versions18. The manufacturer remains

subject to the other vulnerability-handling requirements of Part II of Annex I, as well as to the reporting obligations of Article 14. As also explained in recital 40, these requirements include, among others, for all subsequent substantially modified versions of the software product with digital elements placed on the market: (i) maintaining a policy on coordinated vulnerability disclosure; and (ii) measures to facilitate the sharing of information about potential vulnerabilities19. Example 52: A manufacturer places a smartphone model on the EU market and declares a support period of X years from the date of placement on the market, during which it will provide security updates addressing vulnerabilities. During that period, the manufacturer releases regular software updates and substantially modified versions of the operating system, which users can install free of charge without requiring new hardware. The manufacturer may, in accordance with Article 13(10), address and remediate vulnerabilities for the latest version of the operating system made available for that smartphone model, provided that earlier versions can be upgraded free of charge and without additional costs. For the duration of the support period, the manufacturer remains subject to the other vulnerability handling requirements, such as coordinated vulnerability disclosure and information-sharing measures. Example 53: A manufacturer places an enterprise software product with digital elements on the market and releases substantially modified versions every few months, reflecting security improvements, new features and compatibility with updated operating systems and platforms. Each version is placed on the market with a declared support period in accordance with Article 13(8). The manufacturer expects users to upgrade regularly as part of normal operation and provides access to the latest version free of charge. Applying upgrades may require reasonable operational effort, such as testing or configuration adjustments, but does not require additional costs, such as the purchase of new hardware or fundamental infrastructure changes. In this context, the manufacturer may rely on Article 13(10) to discontinue addressing and remediating vulnerabilities for earlier versions once users can upgrade to the latest version, while continuing to comply with the other vulnerability-handling requirements for all subsequent substantially modified versions.

> 对于持续演进的含数字元素软件产品，制造商可以在相对较短的间隔内将相继的被实质性修改版本投放市场，并预期用户定期升级。在此类情况下，每一个被实质性修改版本的已声明支持期，必须在其投放市场时符合第13条第8款。换言之，制造商必须为该被实质性修改的版本声明一个新的支持期。然而，一旦用户能够免费且不产生上文所指额外费用地升级到较后版本，制造商可以依赖第13条第10款，停止为较早版本处理和补救漏洞，即使这导致这些较早版本的有效支持期较短18。制造商仍然受附件I第二部分的其他漏洞处理要求以及第14条报告义务的约束。正如序言第40项亦所说明的，这些要求尤其包括，对投放市场的含数字元素软件产品此后所有被实质性修改的版本：(i) 维持关于协调漏洞披露的政策；以及(ii) 便于分享关于潜在漏洞的信息的措施19。示例52：某制造商在欧盟市场上投放一款智能手机型号，并声明自投放市场之日起X年的支持期，在此期间它将提供处理漏洞的安全更新。在该期间内，制造商发布操作系统的定期软件更新和被实质性修改的版本，用户可以免费安装，而不需要新硬件。制造商可以根据第13条第10款，为该智能手机型号所提供的操作系统最新版本处理和补救漏洞，但前提是较早版本可以免费且不产生额外费用地升级。在支持期期间，制造商仍然受其他漏洞处理要求的约束，例如协调漏洞披露和信息分享措施。示例53：某制造商投放一款企业含数字元素软件产品，并每隔数月发布被实质性修改的版本，反映安全改进、新功能以及与更新后的操作系统和平台的兼容性。每一个版本都带着符合第13条第8款的已声明支持期被投放市场。制造商预期用户将升级作为正常运行的一部分，并免费提供对最新版本的获取。应用升级可能需要合理的运行努力，例如测试或配置调整，但不需要额外费用，例如购买新硬件或根本性的基础设施变更。在此背景下，一旦用户能够升级到最新版本，制造商可以依赖第13条第10款停止为较早版本处理和补救漏洞，同时继续就此后所有被实质性修改的版本遵守其他漏洞处理要求。

18 It should be recalled that Article 13(19) requires manufacturers, where technically feasible in light of the nature of the product with digital elements, to display a notification to users informing them that their product with digital elements has reached the end of its support period. Therefore, where addressing and remediating vulnerabilities for earlier versions is discontinued, it is expected that users who have not upgraded to the newest version are informed, if technically feasible.

> 18 应当回顾，第13条第19款要求制造商在鉴于含数字元素产品的性质而技术上可行的情况下，向用户显示通知，告知其含数字元素产品已到达支持期的终点。因此，在停止为较早版本处理和补救漏洞的情况下，预期未升级到最新版本的用户在技术上可行时得到告知。

5.1 Substantial modifications and the support period

5.1 实质性修改与支持期

132. As set out in Section 4.4 Consequences of a substantial modification, where a modification of a product with digital elements qualifies as a substantial modification and the modified product with digital elements is made available on the market, it is to be treated as a new product for the purposes of the CRA, and the act of making the substantially modified product with digital elements available on the market constitutes a new placing on the market. It is therefore useful to clarify the effect that this new placing on the market has on the support period of the substantially modified product with digital elements.

> 正如第4.4节“实质性修改的后果”所规定的，如果对含数字元素产品的修改构成实质性修改，并且被修改的含数字元素产品被在市场上提供，则就CRA而言它应作为新产品对待，并且在市场上提供被实质性修改的含数字元素产品这一行为构成新的投放市场。因此，宜澄清这一新的投放市场对被实质性修改的含数字元素产品的支持期有何影响。

133. The support period of a substantially modified product with digital elements should be determined by reference to that product's expected use time, in light of the criteria set out in Article 13(8) of the CRA. A substantial modification should therefore require a reassessment against those criteria, but does not automatically result in the support period being reset, or even extended. The relevant question is whether the substantial modification affects the factors that originally determined that product's expected use time and, therefore, the original support period.

> 被实质性修改的含数字元素产品的支持期，应当参照该产品的预期使用时间，根据CRA第13条第8款所载标准来确定。因此，实质性修改应当要求对照这些标准进行重新评估，但并不自动导致支持期被重置，甚至被延长。相关问题是，实质性修改是否影响原先决定该产品预期使用时间、因而决定原支持期的因素。

19 It should be noted that, where users can upgrade to the latest version of the software without additional costs, manufacturers may nevertheless choose to continue addressing and remediating vulnerabilities in earlier versions of that software, including on a paid basis or under other commercial arrangements. The CRA does not require manufacturers to provide security updates for such earlier versions free of charge.

> 19 应当指出，在用户可以不产生额外费用地升级到软件最新版本的情况下，制造商仍然可以选择继续为该软件的较早版本处理和补救漏洞，包括在付费基础上或根据其他商业安排。CRA并不要求制造商免费为此类较早版本提供安全更新。

134. Where the substantial modification does not affect those factors, the criteria set out in Article 13(8) continue to indicate the same expected use time as originally determined, and the support period of the modified product with digital elements should align with the remaining expected use time of the product as originally placed on the market. This will typically be the case where the expected use time was determined primarily by factors that the modification does not alter, such as the physical durability of hardware components, where the substantial modification concerns only software functionality or back-end services. Example 54: A manufacturer places on the market a robot vacuum cleaner with an expected use time of X years, determined on the basis of the nature of the product with digital elements, including the physical durability and wear characteristics of the hardware components, and taking into account reasonable user expectations as to that product's lifetime. The manufacturer sets a support period of X years. After Y years, the manufacturer releases a software update that qualifies as a substantial modification, adding new cleaning modes and navigation features. The software update does not affect the physical durability of the hardware and does not alter reasonable user expectations as to that product's lifetime. The Article 13(8) criteria therefore continue to indicate the same expected use time. The support period of the modified product with digital elements aligns with the remaining expected use time as originally determined. Example 55: A manufacturer places on the market a complex industrial machinery product with digital elements, with a cloud back-end that constitutes a remote data processing solution. The expected use time is X years, determined in light of reasonable user expectations and the nature of the product with digital elements, such as the physical durability of the machinery hardware and expected wear and tear. The support period is set to align with that expected use time at X years. After Y years, the manufacturer rearchitects the cloud back-end (the remote data

processing solution), introducing new APIs and data flows, in a manner that qualifies as a substantial modification of the product with digital elements but does not alter the nature of that product or affect user expectations. The Article 13(8) criteria therefore continue to indicate the same expected use time. The support period of the modified product with digital elements aligns with the remaining expected use time as originally determined.

> 如果实质性修改不影响这些因素，则第13条第8款所载标准继续表明与原先确定的相同的预期使用时间，被修改的含数字元素产品的支持期应当与该产品按原先投放市场时的剩余预期使用时间相一致。在预期使用时间主要由修改并未改变的因素决定的情况下，通常即是如此，例如硬件组件的物理耐用性，而实质性修改仅涉及软件功能或后端服务。示例54：某制造商投放一款扫地机器人，预期使用时间为X年，该时间根据含数字元素产品的性质确定，包括硬件组件的物理耐用性和磨损特性，并考虑用户对该产品寿命的合理预期。制造商将支持期定为X年。Y年之后，制造商发布构成实质性修改的软件更新，增加新的清洁模式和导航功能。该软件更新不影响硬件的物理耐用性，也不改变用户对该产品寿命的合理预期。因此，第13条第8款的标准继续表明相同的预期使用时间。被修改的含数字元素产品的支持期与原先确定的剩余预期使用时间相一致。示例55：某制造商投放一款复杂的工业机械含数字元素产品，带有构成远程数据处理解决方案的云后端。预期使用时间为X年，该时间根据用户的合理预期和含数字元素产品的性质确定，例如机械硬件的物理耐用性和预期磨损。支持期被定为与该预期使用时间相一致，为X年。Y年之后，制造商重新架构云后端（远程数据处理解决方案），引入新的应用程序接口（API）和数据流，其方式构成含数字元素产品的实质性修改，但不改变该产品的性质，也不影响用户预期。因此，第13条第8款的标准继续表明相同的预期使用时间。被修改的含数字元素产品的支持期与原先确定的剩余预期使用时间相一致。

135. Where the substantial modification affects the factors that originally determined the expected use time of the product with digital elements, the manufacturer should recalculate the support period to reflect the new expected use time, applying the Article 13(8) criteria accordingly. This may be the case, for example, of revitalising hardware modifications that extend that product's operational life, or of a substantial reprogramming or rewrite of that product's core software that materially changes its expected use time20. Example 56: A manufacturer places on the market a programmable logic controller (PLC) with an expected use time of X years, determined primarily on the basis of the nature of the product with digital elements and the durability of the underlying hardware. The support period is set accordingly. Several years after the initial placing on the market, the manufacturer carries out a substantial modification consisting of the replacement of the PLC's embedded computing platform, including the processor, memory and runtime environment, with a new generation of components designed for a significantly longer operational lifetime. As a result of the modification, reasonable user expectations and the nature of the product with digital elements change: the PLC's user may now reasonably expect the PLC to remain in productive use beyond its originally declared expected use time, supported by the new computing platform. The Article 13(8) criteria therefore indicate a longer expected use time, and the manufacturer recalculates the support period for that specific PLC accordingly.

> 如果实质性修改影响原先决定含数字元素产品预期使用时间的因素，制造商应当重新计算支持期，以反映新的预期使用时间，并相应适用第13条第8款的标准。例如，延长该产品运行寿命的、使硬件重新恢复活力的修改，或者对该产品核心软件的实质性重新编程或重写以致实质改变其预期使用时间，即可能如此20。示例56：某制造商投放一款可编程逻辑控制器（PLC），预期使用时间为X年，主要根据含数字元素产品的性质和底层硬件的耐用性确定。支持期相应设定。在初次投放市场数年之后，制造商实施实质性修改，包括用为显著更长的运行寿命而设计的新一代组件，替换该PLC的嵌入式计算平台，包括处理器、内存和运行时环境。由于该修改，用户的合理预期和含数字元素产品的性质发生变化：该PLC的用户现在可以合理预期，在新计算平台的支持下，该PLC在原先声明的预期使用时间之后仍保持生产性使用。因此，第13条第8款的标准表明更长的预期使用时间，制造商相应重新计算该特定PLC的支持期。

20 It should be recalled that, as indicated in Section 4.1 Physical repairs, operations of refurbishment, maintenance or repair are generally not considered to amount to substantial modifications.

> 20 应当回顾，正如第4.1节“物理修理”所指出的，翻新、维护或修理操作一般不视为构成实质性修改。

6 Important and critical products with digital elements
6 重要和关键的含数字元素产品

136. Article 7(1) of the CRA establishes that products with digital elements that have the core functionality of a product category set out in Annex III to the Regulation are considered to be 'important products with digital elements'. Annex III further divides important products with digital elements into class I and class II. Similarly, Article 8(1) establishes that products with digital elements that have the core functionality of a product category set out in Annex IV to the CRA are considered to be 'critical products with digital elements'21.

> CRA第7条第1款规定，具有本条例附件III所载产品类别之核心功能的含数字元素产品，被视为“重要含数字元素产品”。附件III进一步将重要含数字元素产品分为I类和II类。同样，第8条第1款规定，具有CRA附件IV所载产品类别之核心功能的含数字元素产品，被视为“关键含数字元素产品”21。

137. The classification of a product with digital elements as important or critical or, conversely, as belonging to the 'default' category22, is of relevance when determining the conformity assessment procedure the manufacturer needs to follow, in accordance with Article 32, before it can place that product with digital elements on the market. Notably, products with digital elements in the default category can always rely on the internal control procedure based on module A ('self-assessment') 23. Important products with digital elements of class I or II and critical products with digital elements are subject to more stringent conformity assessment procedures. This does not include important products with digital elements of class I or II qualifying as free and open-source software that are placed on the market, for which, in accordance with Article 32(5), manufacturers are allowed to follow the procedures of the default category.

> 将含数字元素产品分类为重要或关键，或者相反地分类为属于“默认”类别22，在根据第32条确定制造商在将该含数字元素产品投放市场之前需要遵循的合格评定程序时具有相关性。尤其是，属于默认类别的含数字元素产品始终可以依赖基于模块A的内部控制程序（“自我评定”）23。I类或II类重要含数字元素产品以及关键含数字元素产品，受更严格的合格评定程序约束。这不包括被投放市场的、符合自由及开源软件条件的I类或II类重要含数字元素产品；根据第32条第5款，制造商被允许对这些产品遵循默认类别的程序。

138. The concept of core functionality is therefore essential for the manufacturer to determine the applicable conformity assessment regime. However, this concept is not explicitly defined in the CRA. Products with digital elements can perform a range of functions, some of which may be ancillary to that product's core functionality, and should not impact the product's classification as default/important class I/important class II/critical. It is therefore useful to provide more guidance to help manufacturers correctly perform the relevant conformity assessment procedures, and to assist market surveillance authorities in ensuring the harmonised enforcement of the CRA across the EU.

> 因此，核心功能这一概念对于制造商确定适用的合格评定制度是必不可少的。然而，这一概念在CRA中没有明确规定。含数字元素产品可以履行一系列功能，其中一些可能是该产品核心功能的辅助功能，并且不应当影响将该产品分类为默认类别/重要I类/重要II类/关键。因此，宜提供更多指导，以帮助制造商正确实施相关合格评定程序，并协助市场监督机构确保CRA在全欧盟范围内得到统一执行。

6.1 Core functionality
6.1 核心功能

139. The core functionality of a product with digital elements refers to that product's main features and technical capabilities, without which it would not be able to meet its intended purpose. It can be assessed in light of that product's specific context and conditions of use, taking into account, among others, the information the manufacturer supplies in the instructions for use, promotional or sales materials and statements, as well as in the technical documentation. Example 57: A software product with digital elements provides an abstraction layer over the underlying hardware and manages the execution of software components. Its main features include hardware and peripheral initialisation, process and memory

management, input–output control, scheduling, resource allocation, and the exposure of system services and application programming interfaces (APIs) through which applications interact with the device's hardware and software resources. The technical documentation indicates that the product with digital elements orchestrates computing resources, enforces system configurations, and provides standardised interfaces for software modules and connected peripherals. The manufacturer highlights these capabilities as enabling the platform to serve as the central software environment on which applications can reliably run. The product with digital elements has the core functionality of an operating system, as described in Annex I, point 11, to Implementing Regulation (EU) 2025/2392.

> 含数字元素产品的核心功能，是指该产品的主要特性和技术能力；没有这些特性和能力，它就无法实现其预期用途。可以结合该产品的具体背景和使用条件来评估核心功能，其中考虑制造商在使用说明、宣传或销售材料和声明以及技术文件中提供的信息。示例57：一款含数字元素软件产品在底层硬件之上提供抽象层，并管理软件组件的执行。其主要特性包括硬件和外设初始化、进程和内存管理、输入—输出控制、调度、资源分配，以及通过应用程序与设备的硬件和软件资源交互的系统服务和应用程序接口（API）的暴露。技术文件表明，该含数字元素产品编排计算资源、强制执行系统配置，并为软件模块和所连接的外设提供标准化接口。制造商强调这些能力使该平台能够作为应用程序可以可靠运行的中心软件环境。该含数字元素产品具有操作系统的核心功能，如实施条例(EU) 2025/2392附件I第11点所述。

21 Commission Implementing Regulation (EU) 2025/2392 sets out the technical description of the categories of important and critical products. 22 The term 'default' category is not a term defined in the CRA. The use of the term in this document refers to products with digital elements that do not have the core functionality of a product category set out in Annexes III or IV to the CRA, and that consequently are subject to the conformity assessment regime set out in Article 32(1). 23 The manufacturer can nonetheless always choose to apply a more stringent conformity assessment procedure, as set out in Article 32(1).

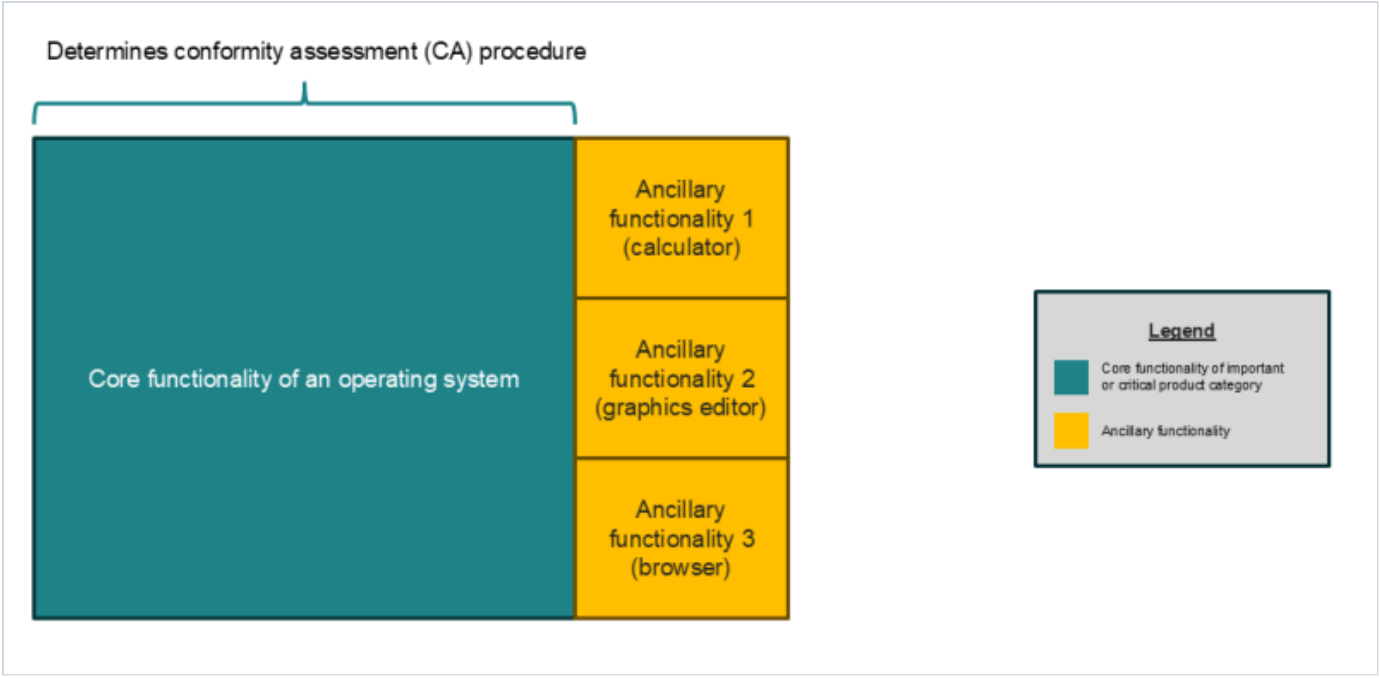
> 21 委员会实施条例(EU) 2025/2392规定了重要和关键产品类别的技术描述。22 “默认”类别这一用语不是CRA中定义的用语。本文件中使用该用语，是指不具有CRA附件III或附件IV所载产品类别之核心功能、因而受第32条第1款所规定的合格评定制度约束的含数字元素产品。23 尽管如此，制造商始终可以选择适用更严格的合格评定程序，如第32条第1款所规定的。

140. The functionality of a product with digital elements is rarely restricted exclusively to its core functionality, as products with digital elements often – if not always – perform additional functions that do not contribute to the product's core functionality. This may also include incorporating components that have themselves the functionality of another important or critical product with digital elements. However, the fact that a product with digital elements performs functions other than or additional to those detailed in the technical descriptions of important or critical products with digital elements does not in itself prevent the product from having one such core functionality.

> 含数字元素产品的功能很少仅限于其核心功能，因为含数字元素产品往往——如果不是总是——履行并不构成该产品核心功能的额外功能。这也可以包括纳入本身具有另一种重要或关键含数字元素产品之功能的组件。然而，含数字元素产品履行重要或关键含数字元素产品的技术描述中所详述功能以外的功能或额外功能，这一事实本身并不妨碍该产品具有这样一种核心功能。

Figure 2: Illustration of how core functionality, and not ancillary functionalities, determine the applicable conformity assessment procedure

> 图2：说明核心功能而非辅助功能如何决定适用的合格评定程序



图中文字对照（只译图内已有文字，不增补说明）

Determines conformity assessment (CA) procedure	决定合格评定（CA）程序
Core functionality of an operating system	操作系统的核心功能
Ancillary functionality 1 (calculator)	辅助功能1（计算器）
Ancillary functionality 2 (graphics editor)	辅助功能2（图形编辑器）
Ancillary functionality 3 (browser)	辅助功能3（浏览器）
Legend	图例
Core functionality of important or critical product category	重要或关键产品类别的核心功能
Ancillary functionality	辅助功能

141. A product with digital elements may have the ability to perform the functions of an important or critical product category, but nonetheless have a core functionality different from that of such a product category. In those cases, that product with digital elements would not qualify as an important or critical product with digital elements. As stated explicitly in Article 7(1) of the CRA for important products with digital elements (and applying the same logic for critical products with digital elements), the mere integration of an important or critical product with digital elements does not in itself render the product with digital elements an important or critical product with digital elements. Example 58: A smartphone integrates an operating system that provides the functionalities described in Annex I, point 11, to Implementing Regulation (EU) 2025/2392. While the operating system enables the management of hardware resources and execution of software applications, the smartphone as a whole has a different core functionality (e.g. that of enabling users to communicate and access information and services). The mere integration of an operating system does not mean that the smartphone has the core functionality of an operating system.

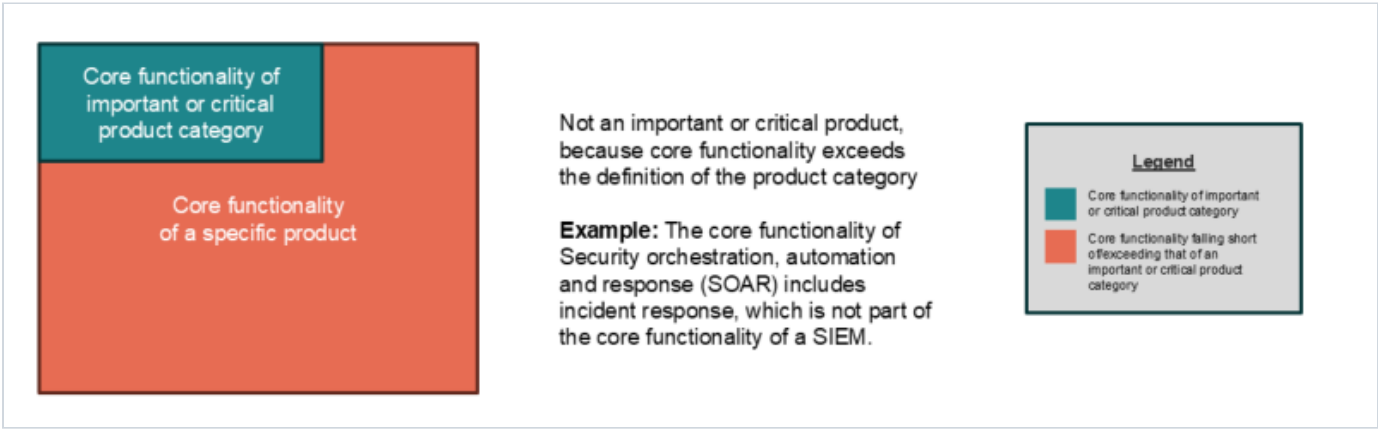
> 含数字元素产品可能具有履行重要或关键产品类别之功能的能力，但其核心功能仍然不同于此类产品类别的核心功能。在这些情况下，该含数字元素产品不构成重要或关键含数字元素产品。正如CRA第7条第1款就重要含数字元素产品所明确表述的（并对关键含数字元素产品适用同一逻辑），仅仅集成重要或关键含数字元素产品，其本身并不使该含数字元素产品成为重要或关键含数字元素产品。示例58：一部智能手机集成了提供实施条例(EU) 2025/2392附件I第11点所述功能的操作系统。尽管该操作系统能够管理硬件资源并执行软件应用程序，智能手机整体具有不同的核心功能（例如使用户能够通信并获取信息和服务）。仅仅集成操作系统，并不意味着该智能手机具有操作系统的核心功能。

142. Some products with digital elements may be similar to an important or critical product category, or belong to the same general product family, yet their core functionality may substantially exceed or fall substantially short of the core functionality of that category. This is not the case where a product with digital elements includes additional functionalities that merely complement or enhance the core functionality, which itself corresponds to that of an important or critical product category; in such cases, the product with digital elements retains the core functionality of that category and is classified accordingly. This assessment should be based on that product's main features and technical capabilities, considered objectively in light of its intended purpose, and not on the way in which the product with digital elements is described or marketed, where that description does not reflect the product's actual technical characteristics. Example 59: A security orchestration, automation and response (SOAR) software often has the ability to perform the functions of products with digital elements in the category of 'security information and event management (SIEM) systems', i.e. collect data from multiple sources, analyse and correlate that data and present it as actionable information for security-related purposes. However, the software's core functionality substantially exceeds that of a SIEM, including services such as incident response as core elements of its technical capabilities. Therefore, SOAR software is generally not considered to have the core functionality of SIEM systems.

> 某些含数字元素产品可能与某一重要或关键产品类别相似，或属于同一总体产品族，但其核心功能可能实质超出或实质未达到该类别的核心功能。如果含数字元素产品包含的额外功能仅仅补充或增强核心功能，而核心功能本身与某一重要或关键产品类别的核心功能相对应，则不属于这种情况；在此类情况下，该含数字元素产品保留该类别的核心功能，并相应分类。这一评估应当基于该产品的主要特性和技术能力，结合其预期用途客观考虑，而不是基于对该含数字元素产品的描述或营销方式，如果该描述并不反映产品的实际技术特性。示例59：安全编排、自动化与响应（SOAR）软件往往具有履行“安全信息与事件管理（SIEM）系统”类别含数字元素产品之功能的能力，即从多个来源收集数据、分析和关联这些数据，并将其作为与安全有关的目的可据以采取行动的信息予以呈现。然而，该软件的核心功能实质超出SIEM的核心功能，包括将事件响应等服务作为其技术能力的核心要素。因此，SOAR软件一般不视为具有SIEM系统的核心功能。

Figure 3: Illustration of the core functionality of a product with digital elements substantially exceeding the definition of an important or critical product category

> 图3：说明含数字元素产品的核心功能实质超出重要或关键产品类别定义的情形



图中文字对照（只译图内已有文字，不增补说明）

Core functionality of important or critical product category	重要或关键产品类别的核心功能
Core functionality of a specific product	某一具体产品的核心功能
Not an important or critical product, because core functionality exceeds the definition of the product category	不是重要或关键产品，因为核心功能超出该产品类别的定义
Example: The core functionality of Security orchestration, automation and response (SOAR) includes incident response, which is not part of the core functionality of a SIEM.	示例：安全编排、自动化与响应（SOAR）的核心功能包括事件响应，而事件响应不属于安全信息与事件管理（SIEM）的核心功能。

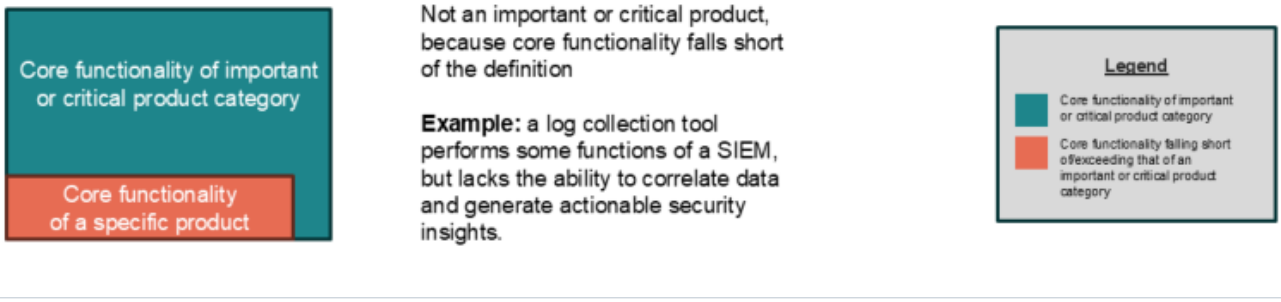
Legend: core functionality of important or critical product category; core functionality falling short of/exceeding that of an important or critical product category	图例：重要或关键产品类别的核心功能；未达到或超出重要或关键产品类别的核心功能

Example 60: Certain log collection and visualisation tools have the ability to ingest log data and present basic dashboards showing system events. While these tools can support security monitoring activities, their core functionality falls short of that of SIEM systems, as they do not perform data correlation, nor do they provide actionable security insights. Therefore, such tools are generally not to be considered to have the core functionality of SIEM systems.

> 示例60：某些日志收集和可视化工具具有摄入日志数据并呈现显示系统事件的基本仪表板的能力。尽管这些工具可以支持安全监测活动，其核心功能未达到SIEM系统的核心功能，因为它们不实施数据关联，也不提供可据以采取行动的安全洞见。因此，此类工具一般不应视为具有SIEM系统的核心功能。

Figure 4: Illustration of the core functionality of a product with digital elements substantially falling short of the definition of an important or critical product category

> 图4：说明含数字元素产品的核心功能实质未达到重要或关键产品类别定义的情形



图中文字对照（只译图内已有文字，不增补说明）

Core functionality of important or critical product category	重要或关键产品类别的核心功能
Core functionality of a specific product	某一具体产品的核心功能
Not an important or critical product, because core functionality falls short of the definition	不是重要或关键产品，因为核心功能未达到该定义
Example: a log collection tool performs some functions of a SIEM, but lacks the ability to correlate data and generate actionable security insights.	示例：日志收集工具履行SIEM的部分功能，但不具备关联数据并生成可据以采取行动的安全洞见的能力。

143. A manufacturer may not misrepresent the core functionality of its product with digital elements in such a way as to escape the conformity assessment regime applicable to important or critical products with digital elements, e.g. by overly emphasising or downplaying the role of certain functionalities, so that the product substantially exceeds or falls short of a given core functionality. This would be the case, for example, where there are clear inconsistencies between promotional materials, instructions for use, and technical documentation.

> 制造商不得以逃避适用于重要或关键含数字元素产品的合格评定制度的方式，虚假陈述其含数字元素产品的核心功能，例如过分强调或淡化某些功能的作用，从而使产品实质超出或未达到某一给定核心功能。例如，在宣传材料、使用说明和技术文件之间存在明显不一致的情况下，即属如此。

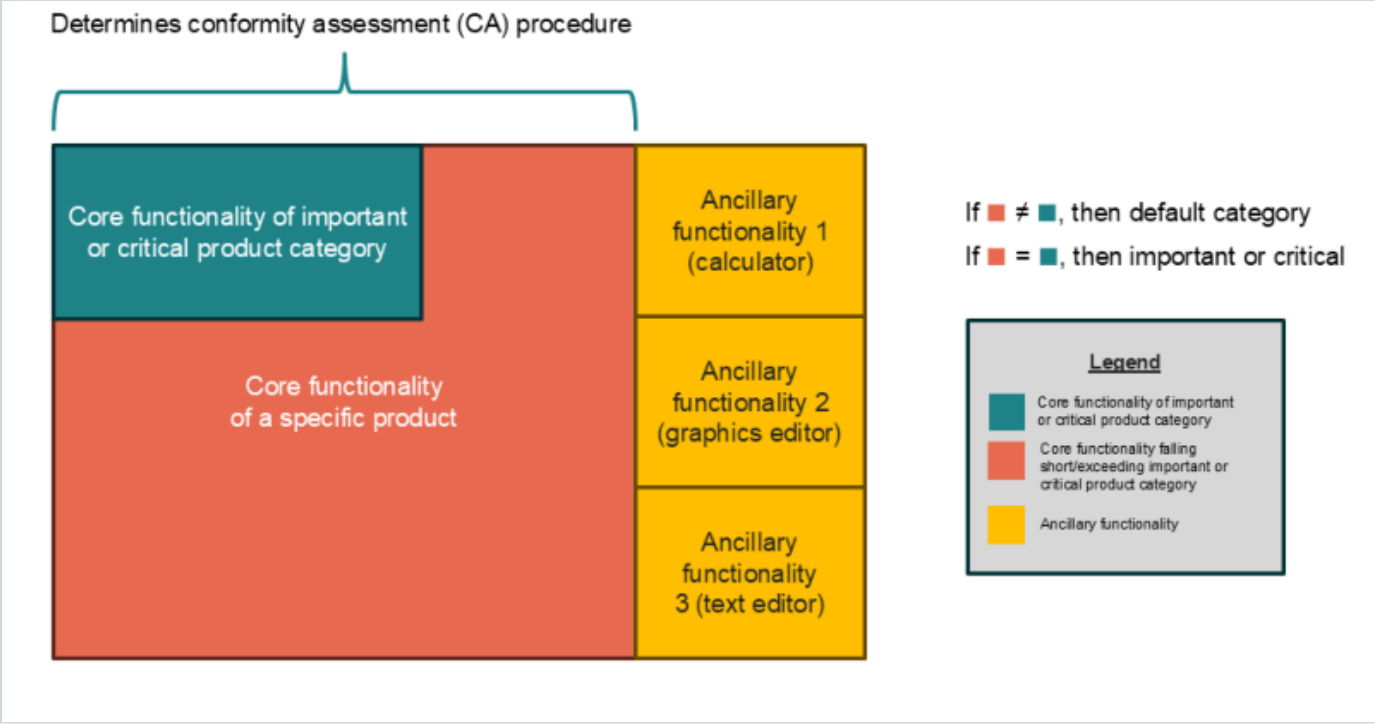
144. A product with digital elements may not have more than one core functionality for the purposes of determining the applicable conformity assessment regime. In accordance with Annex VII of the CRA, as part of a product's technical documentation, manufacturers are required to describe the intended purpose of their product with digital elements and the conformity assessment procedure they have followed. The product's core functionality should therefore be clearly

identified. This enables the correct identification of the applicable conformity assessment regime and allows market surveillance authorities to supervise and check that the Regulation is being applied correctly.

> 就确定适用的合格评定制度而言，含数字元素产品不得具有一项以上的核心功能。根据CRA附件VII，作为产品技术文件的一部分，制造商必须描述其含数字元素产品的预期用途以及其所遵循的合格评定程序。因此，应当清楚识别产品的核心功能。这使适用的合格评定制度能够被正确识别，并使市场监督机构能够监督和核查本条例是否得到正确适用。

Figure 5: Illustration of how the core functionality a specific product with digital elements determines the product class and therefore the applicable conformity assessment procedure

> 图5：说明某一具体含数字元素产品的核心功能如何决定产品类别并因而决定适用的合格评定程序



图中文字对照（只译图内已有文字，不增补说明）

Determines conformity assessment (CA) procedure	决定合格评定（CA）程序
Core functionality of important or critical product category	重要或关键产品类别的核心功能
Core functionality of a specific product	某一具体产品的核心功能
Ancillary functionality 1 (calculator)	辅助功能1（计算器）
Ancillary functionality 2 (graphics editor)	辅助功能2（图形编辑器）
Ancillary functionality 3 (text editor)	辅助功能3（文本编辑器）
If not equal, then default category	如果不相等，则为默认类别
If equal, then important or critical	如果相等，则为重要或关键
Ancillary functionality	辅助功能

145. Some products with digital elements are placed on the market as single products with digital elements but are composed of distinct modules with separate functionalities. Where a manufacturer also makes those modules available on the market separately, such as in the case where they are offered for separate purchase, licensing or subscription, those modules constitute standalone products with digital elements in their own right. As such, they are to be classified on the basis of their respective core functionalities (and therefore subject to the appropriate conformity assessment regime on the

basis of each module's core functionality). This is without prejudice to modules supplied solely as components of an integrated product with digital elements and not made available separately; in such cases, the core functionality is determined at the level of the integrated product with digital elements. Example 61: a manufacturer places on the market a unified security suite combining multiple modules, including a SIEM, an intrusion detection system, and an analytics module. The manufacturer also offers those modules for separate subscriptions. In this scenario, each module is a distinct product with digital elements and is classified on the basis of its own core functionality. The SIEM module is subject to the conformity assessment regime for important products with digital elements of class I, as its core functionality is that of 'Security information and event management (SIEM) systems'. The intrusion detection system is subject to the conformity assessment regime for important products with digital elements of class II, as its core functionality is that of 'Firewalls, intrusion detection and prevention systems'. The analytics module is subject to the conformity assessment regime for 'default' products with digital elements, as its core functionality is not that of an important or critical product category.

> 某些含数字元素产品作为单一含数字元素产品被投放市场，但由具有各自功能的不同模块组成。如果制造商也将这些模块单独在市场上提供，例如在它们被提供以供单独购买、许可或订阅的情况下，这些模块本身构成独立的含数字元素产品。因此，它们应当根据各自的核心功能分类（并因而根据每一模块的核心功能受适当的合格评定制度约束）。这不影响仅作为集成含数字元素产品的组件供应、且并未单独在市场上提供的模块；在此类情况下，核心功能在集成含数字元素产品的层面确定。示例61：某制造商投放一款统一安全套件，组合多个模块，包括SIEM、入侵检测系统和分析模块。制造商也提供这些模块以供单独订阅。在这一情形中，每一模块都是不同的含数字元素产品，并根据其自己的核心功能分类。SIEM模块受I类重要含数字元素产品的合格评定制度约束，因为其核心功能是“安全信息与事件管理（SIEM）系统”的核心功能。入侵检测系统受II类重要含数字元素产品的合格评定制度约束，因为其核心功能是“防火墙、入侵检测和防御系统”的核心功能。分析模块受“默认”含数字元素产品的合格评定制度约束，因为其核心功能不是某一重要或关键产品类别的核心功能。

146. Non-compliance with the obligations set out in Article 32 of the CRA may trigger administrative fines in accordance with Article 64(3).

> 不遵守CRA第32条所规定的义务，可以根据第64条第3款引发行政罚款。

6.2 Conformity assessment for important and critical products with digital elements
6.2 重要和关键含数字元素产品的合格评定

147. Once the manufacturer has determined the core functionality of its product with digital elements, it needs to perform one of the applicable conformity assessment procedures. The manufacturer needs to ensure that the product with digital elements as a whole meets the essential requirements, considering, as appropriate, the security of the components or functionalities integrated into it.

> 一旦制造商确定了其含数字元素产品的核心功能，它需要实施适用的合格评定程序之一。制造商需要确保作为整体的含数字元素产品符合基本要求，并在适当情况下考虑集成于其中的组件或功能的安全。

148. A more stringent conformity assessment procedure, with the involvement of a third-party (based on module B+C, module H or cybersecurity certification schemes) is mandatory for important products with digital elements of class II (with the exception of those qualifying as free and open-source software, in accordance with Article 32(5)) and for critical products with digital elements24. By contrast, important products with digital elements of class I (with the exception of those qualifying as free and open-source software, in accordance with Article 32(5)) are required to undergo a third-party conformity assessment procedure only if the manufacturer has not applied or has applied only in part relevant harmonised standards the references of which have been published in the Official Journal of the European Union (henceforth, 'harmonised standards'), common specifications or European cybersecurity certification schemes at assurance level at least 'substantial' 25.

有第三方参与的更严格合格评定程序（基于模块B+C、模块H或网络安全认证计划）对于II类重要含数字元素产品（根据第32条第5款，符合自由及开源软件条件的除外）以及关键含数字元素产品是强制性的24。相反，I类重要含数字元素产品（根据第32条第5款，符合自由及开源软件条件的除外）仅在制造商未适用或仅部分适用其引用已在《欧盟官方公报》上公布的相关协调标准（以下简称“协调标准”）、通用规范或保证等级至少为“较高”（substantial）的欧洲网络安全认证计划时，才必须接受第三方合格评定程序25。

149. Therefore, for an important product with digital elements of class I to be eligible for the internal control procedure, (i) all the applicable requirements of a relevant harmonised standard need to be applied; and (ii) the standard’s scope needs to cover at least all the cybersecurity risks associated to that product’s core functionality.

因此，I类重要含数字元素产品要有资格适用内部控制程序，需要：(i) 适用相关协调标准的所有适用要求；并且(ii) 该标准的范围至少涵盖与该产品核心功能相关的所有网络安全风险。

150. The scope of the product with digital elements may be broader than the scope foreseen by the relevant harmonised standard, and such additional functions may present different or additional cybersecurity risks. The manufacturer is always required to carry out a risk assessment pursuant to Article 13(2) and should consequently check whether implementing a harmonised standard covers all risks associated with the product with digital elements. Where implementing the standard does not cover all risks, the manufacturer should ensure via other means that its product with digital elements is in compliance with the essential requirements.

含数字元素产品的范围可能宽于相关协调标准所预见的范围，并且此类额外功能可能呈现不同的或额外的网络安全风险。制造商始终必须根据第13条第2款开展风险评估，并因而应当核查实施某一协调标准是否涵盖与该含数字元素产品相关的所有风险。如果实施该标准并未涵盖所有风险，制造商应当通过其他手段确保其含数字元素产品符合基本要求。

151. Therefore, if the manufacturer of an important product with digital elements of class I has applied a relevant harmonised standard that covers the risks associated to that product’s core functionality, it can decide to make use of the internal control procedure to demonstrate its product’s conformity. As part of its conformity assessment activities, the manufacturer will still be required to demonstrate that all risks applicable to its product with digital elements are addressed. Hence, where there is a gap between the coverage of the harmonised standard and the scope of the product with digital elements as a whole, the manufacturer still needs to document which additional measures it has put in place to treat those risks. Example 62: An antivirus software has the core functionality of software that searches for, removes, or quarantines malicious software, as described in Annex I, point 4, to Implementing Regulation (EU) 2025/2392. That product with digital elements also includes additional features, namely a disk-cleaning function and an anti-tracking function protecting the user when navigating on the web. The manufacturer carries out a risk assessment covering the product with digital elements in its entirety, including the antivirus’s core functionality, the disk-cleaning and the anti-tracking functions. It applies a harmonised standard covering the risks associated with the antivirus’s core functionality, and additional measures to deal with risks stemming from additional functions. The manufacturer is allowed to make use of the internal control procedure for its conformity assessment, covering the product with digital elements as a whole, including the disk-cleaning and the anti-tracking functions.

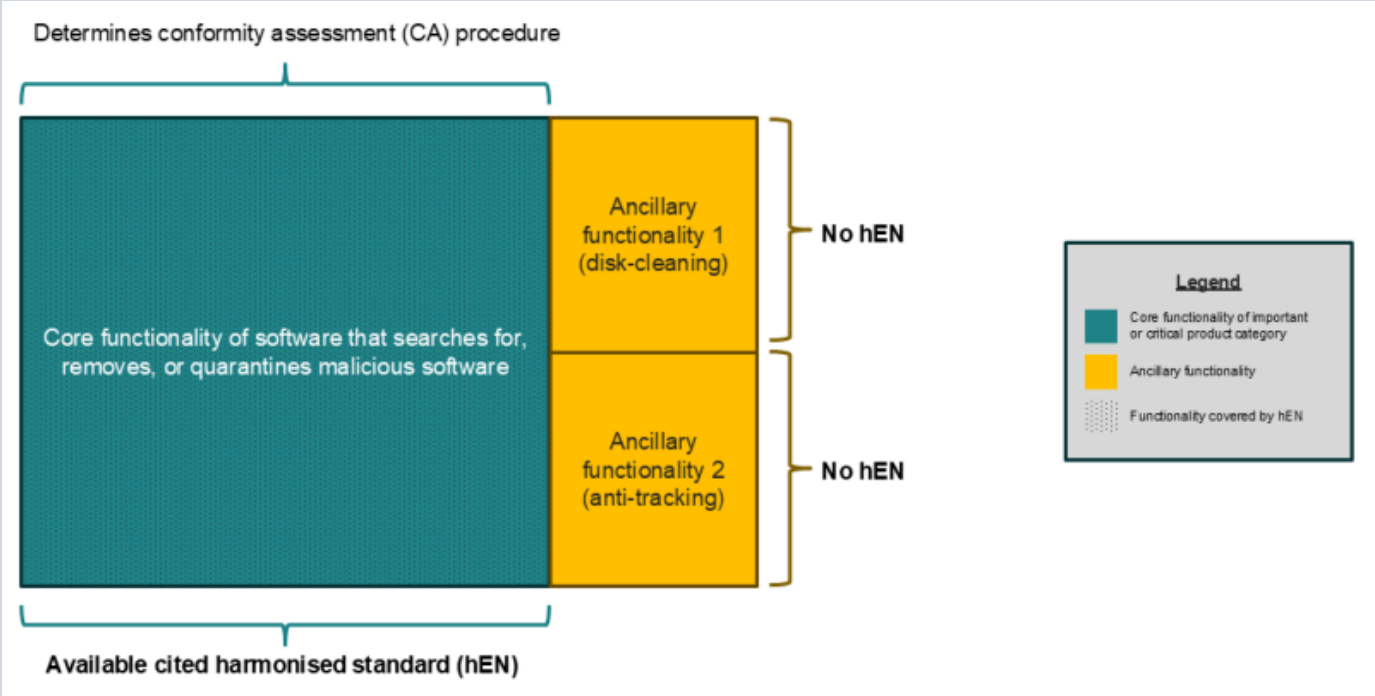
因此，如果I类重要含数字元素产品的制造商已经适用涵盖与该产品核心功能相关风险的相关协调标准，它可以决定使用内部控制程序来证明其产品的符合。作为其合格评定活动的一部分，制造商仍然必须证明适用于其含数字元素产品的所有风险都得到处理。因此，在协调标准的覆盖范围与作为整体的含数字元素产品的范围之间存在差距的情况下，制造商仍然需要记录其为处理这些风险而采取的额外措施。示例62：一款防病毒软件具有搜索、清除或隔离恶意软件的软件的核心功能，如实施条例(EU) 2025/2392附件I第4点所述。该含数字元素产品还包括额外特性，即磁盘清理功能以及在用户浏览网页时保护用户的反跟踪功能。制造商开展涵盖含数字元素产品整体的风险评估，包括防病毒软件的核心功能、磁盘清理功能和反跟踪功能。它适用涵盖与防病毒软件核心功能相关风险的协调标准，并采取额外措施处理源于额外功能的风险。制造商被允许就其合格评定使用内部控制程序，涵盖作为整体的含数字元素产品，包括磁盘清理功能和反跟踪功能。

24 This is also the case when making use of a European cybersecurity certification scheme with an assurance level at least 'substantial', as the involvement of a third-party certification body is required. 25 For brevity's sake, the remainder of this section only refers to harmonised standards the references of which have been published in the Official Journal of the European Union. However, the same guidance also applies to common specifications adopted in accordance with Article 27(2) and to European cybersecurity certification schemes where specified by the Commission via delegated acts in accordance with Article 27(9).

> 24 在使用保证等级至少为“较高”（substantial）的欧洲网络安全认证计划时亦同，因为需要第三方认证机构的参与。25 为求简略，本节其余部分仅提及引用已在《欧盟官方公报》上公布的协调标准。然而，同一指导也适用于根据第27条第2款通过的通用规范，以及委员会根据第27条第9款通过授权法案予以指明的欧洲网络安全认证计划。

Figure 6: Illustration of how the use of a cited harmonised standard covering only core functionality determines the applicable conformity assessment procedure

> 图6：说明使用仅涵盖核心功能的已引用协调标准如何决定适用的合格评定程序



图中文字对照（只译图内已有文字，不增补说明）

Determines conformity assessment (CA) procedure	决定合格评定（CA）程序
Core functionality of software that searches for, removes, or quarantines malicious software	搜索、清除或隔离恶意软件的软件的核心功能
Ancillary functionality 1 (disk-cleaning)	辅助功能1（磁盘清理）
Ancillary functionality 2 (anti-tracking)	辅助功能2（反跟踪）
No hEN	无协调标准（hEN）
Available cited harmonised standard (hEN)	已有被引用的协调标准（hEN）
Functionality covered by hEN	协调标准所涵盖的功能

152. This is also the case where the product with digital elements integrates an additional function that is itself that of another important or critical product with digital elements. In fact, it is the core functionality of the product with digital elements as a whole, and not the functionality of the integrated components taken in isolation, that determines whether the product with digital elements belongs to the important or critical product category (and therefore the applicable conformity assessment regime). For example, if a product with digital elements has the core functionality of an important product with digital elements of class I, that product as a whole is subject to the conformity assessment regime applicable to important products with digital elements of class I, even though it integrates a component that is itself a critical product

with digital elements. In these cases, where the manufacturer applies a harmonised standard covering the risks associated to that product's core functionality, it is allowed to make use of the internal control procedure. Example 63: A hardware product with digital elements has the core functionality of a router, as described in Annex I, point 12, to Implementing Regulation (EU) 2025/2392. That product with digital elements also includes additional functionalities, including firewalling capabilities, as it integrates a firewall component. The manufacturer carries out a risk assessment covering the product with digital elements in its entirety, including the router's core functionality and the firewall functionality. It applies a harmonised standard covering the risks associated with the router's core functionality, and additional measures to deal with risks stemming from additional functions. For instance, the manufacturer may apply the harmonised standard for firewalls to cover the risks associated with the firewall functionality. The manufacturer is allowed to make use of the internal control procedure for its conformity assessment, covering the product with digital elements as a whole, including the firewall functionality.

> 含数字元素产品集成本身属于另一种重要或关键含数字元素产品之功能的额外功能时，亦同。事实上，决定含数字元素产品是否属于重要或关键产品类别（并因而决定适用的合格评定制度）的，是作为整体的含数字元素产品的核心功能，而不是孤立看待的集成组件的功能。例如，如果含数字元素产品具有I类重要含数字元素产品的核心功能，则该产品整体受适用于I类重要含数字元素产品的合格评定制度约束，即使它集成了本身属于关键含数字元素产品的组件。在这些情况下，如果制造商适用涵盖与该产品核心功能相关风险的协调标准，则被允许使用内部控制程序。示例63：一款含数字元素硬件产品具有路由器的核心功能，如实施条例(EU) 2025/2392附件I第12点所述。该含数字元素产品还包括额外功能，包括防火墙功能，因为它集成了防火墙组件。制造商开展涵盖含数字元素产品整体的风险评估，包括路由器的核心功能和防火墙功能。它适用涵盖与路由器核心功能相关风险的协调标准，并采取额外措施处理源于额外功能的风险。例如，制造商可以适用防火墙的协调标准，以涵盖与防火墙功能相关的风险。制造商被允许就其合格评定使用内部控制程序，涵盖作为整体的含数字元素产品，包括防火墙功能。

6.3 Implications for presumption of conformity
6.3 对符合性推定的影响

153. Article 27(1) of the CRA establishes that products with digital elements and processes put in place by the manufacturer which are in conformity with harmonised standards or parts thereof, the references of which have been published in the Official Journal of the European Union (OJEU), are presumed to be in conformity with the essential requirements of the CRA covered by those standards or parts thereof 26. Article 27(5) extends the same presumption of conformity to products with digital elements and processes put in place by the manufacturer which are in conformity with common specifications adopted by the Commission via implementing acts, and Article 27(8) establishes the presumption of conformity for products with digital elements and processes put in place by the manufacturer for which an EU statement of conformity or certificate has been issued under a European cybersecurity certification scheme adopted pursuant to Regulation (EU) 2019/881, if this has been specified via delegated acts in accordance with Article 27(9) 27.

> CRA第27条第1款规定，符合协调标准或其部分的含数字元素产品以及制造商所建立的流程，如这些标准或其部分的引用已在《欧盟官方公报》（OJEU）上公布，则推定符合这些标准或其部分所涵盖的CRA基本要求26。第27条第5款将同一符合性推定扩展到符合委员会通过实施法案通过的通用规范的含数字元素产品以及制造商所建立的流程，第27条第8款规定，对于已根据条例(EU) 2019/881通过的欧洲网络安全认证计划签发欧盟符合性声明或证书的含数字元素产品以及制造商所建立的流程，如果这一点已根据第27条第9款通过授权法案予以指明，则确立符合性推定27。

154. Therefore, where the manufacturer has applied a harmonised standard whose references have been published in the OJEU, it benefits from a presumption of conformity for the risks covered by that standard. This could be the case, for example, where the referenced harmonised standard addresses all the risks associated with the core functionality of a product with digital elements and there are no additional functionalities that present cybersecurity risks. For instance, it is expected that the harmonised standard for routers will address at least the risks associated with the core functionality of these products with digital elements. If such a product does not contain any additional functionalities or if these additional

functionalities do not present risks unaddressed by the standard, the product with digital elements can benefit from presumption of conformity.

> 因此，如果制造商已经适用其引用已在《欧盟官方公报》上公布的协调标准，则它就该标准所涵盖的风险享有符合性推定。例如，所引用的协调标准处理与含数字元素产品核心功能相关的所有风险，并且没有呈现网络安全风险的额外功能，即可能如此。例如，预期路由器的协调标准将至少处理与这些含数字元素产品的核心功能相关的风险。如果此类产品不包含任何额外功能，或者这些额外功能并不呈现该标准未处理的风险，则该含数字元素产品可以享有符合性推定。

26 As clearly stated in Section 4.1.2.2 of the Blue Guide, 'in risk related harmonisation legislation [...] manufacturers always, even when using harmonised standards the references of which are published in the OJEU, remain fully responsible for assessing all the risks of their product in order to determine which essential (or other) requirements are relevant. After this assessment a manufacturer may then choose to apply technical specifications given in harmonised standards the references of which are published in the OJEU to implement 'risk reduction measures' which are specified by harmonised standards'. 27 As above, for brevity's sake, the remainder of this section only refers to harmonised standards the references of which have been published in the OJEU. However, the same guidance also applies to common specifications and to European cybersecurity certification schemes.

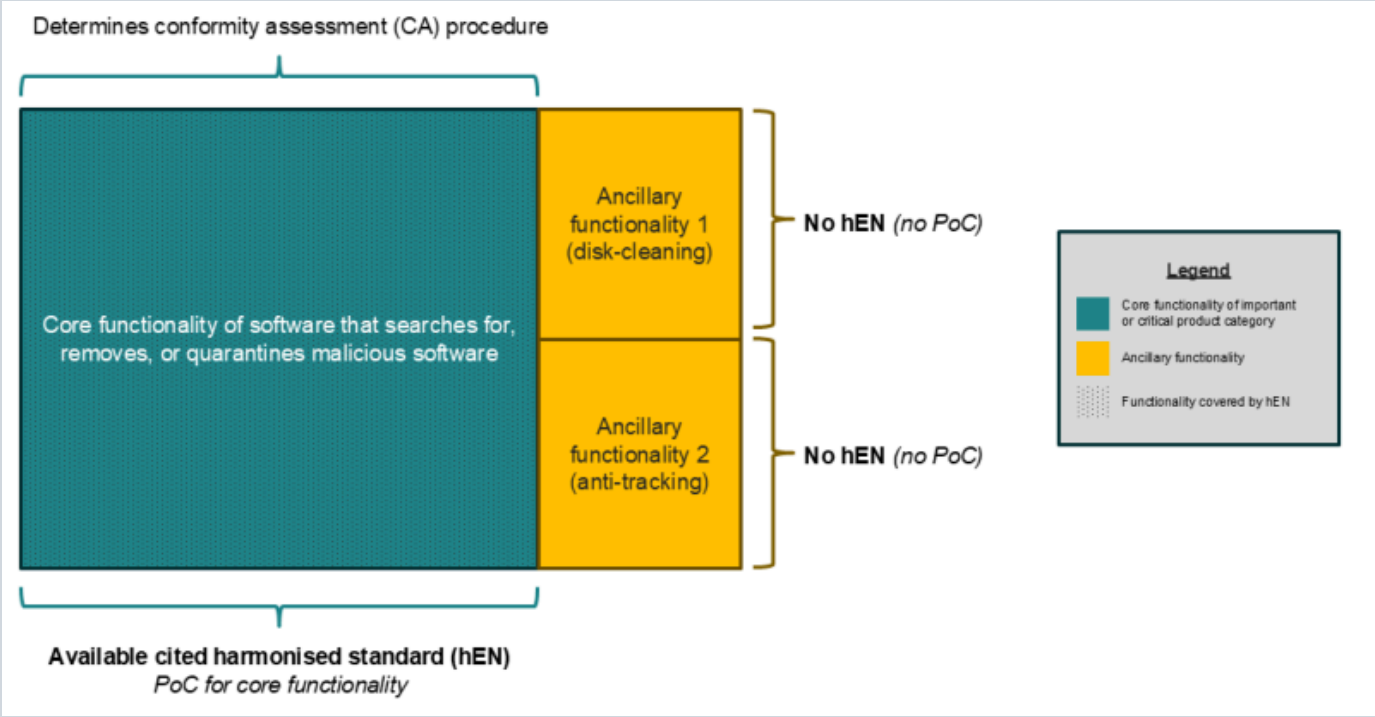
> 26 正如《蓝皮书》第4.1.2.2节所明确表述的，“在与风险有关的协调立法中[……]，制造商始终——即使在使用其引用已在《欧盟官方公报》上公布的协调标准时——仍然对评估其产品的所有风险负全部责任，以确定哪些基本（或其他）要求是相关的。在这一评估之后，制造商随后可以选择适用其引用已在《欧盟官方公报》上公布的协调标准中给出的技术规范，以实施协调标准所规定的‘风险降低措施’”。27 如上所述，为求简略，本节其余部分仅提及引用已在《欧盟官方公报》上公布的协调标准。然而，同一指导也适用于通用规范以及欧洲网络安全认证计划。

155. In the cases discussed in points 151 and 152, the manufacturer is allowed to use the internal control procedure because the harmonised standard covers the risks associated with the core functionality of the product with digital elements. However, the products with digital elements described in those examples may be broader than the scope of the harmonised standards, and additional functionalities may present cybersecurity risks that are not addressed by such harmonised standard. Those products with digital elements may therefore not benefit from presumption of conformity for those additional functionalities. Example 64: An antivirus software has the core functionality of software that searches for, removes, or quarantines malicious software, and risks associated with that core functionality are covered by the harmonised standard. That product with digital elements also includes additional functionalities, namely a disk-cleaning function and an anti-tracking functionality protecting the user when navigating on the web, whose risks are not covered by the harmonised standard. If the harmonised standard is applied, the manufacturer is allowed to make use of the internal control procedure for its conformity assessment. It will benefit from presumption of conformity for the risks associated with that product's core functionality, but not for the risks associated with additional functionalities.

> 在第151点和第152点所讨论的情形中，制造商被允许使用内部控制程序，因为协调标准涵盖与含数字元素产品核心功能相关的风险。然而，这些示例中所述的含数字元素产品可能宽于协调标准的范围，并且额外功能可能呈现此类协调标准未处理的网络安全风险。因此，这些含数字元素产品可能不就这些额外功能享有符合性推定。示例64：一款防病毒软件具有搜索、清除或隔离恶意软件的软件的核心功能，与该核心功能相关的风险由协调标准涵盖。该含数字元素产品还包括额外功能，即磁盘清理功能以及在用户浏览网页时保护用户的反跟踪功能，其风险未被该协调标准涵盖。如果适用该协调标准，制造商被允许就其合格评定使用内部控制程序。它将就与该产品核心功能相关的风险享有符合性推定，但不就与额外功能相关的风险享有符合性推定。

Figure 7: Harmonised standard grants presumption of conformity (PoC) for core functionality, as it addresses all risks associated with that core functionality, but not for ancillary functionalities

> 图7：协调标准对核心功能给予符合性推定（PoC），因为它处理与该核心功能相关的所有风险，但不对辅助功能给予符合性推定



图中文字对照（只译图内已有文字，不增补说明）

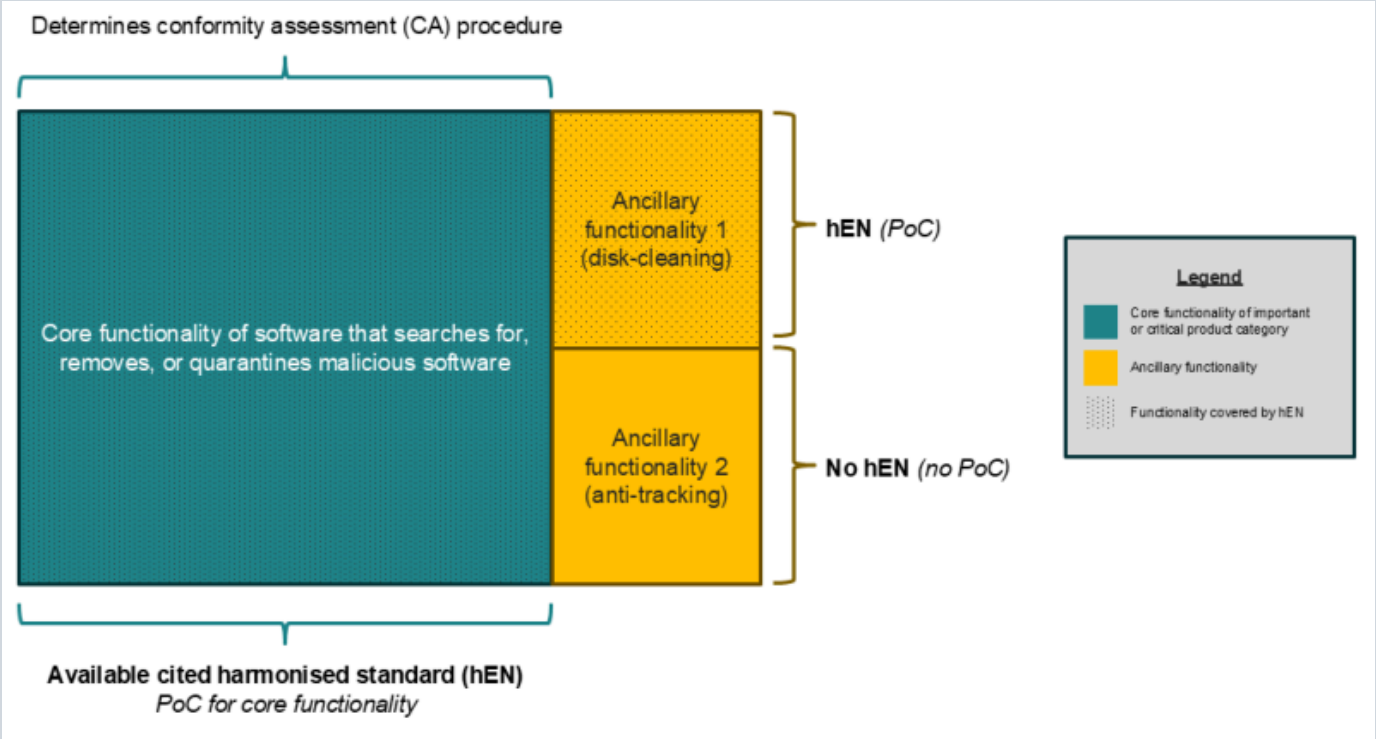
No hEN (no PoC)	无协调标准（无符合性推定）
Available cited harmonised standard (hEN)	已有被引用的协调标准（hEN）
PoC for core functionality	对核心功能的符合性推定
Ancillary functionality 1 (disk-cleaning)	辅助功能1（磁盘清理）
Ancillary functionality 2 (anti-tracking)	辅助功能2（反跟踪）

Example 65: In the same scenario as the previous example, the harmonised standard has now been updated to also cover risks associated with one of the additional functionalities, namely the disk-cleaning function, but not the other (i.e. the anti-tracking function). If the harmonised standard is applied, the manufacturer is allowed to make use of the internal control procedure for its conformity assessment. It will benefit from a presumption of conformity for the risks associated with that product's core functionality and for the disk-cleaning functionality, but not for the risks related to the anti-tracking functionality.

> 示例65：在与上一示例相同的情形中，协调标准现已更新，也涵盖与额外功能之一相关的风险，即磁盘清理功能，但不涵盖另一功能（即反跟踪功能）。如果适用该协调标准，制造商被允许就其合格评定使用内部控制程序。它将就与该产品核心功能相关的风险以及磁盘清理功能享有符合性推定，但不就与反跟踪功能相关的风险享有符合性推定。

Figure 8: Harmonised standard grants PoC for core functionality and ancillary functionality 1, as it addresses all risks associated with those two functionalities, but not for ancillary functionality 2

> 图8：协调标准对核心功能和辅助功能1给予符合性推定（PoC），因为它处理与这两项功能相关的所有风险，但不对辅助功能2给予符合性推定



图中文字对照（只译图内已有文字，不增补说明）

hEN (PoC)	协调标准（符合性推定）
No hEN (no PoC)	无协调标准（无符合性推定）
PoC for core functionality	对核心功能的符合性推定
Ancillary functionality 1 (disk-cleaning)	辅助功能1（磁盘清理）
Ancillary functionality 2 (anti-tracking)	辅助功能2（反跟踪）

7 Cybersecurity risk assessment and integration of products with digital elements and components
7 网络安全风险评估以及含数字元素产品和组件的集成

7.1 On the evaluation and treatment of cybersecurity risks
7.1 关于网络安全风险的评估和处理

156. The cybersecurity risk assessment provided for in Article 13(2) of the CRA requires manufacturers to identify relevant risks and assess their potential impact on the product with digital elements. Manufacturers also need to implement appropriate measures to address those risks, in accordance with the essential requirements of Annex I.

> CRA第13条第2款所规定的网络安全风险评估，要求制造商识别相关风险并评估其对含数字元素产品的潜在影响。制造商还需要根据附件I的基本要求，实施适当措施以处理这些风险。

157. In organisational risk management, risks are commonly evaluated against acceptance criteria derived from the organisation’s internal objectives or risk appetite. By contrast, under the CRA, residual cybersecurity risk should be assessed in light of the requirement that the product with digital elements placed on the market ensures an appropriate level of cybersecurity based on the risks, taking into account its intended purpose and reasonably foreseeable use.

> 在组织风险管理中，风险通常对照源自该组织内部目标或风险偏好的接受标准来评估。相反，在CRA项下，剩余网络安全风险应当结合如下要求来评估：投放市场的含数字元素产品基于风险确保适当的网络安全水

> 平，同时考虑其预期用途和可合理预见的使用。

158. Accordingly, the manufacturer’s internal risk tolerance, commercial strategy or mere cost considerations are not relevant in determining whether risks have been addressed. For the purposes of Articles 13(2) and (3), manufacturers must be in a position to determine whether identified cybersecurity risks have been sufficiently addressed through the implementation of the essential requirements of Part I of Annex I, in light of the intended purpose, reasonably foreseeable use and conditions of use, including, where relevant, the operational environment (for example the intended users of the product with digital elements) and the assets to be protected, taking into account the length of time the product with digital elements is expected to be in use.

> 因此，制造商的内部风险容忍度、商业策略或单纯的成本考虑，在确定风险是否已得到处理时不具相关性。就第13条第2款和第3款而言，制造商必须能够确定，已识别的网络安全风险是否已通过实施附件I第一部分的基本要求而得到充分处理，同时考虑预期用途、可合理预见的使用和使用条件，包括在相关情况下的运行环境（例如含数字元素产品的预期用户）和拟保护的资产，并考虑含数字元素产品预期被使用的时间长度。

159. Residual cybersecurity risk is an inherent outcome of risk assessment and risk treatment. It is recognised that cybersecurity risks cannot, in practice, be entirely eliminated. However, the existence of residual risk does not imply that any risk may be accepted at the manufacturer’s discretion. A product with digital elements may only be placed on the market where the residual risks, once appropriate measures have been taken, have been sufficiently addressed through the implementation of the essential requirements, taking into account the intended purpose and reasonably foreseeable use of the product with digital elements.

> 剩余网络安全风险是风险评估和风险处理的固有结果。人们承认，网络安全风险在实践中不能被完全消除。然而，剩余风险的存在并不意味着任何风险都可以由制造商酌情接受。只有在采取适当措施之后，剩余风险已通过实施基本要求而得到充分处理，并考虑含数字元素产品的预期用途和可合理预见的使用时，含数字元素产品才可以被投放市场。

160. In accordance with Article 13(3), where cybersecurity risks are identified, manufacturers are required to address them through appropriate measures, including at product level. Depending on the circumstances, this may involve for example reducing the attack surface, implementing technical safeguards, limiting or adapting functionality, or defining the intended purpose of the product with digital elements more precisely. Manufacturers may also take steps to shape the reasonably foreseeable use of the product with digital elements, for instance through risk communication, user guidance, or user interface design, in order to steer user behaviour toward secure use patterns.

> 根据第13条第3款，在识别出网络安全风险的情况下，制造商必须通过适当措施处理它们，包括在产品层面。视情况而定，这可以包括例如缩小攻击面、实施技术保障措施、限制或调整功能，或更精确地界定含数字元素产品的预期用途。制造商也可以采取措施塑造含数字元素产品的可合理预见的使用，例如通过风险沟通、用户指导或用户界面设计，以将用户行为引导向安全的使用模式。

161. The CRA does not provide for the transfer of cybersecurity risk or responsibility to users or third parties to compensate for shortcomings in product design or to justify leaving cybersecurity risks unaddressed. The obligation to place a secure product with digital elements on the market and to demonstrate conformity with the essential requirements remains with the manufacturer.

> CRA并不规定将网络安全风险或责任转移给用户或第三方，以弥补产品设计中的不足，或为使网络安全风险得不到处理提供理由。将安全的含数字元素产品投放市场并证明符合基本要求的义务，仍然由制造商承担。

162. Information and instructions provided to users may be used to support the secure deployment and operation of the product with digital elements, including where the manufacturer has chosen to restrict the intended purpose of that product to trusted environments, and to inform users of residual risks, in a manner that is appropriate to the nature of the product with digital elements and its intended users. Example 66: A manufacturer develops an industrial sensor for use in trusted

environments. For the sensor to perform its functionality correctly, the manufacturer does not implement measures to protect against physical attacks on the sensor itself. To mitigate the associated risks identified in the risk assessment, the manufacturer limits the sensor's intended purpose to use only in trusted environments where unauthorised physical access to the product with digital elements is prevented. Information and instructions to the users provide clear information on these limitations on the sensor's use, in a manner that is appropriate to the nature of the product with digital elements and its intended users. Example 67: A manufacturer develops a software application for professional use on managed desktop and mobile devices. The application processes locally stored sensitive data and user-generated content. During the risk assessment, the manufacturer identifies the risk of unauthorised access to such data if they are stored in clear text on the device. Rather than designing and implementing a proprietary encryption mechanism within the application itself, the manufacturer chooses to rely on the encryption and key management functions provided natively by the operating system on which the application is intended to run, as the operating system's built-in cryptographic services are mature and regularly maintained.

> 向用户提供的信息和说明，可以用于支持含数字元素产品的安全部署和运行，包括制造商已选择将该产品的预期用途限制于可信环境的情形，并以便宜于含数字元素产品的性质及其预期用户的方式告知用户剩余风险。示例66：某制造商开发一款供在可信环境中使用的工业传感器。为使该传感器正确履行其功能，制造商不实施保护传感器本身免受物理攻击的措施。为缓解风险评估中识别的相关风险，制造商将该传感器的预期用途限于仅在防止对含数字元素产品进行未经授权的物理访问的可信环境中使用。向用户提供的信息和说明，以便宜于含数字元素产品的性质及其预期用户的方式，就这些对该传感器使用的限制提供清晰信息。示例67：某制造商开发一款供在受管理的桌面和移动设备上专业使用的软件应用程序。该应用程序处理本地存储的敏感数据和用户生成的内容。在风险评估期间，制造商识别出如果这些数据以明文存储在设备上则可能被未经授权访问的风险。制造商并不在应用程序本身内设计和实施专有加密机制，而是选择依赖该应用程序拟在其上运行的操作系统原生提供的加密和密钥管理功能，因为该操作系统的内置密码服务已经成熟并得到定期维护。

163. Where the cybersecurity risk assessment identifies risks that cannot be adequately addressed through appropriate measures, compliance with the CRA may require changes to the design, functionality or intended purpose of the product with digital elements. Considerations relating solely to cost or commercial feasibility do not constitute sufficient grounds for leaving such risks untreated where this would prevent the product with digital elements from meeting the essential requirements.

> 如果网络安全风险评估识别出无法通过适当措施充分处理的风险，遵守CRA可能要求改变含数字元素产品的设计、功能或预期用途。仅与成本或商业可行性有关的考虑，并不构成使此类风险得不到处理的充分理由，如果这样做会妨碍含数字元素产品符合基本要求。

7.2 On designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks
7.2 关于以基于风险确保适当网络安全水平的方式设计、开发和生产含数字元素产品

164. The essential cybersecurity requirement referred to in point (1) of Part I of Annex I to the CRA provides that products with digital elements are designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

> CRA附件I第一部分第(1)点所指的基本网络安全要求规定，含数字元素产品的设计、开发和生产方式，应使其基于风险确保适当的网络安全水平。

165. This essential requirement is aimed at addressing all cybersecurity risks that have been identified as part of the cybersecurity risk assessment. Particularly, this includes cybersecurity risks that are not otherwise adequately addressed as part of the implementation of the essential requirements of Part I of Annex I other than point (1). This essential

requirement is different from the legal obligation to carry out a cybersecurity risk assessment, which is to be carried out pursuant to Article 13(2).

> 这一基本要求旨在处理作为网络安全风险评估一部分已被识别的所有网络安全风险。特别是，这包括在实施附件I第一部分第(1)点以外的基本要求时并未以其他方式得到充分处理的网络安全风险。这一基本要求不同于开展网络安全风险评估的法律义务，后者应当根据第13条第2款实施。

166. Where all relevant cybersecurity risks related to a product with digital elements are treated by implementing adequate measures to address the applicable essential requirements other than point (1), the essential requirement referred to in point (1) of Part I of Annex I is deemed to be fulfilled. Conversely, where the cybersecurity risk assessment identifies additional risks not fully addressed by such measures, manufacturers are required to implement appropriate measures on the product with digital elements to address those risks, so that they comply with the essential requirement referred to in point (1) of Part I of Annex I. In practice, in most cases, compliance with the other essential requirements is expected to result in compliance with this requirement.

> 如果与含数字元素产品相关的所有相关网络安全风险，都通过实施处理第(1)点以外适用基本要求的充分措施而得到处理，则附件I第一部分第(1)点所指的基本要求视为得到满足。相反，如果网络安全风险评估识别出此类措施并未充分处理的额外风险，制造商必须在含数字元素产品上实施适当措施以处理这些风险，从而符合附件I第一部分第(1)点所指的基本要求。在实践中，在大多数情况下，预期遵守其他基本要求将导致遵守这一要求。

7.3 Risk assessment and due diligence in relation to external dependencies and integrated components

7.3 关于外部依赖项和集成组件的风险评估与尽职调查

167. The CRA establishes two distinct but complementary obligations for manufacturers in relation to cybersecurity risk management. First, Article 13(2) requires manufacturers to carry out a cybersecurity risk assessment for the product with digital elements itself. Second, Article 13(5) imposes the obligation to exercise due diligence with respect to integrated components. Together, these two obligations are designed to ensure that the product with digital elements remains secure, including where it relies on remote data processing solutions, remote services, or third-party software or hardware components.

> CRA为制造商规定了与网络安全风险管理有关的两项不同但互补的义务。第一，第13条第2款要求制造商就含数字元素产品本身开展网络安全风险评估。第二，第13条第5款施加就集成组件开展尽职调查的义务。这两项义务共同旨在确保含数字元素产品保持安全，包括在它依赖远程数据处理解决方案、远程服务或第三方软件或硬件组件的情况下。

168. The cybersecurity risk assessment concerns the identification and management of relevant risks that may affect the product with digital elements, including risks that originate outside the product itself, such as external networks, environmental factors, or other external aspects which might affect the product with digital elements or on which the product relies. For such external risks, the CRA does not require manufacturers to control or govern the external environment. Rather, manufacturers are required to identify such risks and to mitigate them through the design and development of the product with digital elements itself. This will involve implementing the appropriate essential requirements set out in Part I of Annex I and, where necessary, providing information and instructions to users on integration or deployment risks.

> 网络安全风险评估涉及识别和管理可能影响含数字元素产品的相关风险，包括源于产品本身以外的风险，例如外部网络、环境因素，或其他可能影响含数字元素产品或该产品所依赖的外部方面。对于此类外部风险，CRA并不要求制造商控制或治理外部环境。相反，制造商必须识别此类风险，并通过含数字元素产品本身的

> 设计和开发来缓解它们。这将涉及实施附件I第一部分所载的适当基本要求，并在必要时向用户提供关于集成或部署风险的信息和说明。

169. For example, a manufacturer may identify a risk that unauthorised persons may gain access to back-end systems that are not part of the product with digital elements itself while the product is in operation, and attempt to send malicious commands to the product with digital elements. Such back-end systems, where they are not designed and developed by the manufacturer or under its responsibility, or where they do not support one of the functions of the product with digital elements, do not constitute remote data processing solutions and therefore fall outside the scope of the product with digital elements for the purposes of the CRA. Nonetheless, the CRA requires the manufacturer to address the risk they may pose through product-level measures, such as by requiring cryptographic authentication of remote commands, verifying the integrity of configuration changes, or generating security-relevant logs or alerts when abnormal behaviour is detected. Similarly, where a manufacturer identifies a risk resulting from such an external service becoming unavailable, for example due to power outages or failures of the infrastructure, the CRA may require product-level mitigation measures against such cybersecurity risks, e.g. ensuring that the outage does not cause the product with digital elements to enter into insecure states. In such cases, the CRA regulates how the product with digital elements responds to those external risks; it does not impose obligations on how the back-end infrastructure is organised, staffed or operated, nor does it treat that infrastructure as part of the product with digital elements.

> 例如，制造商可能识别出一项风险：未经授权的人可能在产品运行期间访问本身不属于含数字元素产品的后端系统，并试图向含数字元素产品发送恶意命令。如果此类后端系统并非由制造商或在其责任下设计和开发，或者并不支持含数字元素产品的功能之一，则它们不构成远程数据处理解决方案，因此就CRA而言不属于含数字元素产品的范围。尽管如此，CRA要求制造商通过产品层面的措施处理它们可能造成的风险，例如要求对远程命令进行密码认证、核验配置变更的完整性，或在检测到异常行为时生成与安全相关的日志或警报。同样，如果制造商识别出此类外部服务变得不可用所导致的风险，例如由于停电或基础设施故障，CRA可能要求针对此类网络安全风险采取产品层面的缓解措施，例如确保中断不会导致含数字元素产品进入不安全状态。在此类情况下，CRA规范含数字元素产品如何应对这些外部风险；它并不就后端基础设施如何组织、配备人员或运营施加义务，也不将该基础设施视为含数字元素产品的一部分。

170. Due diligence relates to elements that form part of the product with digital elements itself, in particular integrated software or hardware components provided by a third party. Manufacturers are required to take appropriate measures to ensure that such components do not undermine the compliance of the product with digital elements with the essential requirements. This can only be achieved by determining what the product with digital elements requires from its components in order to meet its cybersecurity objectives, and verifying, in a risk-based manner, that those components are in line with the product’s needs, as also indicated in recital 34.

> 尽职调查涉及构成含数字元素产品本身一部分的要素，特别是由第三方提供的集成软件或硬件组件。制造商必须采取适当措施，以确保此类组件不减损含数字元素产品对基本要求的符合。这只能通过确定含数字元素产品为达成其网络安全目标而对其组件的要求，并以基于风险的方式核验这些组件符合该产品的需要来实现，正如序言第34项亦所指出的。

171. In alignment with its cybersecurity risk assessment, the manufacturer has to identify the requirements that the integrated component should satisfy. For example, if the product with digital elements relies on cryptographic functions, update mechanisms or secure communications provided by a component, the manufacturer must, as part of its due diligence, identify those needs and verify that the component satisfies them. Evidence for this purpose may consist of documentation obtained from the component manufacturer, such as technical specifications, security documentation or relevant conformity or assurance documentation. Where appropriate, the manufacturer may also carry out tests to verify that those components adequately perform the relevant functions. While due diligence is a separate legal obligation, it supports and underpins the manufacturer’s ability to demonstrate compliance with the essential requirements for the product with digital elements as a whole.

> 与其网络安全风险评估相一致，制造商必须识别集成组件应当满足的要求。例如，如果含数字元素产品依赖某一组件提供的密码功能、更新机制或安全通信，制造商必须作为其尽职调查的一部分识别这些需要，并核验该组件满足它们。为此目的的证据可以包括从组件制造商取得的文件，例如技术规范、安全文件或相关符合或保证文件。在适当情况下，制造商也可以实施测试，以核验这些组件充分履行相关功能。尽管尽职调查是一项单独的法律义务，它支持并支撑制造商证明作为整体的含数字元素产品符合基本要求的能力。

172. When assessing the risks to the product with digital elements as a whole, elements outside of the product, such as environmental elements, external infrastructure, other systems or networks, must be considered in the cybersecurity risk assessment and, where relevant, addressed through product-level measures to ensure compliance of the product with digital elements with the essential requirements. Components that are physically or logically integrated into the product with digital elements but sourced from a third party must also be considered as part of the risk assessment. However, for compliance purposes, the manufacturer should treat those as externally supplied components whose properties are verified through due diligence upon integration, as the manufacturer may not have redesigned or redeveloped them.

> 在评估对作为整体的含数字元素产品的风险时，产品以外的要素，例如环境要素、外部基础设施、其他系统或网络，必须在网络安全风险评估中予以考虑，并在相关情况下通过产品层面的措施加以处理，以确保含数字元素产品符合基本要求。在物理上或逻辑上集成到含数字元素产品中、但来源于第三方的组件，也必须作为风险评估的一部分予以考虑。然而，就合规目的而言，制造商应当将这些组件作为外部供应的组件对待，其属性在集成时通过尽职调查加以核验，因为制造商可能并未重新设计或重新开发它们。

173. The same logic applies during the development and integration of components. Where the manufacturer develops functionalities itself, it must directly implement the essential requirements. Where the manufacturer integrates components developed by others, it must ensure through due diligence, that those components can be used in a way that enables the product with digital elements as a whole to comply. In both cases, the objective remains the same: that the product with digital elements, as placed on the market, achieves an appropriate level of cybersecurity as required by the CRA, taking into account the risks identified in the cybersecurity risk assessment.

> 同一逻辑适用于组件的开发和集成期间。如果制造商自己开发功能，它必须直接实施基本要求。如果制造商集成由他人开发的组件，它必须通过尽职调查确保这些组件能够以使作为整体的含数字元素产品得以合规的方式被使用。在两种情况下，目标保持相同：投放市场的含数字元素产品达到CRA所要求的适当网络安全水平，同时考虑网络安全风险评估中识别的风险。

7.4 Reuse of risk assessments and conformity documentation for families of products with digital elements

7.4 含数字元素产品族的风险评估和合格文件的再利用

174. Manufacturers may place on the market products with digital elements that are similar, for example different variants, models or configurations of the same product family. Where such products with digital elements share the same architecture, security-relevant design and intended purpose, and are exposed to the same cybersecurity risks, the CRA does not require manufacturers to treat each variant as an entirely separate product with digital elements for the purposes of risk assessment and conformity assessment.

> 制造商可以投放相似的含数字元素产品，例如同一产品族的不同变体、型号或配置。如果此类含数字元素产品具有相同的架构、与安全相关的设计和预期用途，并面临相同的网络安全风险，则CRA并不要求制造商就风险评估和合格评定的目的将每一变体作为完全单独的含数字元素产品对待。

175. In such cases, provided that all variants concerned are adequately covered in terms of relevant risks and essential requirements, manufacturers may rely on: (i) a single cybersecurity risk assessment carried out in accordance with Article 13(2) of the CRA; (ii) a single set of technical documentation; and (iii) a single conformity assessment procedure. This

also allows a single EU declaration of conformity to be issued for the group of products with digital elements, as long as it clearly identifies the product variants to which it applies.

> 在此类情况下，如果所涉全部变体在相关风险和基本要求方面都得到充分涵盖，制造商可以依赖：(i) 根据CRA第13条第2款开展的单一网络安全风险评估；(ii) 单一一套技术文件；以及(iii) 单一合格评定程序。这也允许就该组含数字元素产品签发单一欧盟符合性声明，只要它清楚识别其所适用的产品变体。

176. The decisive factor is whether the differences between the variants are relevant to cybersecurity. Variations that do not affect the cybersecurity properties of the product with digital elements, such as differences in colour, form factor, memory size, or other non-security-relevant characteristics, do not require separate risk assessments or conformity assessments. Conversely, in some cases variants may differ in ways that affect the implementation of essential requirements, for example through different communication interfaces, software stacks, update mechanisms or remote connectivity. In such cases, those differences must be reflected in the risk assessment and, where necessary, in the conformity assessment and technical documentation.

> 决定性因素是各变体之间的差异是否与网络安全相关。不影响含数字元素产品网络安全属性的差异，例如颜色、外形规格、内存大小或其他与安全无关的特性的差异，不要求单独的风险评估或合格评定。相反，在某些情况下，变体可能以影响基本要求之实施的方式有所不同，例如通过不同的通信接口、软件栈、更新机制或远程连接。在此类情况下，这些差异必须在风险评估中反映，并在必要时在合格评定和技术文件中反映。

177. Manufacturers remain responsible for ensuring that the risk assessment and the related documentation accurately reflect the products with digital elements placed on the market. Where a new variant introduces new cybersecurity risks or changes the way essential requirements are implemented, the existing risk assessment and conformity documentation must be updated accordingly. Reliance on a single conformity assessment is only possible to the extent that the products with digital elements do not present differences with regards to their cybersecurity properties.

> 制造商仍然负责确保风险评估和相关文件准确反映所投放市场的含数字元素产品。如果新变体引入新的网络安全风险或改变基本要求的实施方式，既有风险评估和合格文件必须相应更新。仅在含数字元素产品在其网络安全属性方面不呈现差异的范围内，才可以依赖单一合格评定。

8 Remote data processing
8 远程数据处理

178. Article 3(1) of the CRA defines a product with digital elements as ‘a software or hardware product and its remote data processing solutions, including software or hardware components being placed on the market separately’. In this light, the manufacturer must consider the product with digital elements as a whole, including its remote data processing solutions (RDPS). For instance, when demonstrating that the product with digital elements complies with the essential requirements laid out in Annex I, RDPS must be taken into account, starting with the risk assessment (Article 13(2)). The same is valid when considering lifecycle obligations, such as reporting of actively exploited vulnerabilities and severe incidents (Article 14).

> CRA第3条第1款将含数字元素产品定义为“软件或硬件产品及其远程数据处理解决方案，包括被单独投放市场的软件或硬件组件”。据此，制造商必须将含数字元素产品作为整体考虑，包括其远程数据处理解决方案（RDPS）。例如，在证明含数字元素产品符合附件I所载基本要求时，必须考虑RDPS，并从风险评估开始（第13条第2款）。在考虑生命周期义务时亦同，例如报告已遭积极利用的漏洞和严重事件（第14条）。

179. The purpose of this guidance is to provide further support to manufacturers in determining whether their product with digital elements has RDPS as defined in the CRA and how to fulfil their compliance obligations in this regard. After an initial analysis of the definitions and recitals laid down in the CRA, this guidance will provide questions to guide manufacturers in clarifying if their product with digital elements includes RDPS (see Section 8.1 What is considered a

remote data processing solution for a product with digital elements?). Subsequently, it will elaborate on the technical implications of RDPS and how to assess compliance with the CRA (see Section 8.2 Practical and technical implications of remote data processing solutions and reliance on third-party solutions).

> 本指南的目的是进一步支持制造商确定其含数字元素产品是否具有CRA所定义的RDPS，以及如何就此履行其合规义务。在初步分析CRA所载定义和序言之后，本指南将提出问题，以指导制造商澄清其含数字元素产品是否包含RDPS（见第8.1节“何为含数字元素产品的远程数据处理解决方案？”）。随后，本指南将阐述RDPS的技术影响以及如何评估对CRA的遵守（见第8.2节“远程数据处理解决方案以及依赖第三方解决方案的实际和技术影响”）。

180. In fact, Article 3(2) defines the concept of ‘remote data processing’ as ‘data processing at a distance for which the software is designed and developed by the manufacturer, or under the responsibility of the manufacturer, and the absence of which would prevent the product with digital elements from performing one of its functions’. RDPS is therefore defined as the software elements (‘the part of an electronic information system which consists of computer code’, as defined in Article 3(4)) of data processing at a distance. It is not meant to include, as part of the scope of the product with digital elements, the hardware that remote data processing may rely upon.

> 事实上，第3条第2款将“远程数据处理”这一概念定义为“远程进行的数据处理，其软件由制造商或在制造商的责任下设计和开发，并且如果没有该数据处理，含数字元素产品将无法履行其功能之一”。因此，RDPS被定义为远程数据处理的软件要素（即第3条第4款所定义的“由计算机代码组成的电子信息系统的部分”）。它并不意在将远程数据处理可能依赖的硬件纳入含数字元素产品的范围。

181. Recitals 11 and 12 give further explanations on how this concept should be interpreted. Recital 11 clarifies that the goal of covering remote data processing solution is that ‘products are adequately secured in their entirety by their manufacturers, irrespective of whether data is processed or stored locally on the user’s device or remotely by the manufacturer’. It also states that ‘requirements concerning the remote data processing solutions falling within the scope of this Regulation do therefore not entail technical, operational or organisational measures aiming to manage the risks posed to the security of a manufacturer’s network and information systems as a whole.’

> 序言第11项和第12项就这一概念应当如何解释给出了进一步说明。序言第11项澄清，涵盖远程数据处理解决方案的目标是“产品由其制造商在整体上得到充分保护，不论数据是在用户设备上本地处理或存储，还是由制造商远程处理或存储”。它还规定，“因此，关于属于本条例适用范围的远程数据处理解决方案的要求，并不包含旨在管理对制造商的网络和信息系统整体安全所造成风险的技术、运行或组织措施。”

182. Therefore, it results from recital 11 that the intent is not for the CRA requirements to cover the whole IT infrastructure of an organisation, but only software components that allow for the execution of the data processing solution. For example, internal systems relating to the manufacturer’s own human resources, payrolls, customer relationship management, continuous integration/continuous delivery (CI/CD) pipelines, the distribution of security updates to edge locations, should not be considered as RDPS. Likewise, systems linked to auditing and testing activities, such as penetration testing, threat hunting and red teaming are outside the scope of a product with digital elements as covered by the CRA. It is important to note that while applying effective and regular tests and reviews of the security of the product with digital elements is an essential requirement laid down in point (3) of Part II of Annex I to the CRA, this does not mean that such activities are to be considered RDPS for the product with digital elements.

> 因此，从序言第11项可以得出，其意图并非使CRA要求涵盖一个组织的整个信息技术基础设施，而仅涵盖使数据处理解决方案得以执行的软件组件。例如，与制造商自身的人力资源、工资、客户关系管理、持续集成/持续交付（CI/CD）管道、向边缘位置分发安全更新有关的内部系统，不应被视为RDPS。同样，与审计和测试活动相联系的系统，例如渗透测试、威胁猎捕和红队演练，不属于CRA所涵盖的含数字元素产品的范围。应当指出，尽管对含数字元素产品的安全实施有效且定期的测试和审查是CRA附件I第二部分第(3)点所规定的基本要求，这并不意味着此类活动应被视为该含数字元素产品的RDPS。

183. Recital 12 focuses on cloud services and elaborates on the circumstances under which cloud services might be considered RDPS. The recital concludes by recalling that cloud computing services and cloud service models fall within the scope of Directive (EU) 2022/2555 (NIS 2)28, which establishes cybersecurity risk-management requirements for cloud computing service providers. Those requirements are further specified by Commission Implementing Regulation (EU) 2024/269029.

> 序言第12项侧重于云服务，并阐述云服务在何种情形下可能被视为RDPS。该序言项以回顾云计算服务和云服务模式属于指令(EU) 2022/2555（NIS 2）28的适用范围作结；该指令为云计算服务提供者确立网络安全风险管理要求。这些要求由委员会实施条例(EU) 2024/269029进一步规定。

8.1 What is considered a remote data processing solution for a product with digital elements?
8.1 何为含数字元素产品的远程数据处理解决方案？

184. The definition of remote data processing laid down in Article 3(2), thus, relies on three elements: (i) whether data processing is ‘at a distance’; (ii) whether the absence of such data processing would prevent the product with digital elements from performing one of its functions; and (iii) whether the software is designed and developed by the manufacturer, or under its responsibility. The next three subsections address each of these elements in more detail.

> 因此，第3条第2款所规定的远程数据处理定义依赖三个要素：(i) 数据处理是否“在远程进行”；(ii) 如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一；以及(iii) 软件是否由制造商或在其责任下设计和开发。以下三个分节更详细地分别说明这些要素。

8.1.1 The notion of ‘at a distance’
8.1.1 “在远程进行”这一概念

185. The notion of ‘at a distance’ referred to in Article 3(2) is relevant but not sufficient to determine whether a product with digital elements includes RDPS. Furthermore, given the variety of solutions that might fall under this concept, it is not possible to provide an exhaustive definition of ‘at a distance’. A case-by-case assessment by the manufacturer is needed.

> 第3条第2款所指的“在远程进行”这一概念，对于确定含数字元素产品是否包含RDPS是相关的，但并不足够。此外，鉴于可能落入这一概念的解决方案多种多样，不可能对“在远程进行”提供穷尽定义。需要由制造商进行逐案评估。

186. Recital 11 of the CRA mentions data processed or stored ‘remotely by the manufacturer’ as opposed to data processed or stored ‘locally on the user’s device’. Remote data processing typically takes place outside the user environment of a product with digital elements or an organisation’s operational environment (for a professional user). This, however, does not prevent processing from also taking place close to the device (‘at the edge’). The transmission of data may be wired (e.g. ethernet cable) or wireless (e.g. Wi-Fi, Bluetooth). Cloud computing, including edge computing, is a typical example of data processing taking place ‘at a distance’. For instance, in the case of a cloud-based function accessed by the user from a mobile application, part of the data processing takes place on the cloud, outside of the user’s environment.

> CRA序言第11项提及由制造商“远程”处理或存储的数据，以区别于“在用户设备上本地”处理或存储的数据。远程数据处理通常发生在含数字元素产品的用户环境之外，或（就专业用户而言）某一组织的运行环境之外。然而，这并不妨碍处理也发生在靠近设备之处（“在边缘”）。数据传输可以是有线的（例如以太网电缆）或无线的（例如Wi-Fi、蓝牙）。云计算，包括边缘计算，是“在远程进行”的数据处理的典型例子。例如，在用户从移动应用程序访问基于云的功能的情况下，部分数据处理发生在云端，即用户环境之外。

28 Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive), OJ L 333, 27.12.2022, p. 80, ELI: http://data.europa.eu/eli/dir/2022/2555/2022-12-27. 29 Commission

Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures and further specification of the cases in which an incident is considered to be significant with regard to DNS service providers, TLD name registries, cloud computing service providers, data centre service providers, content delivery network providers, managed service providers, managed security service providers, providers of online market places, of online search engines and of social networking services platforms, and trust service providers, OJ L, 2024/2690, 18.10.2024, ELI: http://data.europa.eu/eli/reg_impl/2024/2690/oj.

> 28 欧洲议会和理事会2022年12月14日关于在全联盟实现高水平共同网络安全措施、修正条例(EU) No 910/2014和指令(EU) 2018/1972并废止指令(EU) 2016/1148的指令(EU) 2022/2555（NIS 2指令），《官方公报》L 333，2022年12月27日，第80页，ELI: http://data.europa.eu/eli/dir/2022/2555/2022-12-27。29 委员会2024年10月17日实施条例(EU) 2024/2690，为适用指令(EU) 2022/2555制定关于网络安全风险管理措施的技术和方法要求的规则，并进一步规定就域名系统服务提供者、顶级域名注册管理机构、云计算服务提供者、数据中心服务提供者、内容分发网络提供者、托管服务提供者、托管安全服务提供者、在线市场提供者、在线搜索引擎提供者和社会网络服务平台提供者以及信任服务提供者而言，事件被视为重大的情形，《官方公报》L辑，2024/2690，2024年10月18日，ELI: http://data.europa.eu/eli/reg_impl/2024/2690/oj。

187. It is important to note that RDPS are not necessarily operated on third-party cloud infrastructure. Remote data processing running on local servers on the manufacturer's premises can also constitute RDPS. In other words, a solution run on-premises and on a private cloud is just as likely to qualify as RDPS as a solution run on a public cloud and off-premises.

> 应当指出，RDPS并不必然在第三方云基础设施上运行。在制造商场所的本地服务器上运行的远程数据处理也可以构成RDPS。换言之，在本地和私有云上运行的解决方案，与在公共云和场外运行的解决方案同样可能构成RDPS。

188. The two decisive and cumulative questions that determine whether data processing is covered by CRA as remote data processing solution are set out below, in Sections 8.1.2 and 8.2. If both questions are answered in the affirmative, the remote data processing qualifies as RDPS.

> 决定数据处理是否作为远程数据处理解决方案被CRA涵盖的两个决定性且须同时满足的问题，规定于下文第8.1.2节和第8.2节。如果两个问题的答案都是肯定的，则该远程数据处理构成RDPS。

8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions?
8.1.2 如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？

189. As laid down in the definition of 'remote data processing' included in Article 3(2), for data processing at a distance to qualify as an RDPS, its absence would need to prevent the product with digital elements from performing one of its functions. The notion of 'functions' included in this definition is not limited to the 'core functionality' or 'intended purpose' of the product with digital elements, as the CRA does not impose such a limitation. The functions within the scope of the CRA are both functions that directly fulfil the intended purpose of the product with digital elements as experienced by users and functions that support the product's overall performance.

> 正如第3条第2款所载"远程数据处理"的定义所规定的，远程数据处理要构成RDPS，没有它就必须会妨碍含数字元素产品履行其功能之一。这一定义中的"功能"概念并不限于含数字元素产品的"核心功能"或"预期用途"，因为CRA并未施加此种限制。属于CRA范围的功能，既包括用户所体验的、直接实现含数字元素产品预期用途的功能，也包括支持产品整体性能的功能。

190. Examples of functions where data processing at a distance may happen and that would prevent a product with digital elements from performing one of its functions would include: (i) sending commands to a device; (ii) synchronising files; (iii) onboarding the user; (iv) configuration (personalisation of the product with digital elements); (v) automated distribution of updates, including feature update and security patching; (vi) identity and access management.

> 可能发生远程数据处理、并且如果没有它就会妨碍含数字元素产品履行其功能之一的功能示例包括：(i) 向设备发送命令；(ii) 同步文件；(iii) 用户入门；(iv) 配置（含数字元素产品的个性化）；(v) 更新的自动分发，包

> 括功能更新和安全修补；(vi) 身份和访问管理。

191. In some cases, the user can use a function both remotely and manually (e.g. switching a light bulb with an app or manually). Having this option does not exclude qualification as RDPS of the data processing associated with the remote performance of the function. Performing this function remotely is also considered part of the functions the product with digital elements offers.

> 在某些情况下，用户既可以远程也可以手动使用某一功能（例如用应用程序或手动开关灯泡）。具有这一选项，并不排除与远程履行该功能相关的数据处理构成RDPS。远程履行这一功能，也被视为含数字元素产品所提供的功能的一部分。

192. By contrast, where the absence of a certain data processing does not prevent the product with digital elements from performing one of its functions, such processing is not considered as an RDPS within the meaning of the CRA. This includes, for example, remote analysis of telemetry data collected purely for statistical purposes or future product development.

> 相反，如果没有某一数据处理并不会妨碍含数字元素产品履行其功能之一，则此类处理不视为CRA意义上的RDPS。例如，纯粹为统计目的或未来产品开发而收集的遥测数据的远程分析，即属此类。

193. Nevertheless, even when data processing does not support a function of a product with digital elements, manufacturers may need to consider if those remote components introduce risks to the product with digital elements as part of their cybersecurity risk assessment (e.g. in light of the product's operational environment), and mitigate such risks accordingly (e.g. through product-level mitigations).

> 尽管如此，即使数据处理并不支持含数字元素产品的某一功能，制造商仍可能需要考虑这些远程组件是否作为其网络安全风险评估的一部分向含数字元素产品引入风险（例如鉴于产品的运行环境），并相应缓解此类风险（例如通过产品层面的缓解措施）。

194. Websites are a specific case that deserves further clarification, as also explained in Section 2.1 Placing on the market. Websites are not within the scope of RDPS if they do not support a function of a product with digital elements, as explained in recital 11 of the CRA. It is not sufficient for a website to contain information about a product with digital elements to be considered within the scope of RDPS, even if the product redirects to such website. For example, redirecting users to an external webpage that provides information and instructions to users is not an RDPS. By contrast, a website may be within the scope of RDPS if it enables or supports a function of a product with digital elements. For example, an authentication portal that issues credentials or tokens required for the product with digital elements to operate would be considered RDPS (provided that the other criteria of the definition are also met).

> 网站是值得进一步澄清的一种特定情形，正如第2.1节“投放市场”亦所说明的。如果网站并不支持含数字元素产品的某一功能，则它们不属于RDPS的范围，如CRA序言第11项所说明的。网站包含关于含数字元素产品的信息，并不足以使其被视为属于RDPS的范围，即使该产品重定向到该网站。例如，将用户重定向到向用户提供信息和说明的外部网页，不是RDPS。相反，如果网站使含数字元素产品的某一功能成为可能或予以支持，则它可能属于RDPS的范围。例如，签发含数字元素产品运行所需的凭证或令牌的认证门户，将被视为RDPS（但前提是该定义的其他标准也得到满足）。

8.1.3 Has the software been designed and developed by the manufacturer, or under its responsibility?
8.1.3 软件是否由制造商或在其责任下设计和开发？

195. The definition of 'remote data processing' of Article 3(2) of the CRA further specifies that the software of such data processing at a distance needs to be designed and developed by the manufacturer, or under its responsibility. Remote data processing entirely developed and designed by the manufacturer (in-house) would naturally qualify as RDPS. This would also be the case if manufacturers rely on an external service provider for the development and design of a solution (i.e.

‘under its responsibility’). The phrase ‘under the responsibility of the manufacturer’ refers to remote processing solutions that are tailor-made for the manufacturer. These are cases where the manufacturer is not merely licensing an existing product with digital elements or service that a service provider offers to its customers or slightly modified versions thereof. ‘[U]nder the responsibility of the manufacturer’ entails that the software is built solely by or on behalf of the manufacturer, based on designs and specifications provided by it.

> CRA第3条第2款关于“远程数据处理”的定义进一步规定，此类远程数据处理的软件需要由制造商或在其责任下设计和开发。完全由制造商（内部）开发和设计的远程数据处理，自然构成RDPS。如果制造商依赖外部服务提供者为解决方案的开发和设计（即“在其责任下”），亦属如此。“在制造商的责任下”这一用语，是指为制造商量身定制的远程处理解决方案。这些是如下情形：制造商并非仅仅许可服务提供者向其客户提供的既有含数字元素产品或服务，或其略加修改的版本。“在制造商的责任下”意味着该软件仅由制造商或代表制造商、根据其所提供的设计和规范构建。

196. In understanding RDPS, the notion of ‘who operates the solution’ is not a decisive factor, as the CRA definition only refers to the design and development of the RDPS. This is consistent with the CRA approach whereby requirements and obligations are on manufacturers, and not on the operation of the product with digital elements. If manufacturers design and develop solutions, which are then operated by a third party, they remain responsible for compliance with the CRA’s essential requirements for the product with digital elements that they place on the market.

> 在理解RDPS时，“谁运营该解决方案”这一概念不是决定性因素，因为CRA的定义仅提及RDPS的设计和开发。这与CRA的方法相一致，即要求和义务加于制造商，而不是加于含数字元素产品的运营。如果制造商设计和开发解决方案，然后由第三方运营，则它们对其投放市场的含数字元素产品遵守CRA基本要求仍然负责。

197. It is necessary to differentiate between the cases where design and development are done by manufacturers (or under their responsibility) and cases of reliance on third-party solutions not designed and developed by manufacturers (or under their responsibility). As an example, it is helpful to consider the most common cloud service models that provide different degrees of user control and that are also cited in recital 12 of the CRA, namely Software as a Service (SaaS), Platform as a Service (PaaS) and Infrastructure as a Service (IaaS).

> 有必要区分设计和开发由制造商完成（或在其责任下完成）的情形，与依赖并非由制造商（或在其责任下）设计和开发的第三方解决方案的情形。例如，宜考虑提供不同程度用户控制、并且也在CRA序言第12项中被引用的最常见云服务模式，即软件即服务（SaaS）、平台即服务（PaaS）和基础设施即服务（IaaS）。

198. In the case of a third-party IaaS solution, the manufacturer does not manage or control the underlying physical and virtual resources (such as the underlying hardware and the cloud service provider’s hypervisor), but is able to deploy and run arbitrary software using such resources, such as operating systems and applications. Such software is designed and developed by the manufacturer, or under its responsibility, and may therefore qualify as RDPS (if it fulfils the other elements of the definition).

> 就第三方IaaS解决方案而言，制造商并不管理或控制底层物理和虚拟资源（例如底层硬件和云服务提供者的虚拟机监控程序），但能够使用此类资源部署和运行任意软件，例如操作系统和应用程序。此类软件由制造商或在其责任下设计和开发，因此可能构成RDPS（如果它满足该定义的其他要素）。

199. In the case of a third-party PaaS solution, the manufacturer deploys its own (created or acquired) application using programming languages and execution environments provided by the cloud service provider and integrates the application into its product with digital elements. The manufacturer has control over the application and possibly over configuration settings for the execution environment. The application is therefore designed and developed by the manufacturer, or under its responsibility, and may therefore qualify as RDPS (if it fulfils the other elements of the definition).

> 就第三方PaaS解决方案而言，制造商使用云服务提供者提供的编程语言和执行环境部署其自己的（创建或取得的）应用程序，并将该应用程序集成到其含数字元素产品中。制造商对应用程序拥有控制，并可能对执行

环境的配置设置拥有控制。因此，该应用程序由制造商或在其责任下设计和开发，因而可能构成RDPS（如果它满足该定义的其他要素）。

200. In the case of a third-party SaaS solution, the SaaS provider offers the manufacturer a fully developed application to be integrated into the manufacturer's product with digital elements. The manufacturer has limited ability to manage user-specific application configuration settings. The application is therefore not designed and developed by the manufacturer, or under its responsibility.

就第三方SaaS解决方案而言，SaaS提供者向制造商提供一个已完全开发的应用程序，以集成到制造商的含数字元素产品中。制造商管理特定于用户的应用程序配置设置的能力有限。因此，该应用程序并非由制造商或在其责任下设计和开发。

201. Nonetheless, where certain elements do not qualify as RDPS (e.g. the hypervisor in the case of a third-party IaaS infrastructure, the operating system in the case of a third-party PaaS solution, or the third-party SaaS application) but are integrated into the product with digital elements in a manner that affects its security, such solutions should be considered similar to third-party components. The manufacturer is required to identify and assess risks linked to the integration of those elements and to address them by implementing the essential requirements on the product with digital elements itself. This can, where relevant, be supported by the security functions made available by the cloud service provider through its shared responsibility model, where the manufacturer uses or configures those functions to address the identified risks. Additionally, the manufacturer is expected to exercise a similar obligation to the obligation to perform due diligence referred to in Article 13(5) related to the security of these components, in a manner that is proportionate to the risk that the remote solution poses to the security of the product with digital elements.

尽管如此，如果某些要素不构成RDPS（例如第三方IaaS基础设施情况下的虚拟机监控程序、第三方PaaS解决方案情况下的操作系统，或第三方SaaS应用程序），但以影响其安全的方式被集成到含数字元素产品中，则此类解决方案应当被视为类似于第三方组件。制造商必须识别和评估与集成这些要素相联系的风险，并通过在含数字元素产品本身上实施基本要求来处理它们。在相关情况下，这可以得到云服务提供者通过其责任共担模式所提供的安全功能的支持，即制造商使用或配置这些功能以处理已识别的风险。此外，预期制造商就这些组件的安全履行与第13条第5款所指的尽职调查义务相似的义务，其方式与该远程解决方案对含数字元素产品安全所造成的风险相称。

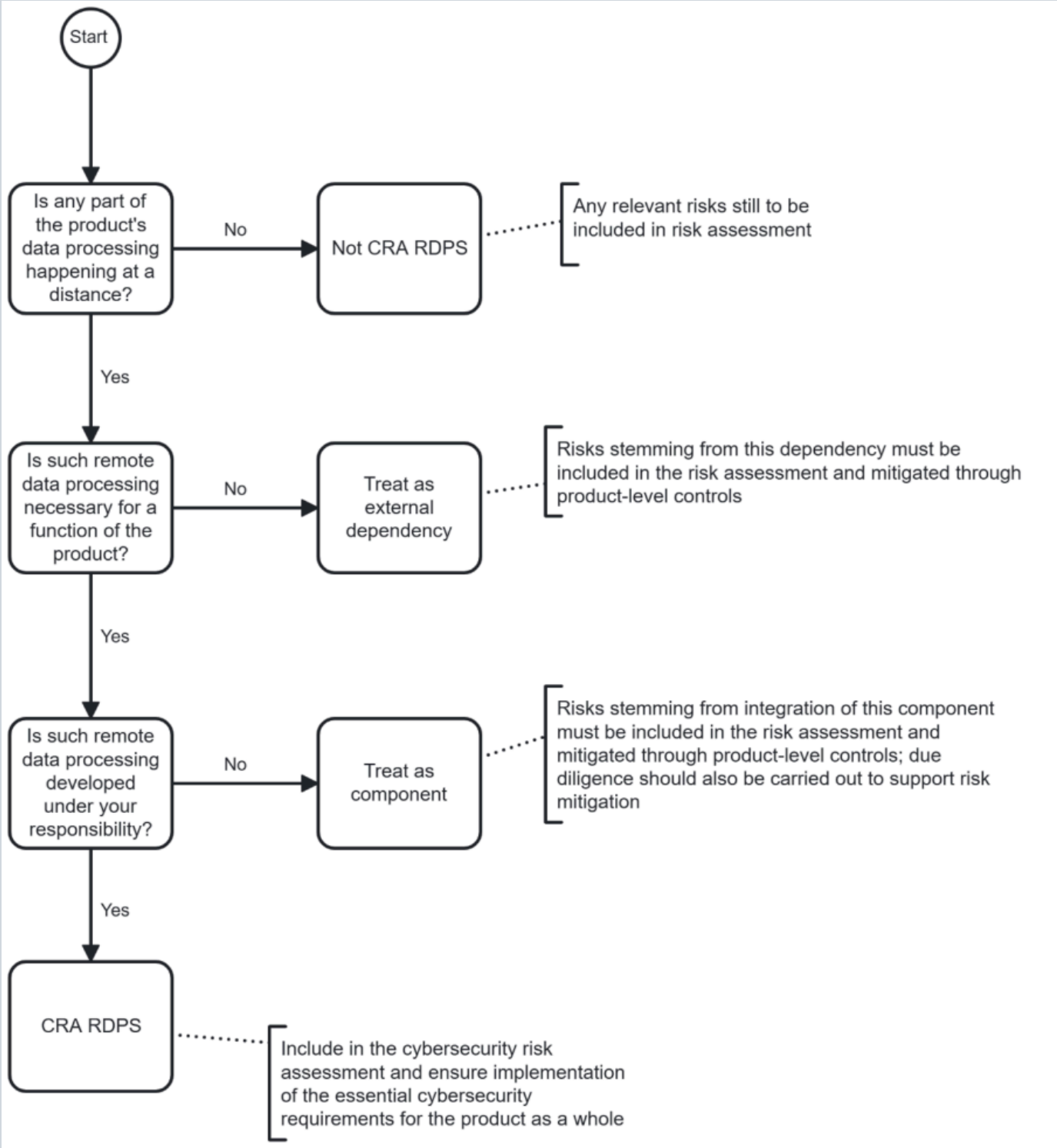
202. Therefore, it can be summarised that: a. For data processing to qualify as RDPS, the answer to both questions posed in Sections 8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions? and 8.1.3 Has the software been designed and developed by the manufacturer, or under its responsibility? needs to be affirmative. b. If the answer to the question in Section 8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions? is negative, manufacturers should assess the risks stemming from the existence of such data processing as part of their risk assessment. c. If the answer to the question in Section 8.1.2 Would the absence of such data processing prevent the product with digital elements from performing one of its functions? is affirmative but the answer to the question in 8.1.3 Has the software been designed and developed by the manufacturer, or under its responsibility? is negative, manufacturers should treat the third-party solution as a component. As part of the risk assessment, manufacturers should assess the risks stemming from the integration of such solution and mitigate them accordingly. Additionally, manufacturers should exercise due diligence.

因此，可以归纳如下：a. 数据处理要构成RDPS，第8.1.2节“如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？”和第8.1.3节“软件是否由制造商或在其责任下设计和开发？”所提出的两个问题的答案都需要是肯定的。b. 如果第8.1.2节“如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？”这一问题的答案是否定的，制造商应当作为其风险评估的一部分，评估源于存在此类数据处理的风险。c. 如果第8.1.2节“如果没有此类数据处理，是否会妨碍含数字元素产品履行其功能之一？”这一问题的答案是肯定的，但第8.1.3节“软件是否由制造商或在其责任下设计和开发？”这一问题的答案是否定的，制

> 造商应当将第三方解决方案作为组件对待。作为风险评估的一部分，制造商应当评估源于集成该解决方案的风险并相应缓解它们。此外，制造商应当开展尽职调查。

Figure 9: Stylised flowchart to determine if a product with digital elements contains RDPS

> 图9：确定含数字元素产品是否包含RDPS的示意流程图



图中文字对照（只译图内已有文字，不增补说明）

Start	开始
Is any part of the product’s data processing happening at a distance?	该产品的数据处理是否有任何部分在远程进行？

Not CRA RDPS	不属于CRA意义上的远程数据处理解决方案
Any relevant risks still to be included in risk assessment	任何相关风险仍须纳入风险评估
Is such remote data processing necessary for a function of the product?	此类远程数据处理是否为该产品的某一功能所必需？
Treat as external dependency	作为外部依赖项对待
Risks stemming from this dependency must be included in the risk assessment and mitigated through product-level controls	源于该依赖项的风险必须纳入风险评估，并通过产品层面的控制加以缓解
Is such remote data processing developed under your responsibility?	此类远程数据处理是否在你的责任下开发？
Treat as component	作为组件对待
Risks stemming from integration of this component must be included in the risk assessment and mitigated through product-level controls; due diligence should also be carried out to support risk mitigation	源于集成该组件的风险必须纳入风险评估，并通过产品层面的控制加以缓解；还应当开展尽职调查以支持风险缓解
CRA RDPS	CRA意义上的远程数据处理解决方案
Include in the cybersecurity risk assessment and ensure implementation of the essential cybersecurity requirements for the product as a whole	纳入网络安全风险评估，并确保对作为整体的产品实施基本网络安全要求
Yes / No	是 / 否

8.2 Practical and technical implications of remote data processing solutions and reliance on third-party solutions

8.2 远程数据处理解决方案以及依赖第三方解决方案的实际和技术影响

203. The CRA follows a risk-based approach, which is enshrined in Article 13(2) and (3), as well as in the first essential requirement of Part I of Annex I, whereby ‘products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks’. Consequently, a risk-based approach should be considered when applying the CRA requirements to the RDPS and the treatment of risks stemming from third-party services integrated into the product with digital elements.

> CRA遵循基于风险的方法，该方法规定于第13条第2款和第3款，以及附件I第一部分的第一项基本要求，即“含数字元素产品的设计、开发和生产方式，应使其基于风险确保适当的网络安全水平”。因此，在将CRA要求适用于RDPS以及处理源于集成到含数字元素产品中的第三方服务的风险时，应当考虑基于风险的方法。

204. First, manufacturers should (i) indicate in the technical documentation that their product with digital elements has RDPS or relies on third-party remote solutions and (ii) describe such solutions. If the same RDPS supports several products with digital elements, the RDPS needs to be declared in each product’s technical documentation. The documentation concerning RDPS serving several products with digital elements may be re-used from one product conformity assessment to another.

> 首先，制造商应当(i) 在技术文件中表明其含数字元素产品具有RDPS或依赖第三方远程解决方案，并且(ii) 描述此类解决方案。如果同一RDPS支持若干含数字元素产品，则该RDPS需要在每一产品的技术文件中声明。关于服务于若干含数字元素产品的RDPS的文件，可以从一次产品合格评定再利用于另一次。

205. As indicated in recital 11, the RDPS that are part of the product with digital elements and therefore subject to the product’s conformity assessment should be limited to those software modules that are responsible for the functionality of the product with digital elements, and to the interfaces those modules use with external services. Further back-end systems

that carry out subsequent processing, and with which the product with digital elements does not directly interact, are not considered RDPS.

> 正如序言第11项所指出的，属于含数字元素产品一部分并因而受该产品合格评定约束的RDPS，应当限于负责该含数字元素产品之功能的那些软件模块，以及这些模块与外部服务所使用的接口。实施后续处理、且含数字元素产品并不与之直接交互的更下游后端系统，不视为RDPS。

206. Nonetheless, those back-end systems remain external dependencies that must be assessed as part of the cybersecurity risk assessment and mitigated through product-level measures. In fact, the risk assessment performed by the manufacturer should consider: (i) risks related to RDPS; (ii) risks related to reliance on third-party remote solutions (similar to third-party components); and (iii) risks related to the product environment (e.g. underlying hardware). Manufacturers should implement security controls on the product with digital elements itself to mitigate those risks.

> 尽管如此，这些后端系统仍然是必须作为网络安全风险评估一部分加以评估、并通过产品层面措施加以缓解的外部依赖项。事实上，制造商所实施的风险评估应当考虑：(i) 与RDPS相关的风险；(ii) 与依赖第三方远程解决方案相关的风险（类似于第三方组件）；以及(iii) 与产品环境相关的风险（例如底层硬件）。制造商应当在含数字元素产品本身上实施安全控制，以缓解这些风险。

207. Furthermore, as part of the conformity assessment and/or the fulfilment of due diligence obligations related to third-party remote services, the following non-exhaustive list of assurance artefacts can be re-used in support of the manufacturer’s assessment: a. evidence of fulfilment of obligations under Commission Implementing Regulation (EU) 2024/2690; b. evidence of fulfilment of obligations under Regulation (EU) 2022/2554 (DORA); c. statement of conformity or certificate obtained under a European cybersecurity certification scheme (adopted under Regulation (EU) 2019/881 – the Cybersecurity Act); d. evidence of conformity with ISO/IEC 27017:2015 or ISO/IEC 27001:2022.

> 此外，作为与第三方远程服务有关的合格评定和/或尽职调查义务履行的一部分，下列非穷尽的保证材料清单可以再利用，以支持制造商的评估：a. 履行委员会实施条例(EU) 2024/2690项下义务的证据；b. 履行条例(EU) 2022/2554（DORA）项下义务的证据；c. 根据欧洲网络安全认证计划（根据条例(EU) 2019/881——《网络安全法》——通过）取得的符合性声明或证书；d. 符合ISO/IEC 27017:2015或ISO/IEC 27001:2022的证据。

208. Finally, in their interactions with third-party remote service providers, manufacturers need to implement the most appropriate security measures based on their risk assessment (and, where appropriate, supported by the provider’s shared responsibility model). Those mitigation measures should include security controls for their products with digital elements and the verification of security measures provided by the third-party providers themselves (due diligence). A tool to mitigate such risks can be to embed security guarantees in their service level agreements (SLAs) with third-party providers, including assurances that providers adequately handle vulnerabilities. A major change in the solutions provided by the third-party remote services providers should not qualify as a substantial modification of the product with digital elements, as these elements are not under the manufacturer’s responsibility. However, as part of their due diligence obligations and to correctly mitigate risks stemming from the use of third-party providers, manufacturers are encouraged to ensure that their third-party cloud service providers keep them adequately informed about changes they implement on their solutions. Based on such information, manufacturers may need to revise their risk assessment. The updated risk assessment should consider whether the third-party service providers still provide sufficient guarantees in terms of cybersecurity and whether the product-level security controls are still adequate. In some cases, manufacturers may need to modify such controls or change third-party service providers.

> 最后，在与第三方远程服务提供者的互动中，制造商需要根据其风险评估实施最适当的安全措施（并在适当情况下得到提供者责任共担模式的支持）。这些缓解措施应当包括对其含数字元素产品的安全控制，以及对第三方提供者自身所提供安全措施的核验（尽职调查）。缓解此类风险的一种工具，可以是在其与第三方提供者的服务级别协议（SLA）中嵌入安全保证，包括提供者充分处理漏洞的保证。第三方远程服务提供者对其所提供解决方案的重大变更，不应构成含数字元素产品的实质性修改，因为这些要素并不处于制造商的责

任之下。然而，作为其尽职调查义务的一部分，并为正确缓解源于使用第三方提供者的风险，鼓励制造商确保其第三方云服务提供者就其在解决方案上实施的变更向其充分告知。根据此类信息，制造商可能需要修订其风险评估。更新后的风险评估应当考虑第三方服务提供者是否仍然提供充分的网络安全保证，以及产品层面的安全控制是否仍然充分。在某些情况下，制造商可能需要修改此类控制或更换第三方服务提供者。

8.3 Use cases for remote data processing solutions
8.3 远程数据处理解决方案的用例

In order to provide additional practical guidance for manufacturers, this section introduces a series of fictional use cases, describing archetypal products with digital elements that rely on remote data processing and illustrating whether such processing qualifies as remote data processing solutions within the meaning of the CRA.

为向制造商提供额外的实际指导，本节介绍一系列虚构用例，描述依赖远程数据处理的典型含数字元素产品，并说明此类处理是否构成CRA意义上的远程数据处理解决方案。

8.3.1 Mobile banking application
8.3.1 移动银行应用程序

A financial entity places a mobile banking application on the market. The app's back-end systems support, among others, authentication, authorisation, account management, and payments. The financial entity uses a hybrid strategy relying on in-house infrastructure as well as third-party remote solutions to support the app's functionalities. These include: Self-hosted infrastructure developed by the financial entity:

某一金融实体将一款移动银行应用程序投放市场。该应用程序的后端系统支持认证、授权、账户管理和支付等功能。该金融实体采用混合策略，依赖内部基础设施以及第三方远程解决方案来支持该应用程序的功能。这些包括：由该金融实体开发的自托管基础设施：

• The customer opens the mobile banking application and is authenticated through the banking interface, a self-hosted solution developed by the financial entity that receives the app's requests and returns the corresponding responses. The banking interface verifies the customer's identity by querying the account management system and grants access to the application. • The customer initiates a transfer via the app. The app transmits the instruction to the banking interface, which submits a corresponding request to the ledger system. • The account-management system and ledger system, both self-hosted but logically segregated from the banking interface, record the transaction. • The ledger system returns the transaction status to the banking interface, which presents the result to the customer.

• 客户打开移动银行应用程序，并通过银行接口得到认证。银行接口是由该金融实体开发的自托管解决方案，它接收应用程序的请求并返回相应响应。银行接口通过查询账户管理系统核验客户身份，并授予对该应用程序的访问。• 客户通过应用程序发起转账。应用程序将指令传输给银行接口，银行接口向分类账系统提交相应请求。• 账户管理系统和分类账系统均为自托管，但在逻辑上与银行接口隔离，它们记录该交易。• 分类账系统将交易状态返回给银行接口，银行接口将结果呈现给客户。

Implications for RDPS:

对RDPS的影响：

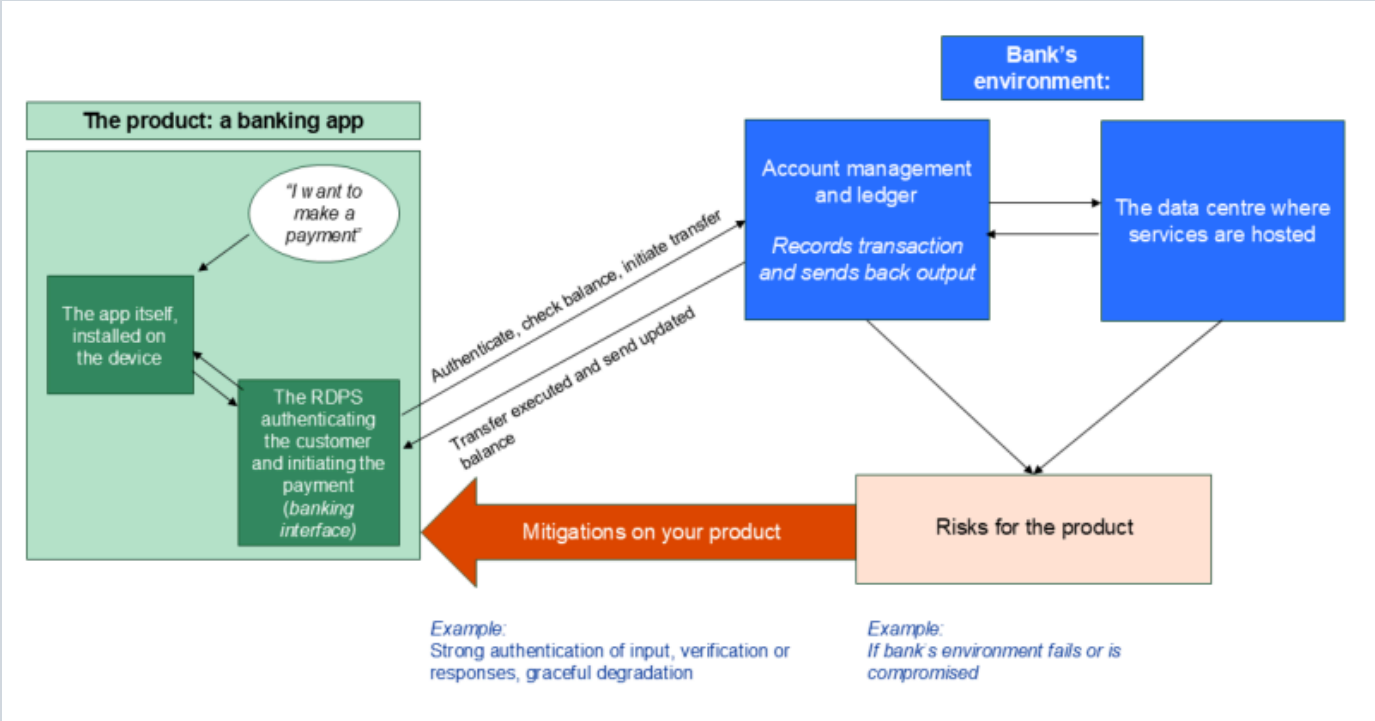
• The banking interface is necessary for the app to perform its functions, namely authenticating the customer, submitting the customer's instructions, including payment and transfer instructions, and returning the resulting status. The banking interface is designed and developed under the responsibility of the manufacturer. As the answer to both questions presented in earlier sections is affirmative, the banking interface is to be considered an RDPS. It must therefore be included in the cybersecurity risk assessment and in the implementation of the essential requirements for the product with digital elements as a whole. The subsequent processing of an instruction once submitted, in particular the recording of the

transaction in the account-management and ledger systems, settlement and clearing, is carried out by systems with which the app does not interact directly and does not, on that basis, constitute an RDPS. • The account-management system and the ledger system do not qualify as RDPS for the banking application. The app does not interact directly with them (interacting instead with the banking interface, which in turn relies upon them). Although their availability may be necessary for a function to be completed, the CRA covers only those parts of the system that interact directly with the product with digital elements. They therefore fall outside the definition of RDPS for the purposes of the CRA. However, those systems remain external dependencies that may give rise to significant cybersecurity risks for the product with digital elements. For example, compromise of the ledger system could allow an attacker to influence transaction results that are subsequently displayed in the application. The manufacturer is therefore required to identify and assess those risks as part of the cybersecurity risk assessment and to mitigate them through product-level measures, such as strong authentication of back-end interfaces, integrity protection of transaction data, secure communication channels and verification of responses received by the app.

> • 银行接口是应用程序履行其功能所必需的，即认证客户、提交客户的指令（包括付款和转账指令）并返回由此产生的状态。银行接口在制造商的责任下设计和开发。由于前面各节所提出的两个问题的答案都是肯定的，银行接口应被视为RDPS。因此，它必须被纳入网络安全风险评估，并纳入对作为整体的含数字元素产品实施基本要求。指令一经提交之后的后续处理，特别是在账户管理和分类账系统中记录交易、结算和清算，由应用程序并不与之直接交互的系统实施，因此仅凭这一点并不构成RDPS。• 账户管理系统和分类账系统不构成该银行应用程序的RDPS。应用程序并不与它们直接交互（而是与银行接口交互，银行接口又依赖它们）。尽管它们的可用性对于完成某一功能可能是必要的，CRA仅涵盖与含数字元素产品直接交互的系统部分。因此，就CRA而言，它们不属于RDPS的定义。然而，这些系统仍然是可能给含数字元素产品带来重大网络安全风险的外部依赖项。例如，分类账系统遭到破坏可能使攻击者能够影响随后在应用程序中显示的交易结果。因此，制造商必须作为网络安全风险评估的一部分识别和评估这些风险，并通过产品层面的措施缓解它们，例如对后端接口进行强认证、对交易数据进行完整性保护、安全通信信道，以及核验应用程序所收到的响应。

Figure 10: Stylised representation of a banking app relying on RDPS

> 图10：依赖RDPS的银行应用程序的示意表示



图中文字对照（只译图内已有文字，不增补说明）

The product: a banking app	产品：银行应用程序
The app itself, installed on the device	应用程序本身，安装在设备上
I want to make a payment	我要进行付款
The RDPS authenticating the customer and initiating the payment (banking interface)	认证客户并发起付款的远程数据处理解决方案（银行接口）
Bank’s environment:	银行的环境：
Account management and ledger	账户管理与分类账
Records transaction and sends back output	记录交易并返回输出
The data centre where services are hosted	托管服务的数据中心
Authenticate, check balance, initiate transfer	认证、查询余额、发起转账
Transfer executed and send updated balance	转账已执行并发送更新后的余额
Mitigations on your product	在你的产品上采取的缓解措施
Risks for the product	对该产品的风险
Example: Strong authentication of input, verification of responses, graceful degradation	示例：对输入进行强认证、核验响应、平稳降级
Example: If bank’s environment fails or is compromised	示例：如果银行环境发生故障或遭到破坏

Third-party SaaS for customer support:

> 用于客户支持的第三方SaaS：

• The financial entity integrates into its app a customer support chat solution developed and operated by a third-party provider; the third-party provider has written the chat server code, built the user interface and operates the infrastructure where the chat is deployed (i.e. SaaS model). • When the customer initiates a request for support, the app connects the customer to the third-party service to establish a chat session and handle the messaging flow, without providing the third party with access to core banking systems.

> • 该金融实体在其应用程序中集成由第三方提供者开发和运营的客户支持聊天解决方案；该第三方提供者编写了聊天服务器代码、构建了用户界面，并运营部署聊天的基础设施（即SaaS模式）。• 当客户发起支持请求时，应用程序将客户连接到第三方服务，以建立聊天会话并处理消息流，而不向第三方提供对核心银行系统的访问。

Implications for RDPS:

> 对RDPS的影响：

• The support chat solution is necessary for the product with digital elements to perform one of its functions, but is not designed and developed by the financial entity, or under its responsibility; it therefore is not an RDPS. However, it should be treated like a third-party component. The reliance on that third-party service may create cybersecurity risks for the banking application, for example if an attacker were to use the chat channel to impersonate the bank or to deliver malicious content to users. The financial entity must take those risks into account in its cybersecurity risk assessment and mitigate them through product-level measures, such as isolating the chat function from core banking features, controlling data flows and validating content. Due diligence on the SaaS should also be exercised.

> • 支持聊天解决方案是含数字元素产品履行其功能之一所必需的，但并非由该金融实体或在其责任下设计和开发；因此它不是RDPS。然而，它应当像第三方组件一样被对待。对该第三方服务的依赖可能给银行应用程序造成网络安全风险，例如如果攻击者利用聊天信道冒充银行或向用户投递恶意内容。该金融实体必须在其网络安全风险评估中考虑这些风险，并通过产品层面的措施缓解它们，例如将聊天功能与核心银行功能隔离、控制数据流并验证内容。还应当就该SaaS开展尽职调查。

8.3.2 Smart thermostat
8.3.2 智能恒温器

A smart thermostat enables users to control the temperature of their homes via a mobile application. The mobile application and the smart thermostat rely on remote data processing to exchange data (e.g. request to increase the temperature) and store data (e.g. user preferences). These functions were developed and designed under the responsibility of the manufacturer but run on an underlying physical and virtual infrastructure provided by a third party (third-party IaaS).

> 智能恒温器使用户能够通过移动应用程序控制其住宅的温度。移动应用程序和智能恒温器依赖远程数据处理来交换数据（例如提高温度的请求）和存储数据（例如用户偏好）。这些功能在制造商的责任下开发和设计，但运行在第三方提供的底层物理和虚拟基础设施上（第三方IaaS）。

As the smart thermostat would not be able to perform its smart functionalities without this remote data processing, its absence would prevent the product with digital elements from performing one or more of its functions. Additionally, the software was developed and designed under the responsibility of the smart thermostat manufacturer. Therefore, the remote data processing qualifies as RDPS as defined in the CRA.

> 由于没有这一远程数据处理，智能恒温器将无法履行其智能功能，没有它就会妨碍含数字元素产品履行其一项或多项功能。此外，该软件在智能恒温器制造商的责任下开发和设计。因此，该远程数据处理构成CRA所定义的RDPS。

For the purpose of CRA compliance, the manufacturer of the smart thermostat needs to document the RDPS as well as the reliance on the third-party IaaS in the technical documentation of the product with digital elements, including details of the contracted service. The manufacturer needs to consider those elements in the risk assessment, which includes the intended purpose and reasonably foreseeable use of the product with digital elements. The manufacturer implements the CRA's essential requirements based on the risks on the RDPS. For the third-party IaaS, the manufacturer needs to ensure that the security measures provided by the third-party provider are appropriate and/or take relevant measures vis-à-vis the infrastructure. For the former, the manufacturer could, for example, ask for evidence that NIS 2 obligations have been met.

> 就遵守CRA而言，智能恒温器的制造商需要在含数字元素产品的技术文件中记录RDPS以及对第三方IaaS的依赖，包括所订约服务的细节。制造商需要在风险评估中考虑这些要素，风险评估包括含数字元素产品的预期用途和可合理预见的使用。制造商基于风险在RDPS上实施CRA的基本要求。就第三方IaaS而言，制造商需要确保第三方提供者所提供的安全措施是适当的，和/或针对该基础设施采取相关措施。就前者而言，制造商可以例如要求提供NIS 2义务已得到履行的证据。

8.3.3 e-Reader
8.3.3 电子阅读器

The manufacturer of an e-Reader software uses a third-party SaaS storage service to store electronic books purchased by customers and enable them to access their books. The absence of this storage service would prevent the product with digital elements from performing one of its functions, but the third-party SaaS storage service is not developed by or under the responsibility of the manufacturer; the SaaS provider makes it available to customers for any use case.

> 电子阅读器软件的制造商使用第三方SaaS存储服务，以存储客户购买的电子书并使其能够访问其书籍。没有这一存储服务会妨碍含数字元素产品履行其功能之一，但该第三方SaaS存储服务并非由制造商或在其责任下开发；SaaS提供者将其提供给客户用于任何用例。

The SaaS storage service does not meet the definition of RDPS. However, the e-Reader manufacturer relies on that external service for the functioning of its product with digital elements and must therefore take the associated risks into account in its cybersecurity risk assessment. The e-Reader manufacturer should treat the SaaS like a component. The manufacturer must implement appropriate product-level security measures, such as secure authentication, encryption and

integrity protection of communications with the storage service. Due diligence when selecting and integrating the SaaS provider will also support the manufacturer's obligations, so that the product with digital elements as a whole can comply with the essential requirements.

> 该SaaS存储服务不符合RDPS的定义。然而，电子阅读器制造商依赖该外部服务以实现其含数字元素产品的功能，因此必须在其网络安全风险评估中考虑相关风险。电子阅读器制造商应当将SaaS像组件一样对待。制造商必须实施适当的产品层面安全措施，例如安全认证、加密以及对与存储服务之通信的完整性保护。在选择和集成SaaS提供者时开展尽职调查，也将支持制造商的义务，从而使作为整体的含数字元素产品能够符合基本要求。

8.3.4 Industrial robot
8.3.4 工业机器人

An industrial robot has the task of picking up parts. The robot sends information collected via cameras to a remote service designed and developed by the manufacturer. This service runs on an underlying physical and virtual infrastructure provided by a third-party service provider (third-party IaaS). The cloud service calculates the position of a part based on the camera feeds and sends commands back to the robot to pick up the parts.

> 工业机器人的任务是拾取零件。机器人将通过摄像头收集的信息发送到由制造商设计和开发的远程服务。该服务运行在第三方服务提供者提供的底层物理和虚拟基础设施上（第三方IaaS）。云服务根据摄像头馈送计算零件的位置，并将命令发回机器人以拾取零件。

The absence of this data processing would prevent the industrial robot from picking up parts, hence from performing one of its functions. Furthermore, the software running on top of the infrastructure has been designed and developed by the manufacturer. The software designed and developed by the manufacturer meets the definition of RDPS.

> 没有这一数据处理会妨碍工业机器人拾取零件，因而妨碍其履行功能之一。此外，在该基础设施之上运行的软件已由制造商设计和开发。由制造商设计和开发的软件符合RDPS的定义。

The manufacturer of the industrial robot needs to document the RDPS as well as the reliance on the third-party IaaS in the technical documentation of the product with digital elements (including details of the contracted service). The manufacturer also needs to consider those elements in the risk assessment, which includes the intended purpose and reasonably foreseeable use of the product with digital elements. The manufacturer implements the CRA's essential requirements on the product with digital elements, including its RDPS, on the basis of the risks. Due diligence when selecting the IaaS provider will also support the manufacturer's obligations. For example, the manufacturer could ask for evidence that NIS 2 obligations have been met.

> 工业机器人的制造商需要在含数字元素产品的技术文件中记录RDPS以及对第三方IaaS的依赖（包括所订约服务的细节）。制造商还需要在风险评估中考虑这些要素，风险评估包括含数字元素产品的预期用途和可合理预见的使用。制造商基于风险在含数字元素产品（包括其RDPS）上实施CRA的基本要求。在选择IaaS提供者时开展尽职调查，也将支持制造商的义务。例如，制造商可以要求提供NIS 2义务已得到履行的证据。

8.3.5 Cellular network
8.3.5 蜂窝网络

A smartphone relies on a 5G network to provide internet connection, phone calls and messages to its users (mobile connectivity). The cellular network is developed and designed by telecommunication operators. The network comprises small cells and cell towers, and other network equipment.

> 智能手机依赖5G网络向其用户提供互联网连接、电话和消息（移动连接）。蜂窝网络由电信运营商开发和设计。该网络包括小基站和信号塔以及其他网络设备。

The product with digital elements should be able to connect to a network correctly; this is one of its functions. However, whether that network is in operation or not is not relevant to ascertain if the product with digital elements is working correctly. The network is only a communication channel and is not necessary for the product with digital elements to perform its function of 'connecting to a network correctly'. Likewise, an ethernet cable, a router or Wi-Fi signal is not considered data processing whose absence would prevent the product with digital elements from performing one of its functions, but rather an enabler of communication/connectivity.

> 含数字元素产品应当能够正确连接到网络；这是其功能之一。然而，该网络是否在运行，与确定含数字元素产品是否正常工作无关。该网络只是通信信道，对于含数字元素产品履行其“正确连接到网络”的功能并非必要。同样，以太网电缆、路由器或Wi-Fi信号不视为如果没有它就会妨碍含数字元素产品履行其功能之一的数据处理，而是通信/连接的使能因素。

Consequently, the cellular network does not meet the definition of RDPS. The network should not be considered like a third-party component, as there is no software integrated into the product with digital elements, the product instead merely relying on this network. As such, it is not necessary for the manufacturer to exercise due diligence obligations towards the network provider.

> 因此，蜂窝网络不符合RDPS的定义。该网络不应被视为类似于第三方组件，因为没有软件被集成到含数字元素产品中，该产品只是依赖这一网络。因此，制造商没有必要对网络提供者履行尽职调查义务。

9 Additional elements
9 其他要素

9.1 Reporting obligations
9.1 报告义务

209. Under Article 14(1) and (3) of the CRA, a manufacturer is required to notify simultaneously to the CSIRT designated as coordinator and to ENISA of (i) any actively exploited vulnerability contained in its product with digital elements that it becomes aware of; and (ii) any severe incident having an impact on the security of the product with digital elements that it becomes aware of.

> 根据CRA第14条第1款和第3款，制造商必须同时向被指定为协调者的计算机安全事件响应小组（CSIRT）和欧盟网络安全局通知：(i) 其所知悉的、包含在其含数字元素产品中的任何已遭积极利用的漏洞；以及(ii) 其所知悉的、对含数字元素产品的安全有影响的任何严重事件。

210. In accordance with Article 69(3) and 71(2), second sentence, the obligation to comply with Article 14 applies from 11 September 2026 to all products with digital elements that fall within the scope of the CRA, including products with digital elements placed on the market before 11 December 2027. Furthermore, unlike the vulnerability handling obligations, which continue only for the length of a product's support period, the reporting obligations continue to apply after a product with digital elements is no longer supported. Where a product with digital elements was placed on the market before 11 December 2027, or where its support period has ended, the manufacturer is not required to comply with the vulnerability handling obligations set out in Part II of Annex I.

> 根据第69条第3款和第71条第2款第二句，遵守第14条的义务自2026年9月11日起适用于属于CRA适用范围的所有含数字元素产品，包括在2027年12月11日之前投放市场的含数字元素产品。此外，与仅在产品支持期期间继续适用的漏洞处理义务不同，报告义务在含数字元素产品不再受支持之后继续适用。如果含数字元素产品在2027年12月11日之前被投放市场，或者其支持期已经结束，则制造商不需要遵守附件I第二部分所规定的漏洞处理义务。

211. It should be recalled that the obligation to notify such events applies once the manufacturer becomes aware that a vulnerability is being actively exploited or that a severe incident has occurred and has led to the security of its product with digital elements being compromised. Therefore, guidance on when a manufacturer is deemed to have become aware should help manufacturers determine the moment when the applicable reporting deadlines start.

> 应当回顾，通知此类事件的义务，在制造商知悉某一漏洞正在被积极利用、或者某一严重事件已经发生并导致其含数字元素产品的安全遭到破坏时适用。因此，关于制造商在何时被视为已经知悉的指导，应当帮助制造商确定适用的报告期限自何时起算。

212. Manufacturers may be subject to comparable reporting obligations under different EU acts. To ensure the concept of 'becoming aware' is interpreted consistently and to facilitate manufacturers' compliance with those obligations, this guidance is aligned with recital 31 of Commission Implementing Regulation (EU) 2024/2690 and Section II(A) of the Guidelines 9/2022 on personal data breach notification under the GDPR.

> 制造商可能根据不同的欧盟法律文书负有可比的报告义务。为确保“知悉”这一概念得到一致解释，并便于制造商遵守这些义务，本指南与委员会实施条例(EU) 2024/2690序言第31项以及《关于GDPR项下个人数据泄露通知的第9/2022号指南》第二节(A)保持一致。

213. In some cases, a manufacturer will detect a suspicious event, or a third party, such as an individual, a customer, an entity, an authority, a media organisation or other source will bring a potential incident or vulnerability to its attention. In such cases, the manufacturer should assess the suspicious event immediately to determine whether it constitutes an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements. The manufacturer is therefore to be regarded as having become aware when, after such an initial assessment, it has a reasonable degree of certainty that: (i) a vulnerability contained in its product with digital elements is being actively exploited; or (ii) a severe incident has occurred and has led to the security of its product with digital elements being compromised.

> 在某些情况下，制造商将发现可疑事件，或者第三方，例如个人、客户、实体、机关、媒体组织或其他来源，将向其提请注意潜在事件或漏洞。在此类情况下，制造商应当立即评估该可疑事件，以确定它是否构成已遭积极利用的漏洞，或对含数字元素产品的安全有影响的严重事件。因此，在此类初步评估之后，当制造商具有合理程度的确定性，认为：(i) 包含在其含数字元素产品中的某一漏洞正在被积极利用；或(ii) 某一严重事件已经发生并导致其含数字元素产品的安全遭到破坏时，制造商应被视为已经知悉。

214. Therefore, the point in time at which a manufacturer can be considered to be aware will depend on the circumstances of the specific actively exploited vulnerability or severe incident. In some cases, it will be relatively clear from the outset that a vulnerability is being actively exploited or that a severe incident is impacting the security of a product with digital elements. In others, it may take some time to establish whether a product with digital elements is affected by a vulnerability and whether that vulnerability is being exploited by a malicious actor, or whether an incident is impacting the security of a product with digital elements. However, the emphasis should be on prompt action to carry out the initial assessment to determine whether such conditions are indeed met, particularly where the vulnerability may pose a significant risk, and if so, to take remedial action and notify in accordance with the CRA.

> 因此，制造商可以被视为知悉的时点，将取决于该特定已遭积极利用漏洞或严重事件的情形。在某些情况下，从一开始就相对清楚某一漏洞正在被积极利用，或某一严重事件正在影响含数字元素产品的安全。在其他情况下，可能需要一些时间来确定含数字元素产品是否受某一漏洞影响、该漏洞是否正被恶意行为者利用，或者某一事件是否正在影响含数字元素产品的安全。然而，重点应当是迅速采取行动进行初步评估，以确定此类条件是否确实得到满足，特别是在该漏洞可能造成重大风险的情况下，并且如果得到满足，则根据CRA采取补救行动并通知。

215. Furthermore, the structure of the reporting obligations requires manufacturers to update their notifications progressively, as their internal investigations advance and their knowledge of the actively exploited vulnerability or

incident becomes more detailed. In particular, manufacturers are required to submit an early warning notification containing limited information without undue delay and in any event within 24 hours of becoming aware. Additional information is subsequently required as part of the notification to be submitted without undue delay and in any event within 72 hours of becoming aware ('72-hour notification'). The complete report needs to be submitted within 14 days after a corrective or mitigating measure is available for actively exploited vulnerabilities, or within one month after the 72-hour notification for severe incidents.

> 此外，报告义务的结构要求制造商随着其内部调查的推进以及其对已遭积极利用漏洞或事件的了解变得更加详细，逐步更新其通知。特别是，制造商必须在知悉后无不适当迟延地、并且无论如何在24小时内，提交包含有限信息的预警通知。额外信息随后作为须在知悉后无不适当迟延地、并且无论如何在72小时内提交的通知的一部分被要求（“72小时通知”）。完整报告需要在已遭积极利用漏洞的纠正或缓解措施可用后14日内提交，或者就严重事件而言在72小时通知后一个月内提交。

216. As also recalled in Section 3.3.1 Sustained support and ensuring viability of FOSS, open-source software stewards are also required to report actively exploited vulnerabilities in accordance with Article 24(3)30. That obligation applies upon becoming aware of an actively exploited vulnerability, and not merely where a vulnerability exists in the codebase of a FOSS for which that entity is a steward. In practice, because FOSS components are typically integrated downstream into other products with digital elements, a steward is likely to become aware of active exploitation via reports from third parties, which identify exploitation in FOSS components as integrated into other products with digital elements. This may be the case, for example, where a manufacturer of a product with digital elements detects active exploitation in a FOSS component integrated into its own product and reports it to that component's steward; or when a user or a security researcher finds evidence of exploitation of a FOSS component integrated in a product with digital elements and reports that active exploitation to the component's steward.

> 正如第3.3.1节“持续支持并确保自由及开源软件的存续”亦所回顾的，开源软件管理者也必须根据第24条第3款报告已遭积极利用的漏洞30。该义务在知悉已遭积极利用的漏洞时适用，而不仅仅是在该实体担任管理者的自由及开源软件的代码库中存在漏洞时适用。在实践中，由于自由及开源软件组件通常在下游被集成到其他含数字元素产品中，管理者很可能通过第三方的报告知悉积极利用，这些报告识别出被集成到其他含数字元素产品中的自由及开源软件组件中的利用。例如，含数字元素产品的制造商在集成到其自己产品中的自由及开源软件组件中发现积极利用，并向该组件的管理者报告；或者用户或安全研究人员发现集成在含数字元素产品中的自由及开源软件组件被利用的证据，并将该积极利用报告给该组件的管理者，即可能如此。

217. It should also be clarified that, because the obligation to report actively exploited vulnerabilities applies when the manufacturer becomes aware of active exploitation, the manufacturer is not required to report vulnerabilities of whose active exploitation it had already become aware before 11 September 2026 (the date on which the reporting obligation starts to apply). The CRA, therefore, does not require the retroactive reporting of such vulnerabilities. By contrast, the obligation does apply where the manufacturer was aware of a vulnerability before 11 September 2026 but was not, at that time, aware of any active exploitation of it (either because none had yet occurred or because the manufacturer had not become aware of it). If, after 11 September 2026, active exploitation subsequently occurs or the manufacturer becomes aware of it, the vulnerability is deemed an actively exploited one subject to the reporting obligation.

> 还应当澄清，由于报告已遭积极利用漏洞的义务在制造商知悉积极利用时适用，制造商不需要报告其在2026年9月11日（报告义务开始适用之日）之前已经知悉其积极利用的漏洞。因此，CRA不要求对此类漏洞进行追溯报告。相反，如果制造商在2026年9月11日之前知悉某一漏洞，但在当时并不知悉对该漏洞的任何积极利用（或者因为尚未发生，或者因为制造商尚未知悉），则该义务确实适用。如果在2026年9月11日之后，积极利用随后发生或制造商知悉该积极利用，则该漏洞被视为受报告义务约束的已遭积极利用的漏洞。

30 To the extent that the steward is involved in the development of a product with digital elements.

> 30 以管理者参与含数字元素产品开发的范围为限。

218. Similarly, a manufacturer is only required to report actively exploited vulnerabilities contained in their product with digital elements. Where a product with digital elements contains an actively exploited vulnerability originating from a third-party component, the manufacturer of the product with digital elements is required to notify that actively exploited vulnerability. However, if a manufacturer is aware that a third-party component contains a vulnerability, but that vulnerability either (i) cannot be exploited in its product with digital elements (e.g. because the vulnerable code is not reachable) or (ii) has not been exploited in its product with digital elements, that vulnerability does not qualify as an actively exploited vulnerability contained in its product with digital elements, and therefore it is not subject to mandatory reporting for that manufacturer. That manufacturer can still notify that vulnerability on a voluntary basis, in accordance with Article 15 of the CRA. It is also required to comply with the vulnerability handling requirements of Part II of Annex I to the CRA, as well as to report the vulnerability to the person or entity manufacturing or maintaining the component, in accordance with Article 13(6), and as further explained in Section 9.2.1 Reporting upstream and sharing security fixes.

> 同样，制造商仅需要报告包含在其含数字元素产品中的已遭积极利用漏洞。如果含数字元素产品包含源于第三方组件的已遭积极利用漏洞，则该含数字元素产品的制造商必须通知该已遭积极利用的漏洞。然而，如果制造商知悉某一第三方组件包含漏洞，但该漏洞(i) 不能在其含数字元素产品中被利用（例如因为该易受攻击的代码不可到达），或(ii) 尚未在其含数字元素产品中被利用，则该漏洞不构成包含在其含数字元素产品中的已遭积极利用漏洞，因此对该制造商不须强制报告。该制造商仍然可以根据CRA第15条在自愿基础上通知该漏洞。它还必须遵守CRA附件I第二部分的漏洞处理要求，并根据第13条第6款向制造或维护该组件的人或实体报告该漏洞，详见第9.2.1节“向上游报告并分享安全修复”。

219. After becoming aware of an actively exploited vulnerability or a severe incident, manufacturers are also required, in accordance with Article 14(8), to inform impacted users and, where appropriate, all users. Where they fail to do so in a timely manner, the CSIRTs that received the notification may provide such information to users when this is considered proportionate and necessary to prevent or mitigate the impact of that vulnerability or incident.

> 在知悉已遭积极利用的漏洞或严重事件之后，制造商还必须根据第14条第8款告知受影响的用户，并在适当情况下告知所有用户。如果它们未能及时这样做，收到通知的CSIRT可以在认为相称且为防止或缓解该漏洞或事件的影响所必要时，向用户提供此类信息。

220. In line with the CRA’s risk-based approach, the obligation to inform users laid down in Article 14(8) is to be applied in a risk-based and proportionate manner. In particular, the provision of information about an actively exploited vulnerability or a severe incident does not imply that such information must be made public or disclosed indiscriminately. Where appropriate, and in light of the nature of the product with digital elements, the affected users and the vulnerability or incident’s potential impact, manufacturers may limit the disclosure of detailed information to the relevant users or customers concerned. This is particularly the case for products with digital elements used in sensitive or essential environments, where public disclosure of technical details could itself increase cybersecurity risks or facilitate further exploitation.

> 根据CRA基于风险的方法，第14条第8款所规定的告知用户的义务，应当以基于风险且相称的方式适用。特别是，提供关于已遭积极利用漏洞或严重事件的信息，并不意味着此类信息必须被公开或无差别披露。在适当情况下，并鉴于含数字元素产品的性质、受影响的用户以及该漏洞或事件的潜在影响，制造商可以将详细信息的披露限于有关的相关用户或客户。对于在敏感或关键环境中使用的含数字元素产品，尤其如此；在这些环境中，公开披露技术细节本身可能增加网络安全风险或便于进一步利用。

221. Once the vulnerability has been adequately addressed or mitigated, broader disclosure may be appropriate. This would be the case, for example, where disclosure contributes to raising general awareness or enables users to verify that their products with digital elements are no longer affected. In such cases, the level of detail and the timing of any broader disclosure should remain proportionate and take into account the residual risks of exploitation, the nature of the product with digital elements and the interests of the users concerned. Furthermore, point (4) of Part II of Annex I requires manufacturers to publicly disclose information about fixed vulnerabilities once a security update has been made available.

> 一旦漏洞已得到充分处理或缓解，更广泛的披露可能是适当的。例如，披露有助于提高一般认识，或使用户能够核实其含数字元素产品不再受影响，即属如此。在此类情况下，任何更广泛披露的详细程度和时间安排应当保持相称，并考虑剩余的利用风险、含数字元素产品的性质以及有关用户的利益。此外，附件I第二部分第(4)点要求制造商在安全更新可供使用后，公开披露关于已修复漏洞的信息。

9.2 Vulnerability handling
9.2 漏洞处理

9.2.1 Reporting upstream and sharing security fixes
9.2.1 向上游报告并分享安全修复

222. Article 13(6) of the CRA requires manufacturers to report vulnerabilities in integrated components to the person or entity manufacturing or maintaining that component (‘reporting upstream’).

> CRA第13条第6款要求制造商向制造或维护集成组件的人或实体报告集成组件中的漏洞（“向上游报告”）。

223. Manufacturers are required to report upstream only in respect of the version of the component that they integrate. Where the person or entity manufacturing or maintaining the component has established security policies, coordinated vulnerability disclosure processes or designated channels for reporting vulnerabilities, manufacturers should report in accordance with them, particularly where premature disclosure of unpatched vulnerabilities could increase cybersecurity risks. Furthermore, in order to reduce the burden on upstream maintainers, particularly in open-source projects, manufacturers are not required to report upstream where they can confirm that the person or entity manufacturing or maintaining a component is aware of the existence of a vulnerability. Manufacturers are encouraged to take reasonable steps to avoid the submission of duplicate reports, for example by checking publicly accessible vulnerability databases, project-specific security advisories, or established issue trackers before reporting upstream.

> 制造商仅需就其集成的组件版本向上游报告。如果制造或维护该组件的人或实体已经建立安全政策、协调漏洞披露流程或指定的漏洞报告渠道，制造商应当按照它们报告，特别是在过早披露未修补的漏洞可能增加网络安全风险的情况下。此外，为减轻上游维护者的负担，特别是在开源项目中，如果制造商能够确认制造或维护某一组件的人或实体已知悉某一漏洞的存在，则制造商不需要向上游报告。鼓励制造商采取合理步骤以避免提交重复报告，例如在向上游报告之前核查可公开访问的漏洞数据库、项目特定的安全公告或既有的问题跟踪器。

224. Manufacturers are required to report upstream only those vulnerabilities that exist in the integrated component itself, and not vulnerabilities that exist as a result of the integration between the component and other code developed by the manufacturer or by the integration of other components. Nonetheless, there may be situations in which a component’s integration into a specific product with digital elements reveals certain behaviours, interactions or security-relevant characteristics of that component that were not apparent, or not readily identifiable, in isolation. In such cases, manufacturers are encouraged to communicate this information to the person or entity manufacturing or maintaining the component, in order to foster good vulnerability-handling practices aimed at facilitating effective remediation and improving the overall security of the component ecosystem.

> 制造商仅需向上游报告存在于集成组件本身中的那些漏洞，而不是由于该组件与制造商开发的其他代码之间的集成、或由于其他组件的集成而存在的漏洞。尽管如此，可能存在如下情形：某一组件被集成到特定含数字元素产品中，揭示了该组件在孤立状态下并不明显或不易识别的某些行为、交互或与安全相关的特性。在此类情况下，鼓励制造商将这些信息告知制造或维护该组件的人或实体，以促进旨在便于有效补救并改善组件生态系统整体安全的良好漏洞处理做法。

225. Finally, manufacturers are also not required to report the vulnerability upstream where the component no longer has a maintainer, or when the manufacturer no longer relies on the original maintainer for new versions or security fixes. In such cases, the manufacturer is nonetheless encouraged to inform users of that component via reasonable alternative measures, e.g. through existing community mechanisms (such as mailing lists or issue tickets) or through public vulnerability records.

> 最后，如果该组件不再有维护者，或者制造商不再依赖原维护者提供新版本或安全修复，制造商也不需要向上游报告该漏洞。在此类情况下，尽管如此，鼓励制造商通过合理的替代措施告知该组件的用户，例如通过既有的社区机制（如邮件列表或问题工单）或通过公开的漏洞记录。

226. Furthermore, under Article 13(6) manufacturers that have developed a software modification to address a vulnerability in an integrated component are required to share that software modification ('security fix') with the person or entity manufacturing or maintaining the component ('sharing upstream').

> 此外，根据第13条第6款，已开发软件修改以处理集成组件中漏洞的制造商，必须与制造或维护该组件的人或实体分享该软件修改（“安全修复”）（“向上游分享”）。

227. Where manufacturers are required to share a security fix under Article 13(6), the fix should, where appropriate, be provided in a machine-readable format, in a manner that can be easily verified and, where appropriate, integrated by the person or entity manufacturing or maintaining the component. Where the component is a free and open-source component, the security fix should be shared in a manner compatible with that component's licence, for example by sharing it under the same licence or under a licence that allows the maintainer to distribute the fix under its own licence. Where the maintainer of that component has guidelines on how security fixes should be shared, the manufacturer should follow those guidelines.

> 如果制造商根据第13条第6款必须分享安全修复，则该修复在适当情况下应当以机器可读格式提供，以便于核验，并在适当情况下便于制造或维护该组件的人或实体予以集成。如果该组件是自由及开源组件，安全修复应当以与该组件的许可相容的方式分享，例如依据同一许可分享，或依据允许维护者在其自己的许可下分发该修复的许可分享。如果该组件的维护者有关于安全修复应当如何分享的指南，制造商应当遵循这些指南。

228. However, manufacturers are not required by the CRA to ensure that their security fixes are necessarily accepted by the person or entity manufacturing or maintaining the component. Nor are they required to ensure that those fixes are necessarily integrated into the component's code repository, for instance where the maintainer may prefer a different option to fix the issue. Similarly, manufacturers are not required to accept a proposed fix developed by the component maintainer, and may prefer to mitigate the issue in other suitable ways.

> 然而，CRA并不要求制造商确保其安全修复必然被制造或维护该组件的人或实体接受。它们也不需要确保这些修复必然被集成到该组件的代码存储库中，例如在维护者可能更倾向于以不同方式修复该问题的情况下。同样，制造商不需要接受由组件维护者开发的拟议修复，并可以更倾向于以其他适当方式缓解该问题。

229. In some cases, the person or entity manufacturing or maintaining the component may have already provided a security fix to address the vulnerability, but a manufacturer implements a different mitigation strategy (for example by changing a different configuration). In such cases, the CRA does not require the manufacturer to share the modification of another part of the system upstream. The manufacturer is nonetheless encouraged to do so where this can support the person or entity maintaining the component.

> 在某些情况下，制造或维护该组件的人或实体可能已经提供安全修复以处理该漏洞，但制造商实施不同的缓解策略（例如通过改变另一配置）。在此类情况下，CRA不要求制造商向上游分享对系统另一部分的修改。尽管如此，如果这样做能够支持维护该组件的人或实体，则鼓励制造商这样做。

9.2.2 Known exploitable vulnerabilities
9.2.2 已知可利用漏洞

230. One of the essential requirements of Part I of Annex I to the CRA provides that, on the basis of the cybersecurity risk assessment referred to in Article 13(2), and where applicable, products with digital elements must be made available on the market without known exploitable vulnerabilities.

> CRA附件I第一部分的基本要求之一规定，基于第13条第2款所指的网络安全风险评估，并在适用的情况下，含数字元素产品必须在没有已知可利用漏洞的情况下在市场上提供。

231. Article 3(41) defines 'exploitable vulnerability' as 'a vulnerability that has the potential to be effectively used by an adversary under practical operational conditions'. Not all vulnerabilities are exploitable under practical operational conditions, and some vulnerabilities can only be exploited in theoretical conditions (e.g. in a lab or in a simulation) and/or not under conditions which would occur in the operational environment of a product with digital elements.

> 第3条第41款将“可利用漏洞”定义为“在实际运行条件下有可能被对手有效利用的漏洞”。并非所有漏洞在实际运行条件下都可利用，某些漏洞只能在理论条件下被利用（例如在实验室中或在模拟中），和/或不能在含数字元素产品的运行环境中会发生的条件下被利用。

232. The CRA requires manufacturers to have appropriate policies and procedures to handle and remediate potential vulnerabilities reported from internal or external sources (Article 13(8)). However, it does not explicitly specify when an exploitable vulnerability should be considered to be known by the manufacturer, thereby triggering the obligation to comply with this essential requirement at the moment of placement on the market.

> CRA要求制造商具有适当的政策和程序，以处理和补救从内部或外部来源报告的潜在漏洞（第13条第8款）。然而，它并未明确规定可利用漏洞在何时应被视为制造商已知，从而在投放市场之时引发遵守这一基本要求的义务。

233. A vulnerability should be regarded as known when it is listed in relevant publicly accessible vulnerability databases, such as the European vulnerability database established by Article 12(2) of Directive (EU) 2022/2555 or other prominent vulnerability databases.

> 漏洞在被列入相关可公开访问的漏洞数据库时，应当被视为已知，例如指令(EU) 2022/2555第12条第2款所建立的欧洲漏洞数据库，或其他主要漏洞数据库。

234. Additionally, a vulnerability may also be known when the manufacturer has been made aware of it via non-public information, for example via coordinated disclosure by a security researcher or through the manufacturer's own internal testing and analysis, including, for example, when making use of AI-powered services. Likewise, a vulnerability may be known when it has been publicly and prominently reported in reliable media outlets, including specialised cybersecurity publications or general mass media.

> 此外，如果制造商通过非公开信息知悉某一漏洞，该漏洞也可以是已知的，例如通过安全研究人员的协调披露，或通过制造商自己的内部测试和分析，例如包括在使用人工智能驱动的服务时。同样，如果漏洞已在可靠的媒体中被公开且显著地报道，包括专业网络安全出版物或大众媒体，该漏洞也可以是已知的。

235. Nevertheless, the mere fact that a vulnerability is reported or found does not, in itself, mean that it is exploitable in practice or applicable to the specific product with digital elements concerned. The manufacturer will need to investigate it and confirm the veracity of such information and applicability to its own product with digital elements. Accordingly, a limited period of time may elapse between the first report of the vulnerability and its confirmation. As indicated in Section 9.1 Reporting obligations, the emphasis should be on prompt action to investigate and react.

> 尽管如此，漏洞被报告或被发现，仅此事实本身并不意味着它在实践中可利用，或适用于所涉特定含数字元素产品。制造商将需要调查它，并确认此类信息的真实性及其对自己的含数字元素产品的适用性。因此，在

> 漏洞的首次报告与其确认之间，可能经过一段有限的时间。正如第9.1节“报告义务”所指出的，重点应当是迅速采取行动进行调查和应对。

236. Furthermore, the obligation for manufacturers to comply with the essential requirements set out in Part I of Annex I applies at the moment of placement on the market, in accordance with Article 13(1). In practice, it may be the case that new potentially exploitable vulnerabilities are discovered during the final stages of the development lifecycle of the product with digital elements, including shortly before it enters the distribution chain (and is therefore placed on the market).

> 此外，制造商遵守附件I第一部分所载基本要求的义务，根据第13条第1款在投放市场之时适用。在实践中，可能出现如下情形：在含数字元素产品开发生命周期的最后阶段，包括在它进入分销链（并因而被投放市场）之前不久，发现新的潜在可利用漏洞。

237. As the obligation to place products with digital elements on the market without known exploitable vulnerabilities is a risk-based obligation, it falls upon the manufacturer to determine whether, on the basis of the cybersecurity risk assessment, the product with digital elements can be securely placed on the market, in compliance with the CRA. Alternatively, the manufacturer may determine that a new vulnerability that may have become known needs to be fixed before the product with digital elements can be placed on the market. In making that determination, manufacturers should take into account the severity, exploitability and potential impact of the vulnerability, as well as the risks arising for the product with digital elements itself once in use. They may also take into account the risks of postponing the product’s release until the vulnerability is fixed, for example because the new release also addresses other exploitable vulnerabilities, or is necessary for the continued operation of critical systems. In any case, once a product with digital elements is placed on the market, the manufacturer remains subject to the obligation to handle vulnerabilities effectively and in accordance with the vulnerability handling requirements set out in Part II of Annex I.

> 由于在没有已知可利用漏洞的情况下将含数字元素产品投放市场的义务是一项基于风险的义务，由制造商根据网络安全风险评估确定该含数字元素产品能否在遵守CRA的情况下被安全地投放市场。或者，制造商可以确定，在含数字元素产品能够被投放市场之前，需要修复一项可能已成为已知的新漏洞。在作出该决定时，制造商应当考虑该漏洞的严重程度、可利用性和潜在影响，以及含数字元素产品一旦投入使用本身所产生的风险。它们也可以考虑将产品发布推迟到漏洞被修复为止的风险，例如因为新发布也处理其他可利用漏洞，或为关键系统的持续运行所必要。无论如何，一旦含数字元素产品被投放市场，制造商仍然负有有效处理漏洞并符合附件I第二部分所规定的漏洞处理要求的义务。

9.2.3 Effective and regular tests and reviews
9.2.3 有效且定期的测试和审查

238. Point (3) of Part II of Annex I requires manufacturers to apply effective and regular tests and reviews of the product with digital elements throughout its support period. Applying regular tests does not require the mechanical repetition, at fixed intervals, of an unchanged test campaign. It means regularly reviewing whether new input, such as newly identified threats or newly discovered vulnerabilities, requires the existing tests to be updated, and executing tests accordingly.

> 附件I第二部分第(3)点要求制造商在其支持期全程对含数字元素产品实施有效且定期的测试和审查。实施定期测试，并不要求以固定间隔机械重复不变的测试活动。它意味着定期审查新的输入，例如新识别的威胁或新发现的漏洞，是否要求更新既有测试，并相应执行测试。

239. The frequency, depth and content of the review should be proportionate to the cybersecurity risk profile of the product with digital elements, its evolution over time, and the state of the threat landscape. Where the review identifies relevant new input affecting the test set, new or modified tests should be devised and executed on the product, to ensure that no vulnerabilities remain unaddressed. This may include re-executing existing tests where a modification to the product with digital elements makes such types of testing appropriate, such as regression testing.

> 审查的频率、深度和内容应当与含数字元素产品的网络安全风险状况、其随时间的演变以及威胁态势相称。如果审查识别出影响测试集的相关新输入，应当设计并在产品上执行新的或经修改的测试，以确保没有漏洞得不到处理。这可以包括在对含数字元素产品的修改使此类测试适当的情况下重新执行既有测试，例如回归测试。

240. Where the review identifies no such input, additional tests need not be devised. Other vulnerability handling obligations, including that of addressing and remediating vulnerabilities in relation to the risks posed, continue to apply in parallel.

> 如果审查未识别出此类输入，则不必设计额外测试。其他漏洞处理义务，包括处理和补救与所造成风险有关的漏洞的义务，继续并行适用。

9.3 Interplay with other legislation
9.3 与其他立法的相互关系

9.3.1 Regulation (EU) 2019/2144 and Regulation (EU) No 168/2013
9.3.1 条例(EU) 2019/2144和条例(EU) No 168/2013

241. Point (c) of Article 2(2) of the CRA establishes that the Regulation does not apply to products with digital elements to which Regulation (EU) 2019/2144 applies. Regulation (EU) 2019/2144 applies to 'vehicles of categories M, N and O, as defined in Article 4 of Regulation (EU) 2018/858, and to systems, components and separate technical units designed and constructed for such vehicles'.

> CRA第2条第2款(c)项规定，本条例不适用于条例(EU) 2019/2144所适用的含数字元素产品。条例(EU) 2019/2144适用于“条例(EU) 2018/858第4条所定义的M、N和O类车辆，以及为此类车辆设计和制造的系统、部件和单独技术单元”。

242. Similarly, products with digital elements falling within the scope of Regulation (EU) No 168/2013 have been excluded from the scope of the CRA by Commission Delegated Regulation (EU) 2025/1535. Regulation (EU) 168/2013 applies to L-category vehicles and 'to systems, components and separate technical units, as well as parts and equipment, designed and constructed for such vehicles' (Article 2(1)).

> 同样，属于条例(EU) No 168/2013适用范围的含数字元素产品，已由委员会授权条例(EU) 2025/1535排除在CRA适用范围之外。条例(EU) 168/2013适用于L类车辆，以及“为此类车辆设计和制造的系统、部件和单独技术单元，以及零件和设备”（第2条第1款）。

243. Vehicles to which those Regulations apply are not subject to the CRA. Furthermore, additional clarifications are necessary as regards the scope of the exemption for systems, components, separate technical units, parts and equipment (for the sake of this section, 'components') designed and constructed for such vehicles that are deemed to be products with digital elements within the meaning of the CRA.

> 这些条例所适用的车辆不受CRA约束。此外，就为被视为CRA意义上含数字元素产品的此类车辆设计和制造的系统、部件、单独技术单元、零件和设备（就本节而言，称“组件”）的豁免范围，需要额外澄清。

244. It is considered that such components are not subject to the CRA, provided that they are exclusively designed and constructed for integration into vehicles covered by Regulations (EU) 2019/2144 and No 168/2013. This is the case regardless of whether the manufacturer of that component sells it directly to the vehicle manufacturer or to another economic operator in the automotive supply chain, as long as the component is clearly intended and suitable only for ultimate integration within those vehicles.

> 此类组件不视为受CRA约束，但前提是它们专为集成到条例(EU) 2019/2144和No 168/2013所涵盖的车辆中而设计和制造。不论该组件的制造商将其直接销售给车辆制造商，还是销售给汽车供应链中的另一经济经营者，均属如此，只要该组件明确仅旨在并仅适合于最终集成到这些车辆中。

245. By contrast, a manufacturer that sells generic components that are products with digital elements that can be integrated into different types of products, and not exclusively into vehicles covered by those Regulations, is subject to the CRA.

> 相反，销售通用组件的制造商，如果这些组件是可以集成到不同类型产品中、而不是专用于这些条例所涵盖车辆的含数字元素产品，则受CRA约束。

246. The assessment of whether a component is placed on the market within the meaning of the CRA must be based on the objective conditions under which it is made available. Where a manufacturer offers a component that is not exclusively suitable for ultimate integration within those vehicles through distribution channels that are open to customers outside the automotive supply chain, such as general retail outlets or online sales channels accepting orders from the general public, that component falls within the scope of the CRA, irrespective of any statements concerning its intended use. In such circumstances, the component cannot be considered as being designed and constructed exclusively for integration into vehicles covered by Regulations (EU) 2019/2144 and No 168/2013, and the manufacturer is required to comply with the CRA. By contrast, the use of restricted, business-to-business distribution channels limited to the automotive supply chain may indicate that it is designed and constructed exclusively for such integration.

> 关于某一组件是否在CRA意义上被投放市场的评估，必须基于其被提供的客观条件。如果制造商通过向汽车供应链以外的客户开放的分销渠道，提供并非仅适合于最终集成到这些车辆中的组件，例如一般零售网点或接受公众订单的在线销售渠道，则该组件属于CRA的适用范围，不论关于其预期用途的任何声明如何。在此类情形下，该组件不能被视为专为集成到条例(EU) 2019/2144和No 168/2013所涵盖的车辆中而设计和制造，制造商必须遵守CRA。相反，使用限于汽车供应链的、受限制的企业对企业分销渠道，可以表明它是专为此类集成而设计和制造的。

9.3.2 Validity of EU type-examination certificates (Article 69(1))
9.3.2 欧盟型式检验证书的有效性（第69条第1款）

247. Article 69(1) of the CRA states that ‘EU type-examination certificates and approval decisions issued regarding cybersecurity requirements for products with digital elements that are subject to Union harmonisation legislation other than this Regulation shall remain valid until 11 June 2028, unless they expire before that date, or unless otherwise specified in such other Union harmonisation legislation, in which case they shall remain valid as referred to in that legislation’.

> CRA第69条第1款规定：“就受本条例以外的联盟协调立法约束的含数字元素产品的网络安全要求所签发的欧盟型式检验证书和批准决定，应当保持有效至2028年6月11日，除非它们在该日之前到期，或除非该其他联盟协调立法另有规定；在后一种情况下，它们应当按照该立法所指的方式保持有效”。

248. The continued validity of such certificates and approval decisions should be understood as being limited to the cybersecurity risks and corresponding requirements that are covered by the respective Union harmonisation legislation on the basis of which they were issued. For those risks, manufacturers are not required to reassess or re-demonstrate compliance solely for the purposes of the CRA during the period of validity referred to in Article 69(1) for products with digital elements they intend to place on the market on or after 11 December 2027 and until 11 June 202831. This is the case for certificates and approval decisions issued where the applicable Union harmonisation legislation requires the manufacturer to perform the conformity assessment procedure via a notified body, as well as where the manufacturer has voluntarily chosen to do so.

> 此类证书和批准决定的持续有效，应理解为限于签发它们所依据的各自联盟协调立法所涵盖的网络安全风险和相应要求。就这些风险而言，对于制造商拟在2027年12月11日或之后至2028年6月11日投放市场的含数字元素产品，在第69条第1款所指的有效期内，制造商不需要仅为CRA的目的重新评估或重新证明合规31。对于适用的联盟协调立法要求制造商通过公告机构实施合格评定程序而签发的证书和批准决定，以及制造商自愿选择这样做的情形，均属如此。

31 Products with digital elements placed on the market before 11 December 2027 are subject to Union legislation applicable at the time of their placing on the market and, if they were compliant, they can be sold and put into operation, unless they are, on or after 11 December 2027, subjected to substantial modifications. For the concept of 'placing on the market' and 'making available on the market', see also Section 2.1 Placing on the market of this document as well as Chapter 2 of the Blue Guide.

> 31 在2027年12月11日之前投放市场的含数字元素产品，受其投放市场时适用的联盟立法约束；如果它们当时是合规的，则可以销售并投入运行，除非它们在2027年12月11日或之后受到实质性修改。关于“投放市场”和“在市场上提供”的概念，另见本文件第2.1节“投放市场”以及《蓝皮书》第2章。

249. Accordingly, the existence of a valid certificate or approval decision under other Union harmonisation legislation does not exempt manufacturers from carrying out a comprehensive cybersecurity risk assessment under the CRA (or from other obligations under it). Instead, it allows them to rely on existing certifications as evidence of compliance for their conformity assessment procedure, to the extent that the corresponding cybersecurity risks are already covered. Where the certificate or approval decision has validity under other Union harmonisation legislation extending beyond 11 June 2028, the manufacturer may nonetheless rely on such certificate or decision for the purposes of the CRA only until 11 June 2028.

> 因此，根据其他联盟协调立法存在有效证书或批准决定，并不免除制造商根据CRA开展全面网络安全风险评估（或免除其在CRA项下的其他义务）。相反，它允许它们在相应网络安全风险已经被涵盖的范围内，依赖既有认证作为其合格评定程序的合规证据。如果证书或批准决定根据其他联盟协调立法的有效期延长到2028年6月11日之后，制造商就CRA的目的仍然只能依赖该证书或决定至2028年6月11日。

250. Where the cybersecurity risk assessment carried out in accordance with Article 13(2) identifies additional risks not covered by the cybersecurity requirements underpinning the existing certificate or approval decision, manufacturers remain responsible for addressing those risks in accordance with the CRA. In such cases, compliance requires that the identified gaps be assessed and mitigated, irrespective of the continued validity of the existing certificate or approval decision.

> 如果根据第13条第2款开展的网络安全风险评估识别出既有证书或批准决定所依据的网络安全要求未涵盖的额外风险，制造商仍然负责根据CRA处理这些风险。在此类情况下，合规要求已识别的差距得到评估和缓解，不论既有证书或批准决定是否继续有效。

251. This can be illustrated by considering the case where a product with digital elements is subject to the cybersecurity requirements laid down in Commission Delegated Regulation (EU) 2022/30 supplementing Directive 2014/53/EU (the Radio Equipment Directive (RED) Delegated Act), and where an EU type-examination certificate or approval decision has been issued on the basis of those requirements. In that case, the certificate or decision remains valid, in accordance with Article 69(1), for the cybersecurity risks that are covered by that certificate and related to the cybersecurity essential requirements of Directive 2014/53/EU (the Radio Equipment Directive, or 'RED').

> 这一点可以通过如下情形说明：含数字元素产品受补充指令2014/53/EU的委员会授权条例(EU) 2022/30（《无线电设备指令》（RED）授权法案）所规定的网络安全要求约束，并且已基于这些要求签发欧盟型式检验证书或批准决定。在该情况下，根据第69条第1款，该证书或决定就该证书所涵盖的、与指令2014/53/EU（《无线电设备指令》，或“RED”）的网络安全基本要求有关的网络安全风险保持有效。

252. In such cases, manufacturers are not required, for the purposes of the CRA, to reassess or re-demonstrate compliance in respect of those risks already addressed by those certificates, for as long as the relevant certificate or approval decision

remains valid and, in any event, not beyond 11 June 2028. This includes, for example, cybersecurity risks related to network protection, protection of personal data and privacy or prevention of fraud (to the extent that those risks are covered by that certificate) related to the RED cybersecurity requirements and reflected in the conformity assessment.

> 在此类情况下，就CRA的目的而言，制造商不需要就这些证书已经处理的那些风险重新评估或重新证明合规，只要相关证书或批准决定保持有效，并且无论如何不超过2028年6月11日。例如，这包括与网络保护、个人数据和隐私保护或防止欺诈有关的网络安全风险（以这些风险被该证书涵盖为限），这些风险与RED的网络安全要求有关并反映在合格评定中。

253. However, where the cybersecurity risk assessment carried out in accordance with Article 13(2) of the CRA identifies additional cybersecurity risks not covered by those certificates, manufacturers remain responsible for addressing those risks in accordance with the CRA. This may include, for example, risks related to vulnerability handling processes, data minimisation, and reduction of the attack surface, or other product-specific cybersecurity aspects not addressed by those certificates or, in any case, not covered by the RED cybersecurity essential requirements.

> 然而，如果根据CRA第13条第2款开展的网络安全风险评估识别出这些证书未涵盖的额外网络安全风险，制造商仍然负责根据CRA处理这些风险。例如，这可以包括与漏洞处理流程、数据最小化以及缩小攻击面有关的风险，或其他这些证书未处理的、或者无论如何未被RED网络安全基本要求涵盖的产品特定网络安全方面。

254. Accordingly, the existence of a valid EU type-examination certificate or approval decision under the RED for its essential requirements relating to cybersecurity does not, in itself, demonstrate full compliance with the CRA. Instead, it allows manufacturers to rely on that certificate or decision as evidence of compliance for the corresponding risks, while ensuring that any remaining or newly identified risks are assessed and mitigated in accordance with the CRA.

> 因此，根据RED就其与网络安全有关的基本要求存在有效的欧盟型式检验证书或批准决定，其本身并不证明完全遵守CRA。相反，它允许制造商依赖该证书或决定作为相应风险的合规证据，同时确保任何剩余的或新识别的风险根据CRA得到评估和缓解。

255. Similarly, where a product with digital elements is subject to the cybersecurity-related essential health and safety requirements laid down in Regulation (EU) 2023/1230 (the Machinery Regulation), fully applicable as of 20 January 2027, and where an EU type-examination certificate or approval decision has been issued on the basis of those requirements, that certificate or approval decision remains valid, in accordance with Article 69(1) of the CRA, for the cybersecurity risks covered by the Machinery Regulation.

> 同样，如果含数字元素产品受条例(EU) 2023/1230（《机械条例》）所规定的与网络安全有关的基本健康和安全要求约束，该条例自2027年1月20日起全部适用，并且已基于这些要求签发欧盟型式检验证书或批准决定，则根据CRA第69条第1款，该证书或批准决定就《机械条例》所涵盖的网络安全风险保持有效。

256. In particular, this concerns cybersecurity aspects related to the protection against corruption and the safety and reliability of control systems, as set out in Sections 1.1.9 and 1.2.1 of Annex III to the Machinery Regulation. For those risks, manufacturers are not required, for the purposes of the CRA, to reassess or re-demonstrate compliance for as long as the relevant certificate or approval decision remains valid and, in any event, not beyond 11 June 2028. This applies insofar as those risks have been addressed as part of the conformity assessment under the Machinery Regulation.

> 特别是，这涉及与防止损坏以及控制系统的安全和可靠性有关的网络安全方面，如《机械条例》附件III第1.1.9节和第1.2.1节所规定的。就这些风险而言，就CRA的目的，制造商不需要重新评估或重新证明合规，只要相关证书或批准决定保持有效，并且无论如何不超过2028年6月11日。这在这些风险已作为《机械条例》项下合格评定的一部分得到处理的范围内适用。

257. As with the RED cybersecurity essential requirements mentioned above, where the cybersecurity risk assessment carried out pursuant to Article 13(2) of the CRA identifies additional cybersecurity risks that are not covered by the

relevant certificate issued pursuant to the Machinery Regulation and that are related to the cyber-safety requirements of that Regulation, manufacturers remain responsible for addressing those risks in accordance with the CRA.

> 与上文所述的RED网络安全基本要求一样，如果根据CRA第13条第2款开展的网络安全风险评估识别出根据《机械条例》签发的相关证书未涵盖的、并且与该条例的网络安全性要求有关的额外网络安全风险，制造商仍然负责根据CRA处理这些风险。